

Quantifying Compromise Risk in Exceptional Access Architectures Under Sparse and Indirect Evidence

Alan Woodward ¹

¹Surrey Centre for Cyber Security, University of Surrey,
Guildford GU2 7XH, UK,

alan.woodward@surrey.ac.uk,

Approximate word count: 25,600 (main text excluding abstract, tables, figures, captions, and references).

Contents

1	Introduction	6
1.1	Decision Support Objective	7
1.2	The Four Analytical Layers	7
1.3	Motivating Cases	8
1.4	Structure of the Paper	9
1.5	Principal Findings at a Glance	9
2	Background and Related Work	12
2.1	Exceptional Access Systems	12
2.2	Cyber Risk Quantification	12
2.3	Empirical Sources and Evidential Status	13
3	System and Threat Model	13
3.1	Abstract EA Architecture	13
3.1.1	Architectural Taxonomy	14
3.2	Adversary Model	15
3.3	Compromise Definitions	15
3.4	Notation Summary	17
4	Framework Architecture and Epistemic Foundations	17
4.1	Rationale for a Multi-Method Approach	17
4.2	The Epistemic Status of Framework Outputs	18
4.3	Preview of the Synthesis Hierarchy	18
5	Pillar I: Historical Analogy Analysis	19
5.1	Stream A: Government High-Security Systems	19
5.1.1	Empirical Dataset	19
5.1.2	Maximum Likelihood and Bayesian Estimation	20
5.1.3	Summary	21
5.2	Stream B: Certificate Authority Cohort	21
5.3	Stream C: Platform-Level Key/Data Compromise Cohort	22
5.3.1	Inclusion Criteria	22
5.3.2	Empirical Dataset	22

5.3.3	Cohort Population and Rate Estimation	23
5.3.4	Architectural Caveats and Cross-Stream Comparison	24
5.4	Cross-Stream Meta-Analysis	24
6	Pillar II: Prospective Scenario Model	26
6.1	Model Architecture and Epistemic Framing	27
6.2	Two-Tier Adversary Model and Parameter Structure	27
6.3	Architecture-Conditional Outcome Decomposition	27
6.3.1	T-EA Outcome Decomposition	27
6.3.2	OTT-EA Outcome Decomposition	28
6.3.3	System-Level Aggregation	28
6.3.4	Calibration of ξ_i , P_3 , and P_4	28
6.4	System-Level Annual Projections	29
6.4.1	T-EA projections	29
6.4.2	OTT-EA projections	29
6.4.3	T-EA and OTT-EA central comparison	30
6.5	Fréchet–Hoeffding Bounding Analysis	31
6.5.1	T-EA bounds	31
6.5.2	OTT-EA bounds	32
6.5.3	Architectural comparison and the segregation gain	32
6.6	Sensitivity Analysis	32
6.6.1	Common parameters: APT mixing and uplift	33
6.6.2	OTT-specific parameters: P_3 , P_4 , and ξ_i	33
6.6.3	Scenario ordering and sensitivity reporting	33
7	Pillar III: Architectural Heuristic Decomposition	33
7.1	Rationale and Approach	33
7.2	Four Non-Eliminable Component Risk Channels	34
7.3	Per-Channel Cross-Cutting Fractions	35
7.4	Architecture-Conditional Channel-Aggregate Projection Estimates	35
7.4.1	T-EA channel-aggregate projection	35
7.4.2	OTT-EA channel-aggregate projection	36
7.4.3	Channel-minimum heuristics	36
7.5	Sensitivity Analysis	36
7.6	Independence Assumption and Its Status	36
8	The Bayesian Structural Risk Model (Layer IV)	37
8.1	Overview and Rationale	37
8.2	Attack Graph Model	38
8.2.1	T-EA attack graph	38
8.2.2	OTT-EA compound attack graph	38
8.2.3	Hazard rates and attack-path aggregation	40
8.3	Bayesian Hierarchical Model	40
8.3.1	Priors for edge hazard rates	40
8.3.2	Hyperpriors	41
8.3.3	EA-specific system modifiers	41
8.4	Domain Transfer	41
8.5	Dependence Modelling	42
8.5.1	T-EA dependence: uniform coupling	42
8.5.2	OTT-EA dependence: cross-cutting coupling	42
8.5.3	Architectural consequence: tail expansion under correlation	43
8.6	Adversarial Targeting Layer	43

8.7	Simulation Procedure	43
8.8	Structural Lower Bound and Stochastic Dominance	44
9	Results	46
9.1	Three-Pillar Framework: Consolidated Outputs	46
9.2	Which Quantity Answers Which Question	46
9.3	Bayesian Layer: Distributional Results	48
9.4	Effect of Dependence	48
9.4.1	Conditional sensitivity to γ_X/γ	50
9.4.2	Robustness	50
9.5	Tail Risk Characterisation	51
9.6	Cumulative Risk	52
9.7	Exceedance Probabilities Over Policy Thresholds	53
9.8	Prior Sensitivity for Exceedance Probabilities	56
9.9	Parameter Uncertainty Decomposition	57
9.9.1	EVPPI-style variance decomposition	58
10	Synthesis: What the Framework Collectively Establishes	60
10.1	Structural Versus Calibration-Dependent Results	60
10.2	The Role of the Bayesian Layer	61
10.3	The Shared Structural Assumption and Its Limits	62
10.4	The Evidence Base for a Material Risk Finding	62
10.5	The Stochastic Dominance Floor	63
10.6	What the Full Framework Establishes	63
11	Discussion of Limitations	64
11.1	The Fundamental Epistemic Gap	64
11.2	Bayesian Prior Calibration and the Limits of the Median	65
11.3	The EA Targeting Premium	65
11.4	Regulatory Defensive Uplift: The Unmodelled Counterfactual	66
11.5	The Cross-Cutting Coupling Ratio γ_X/γ	67
11.6	Pillar II/III Calibration Validity	68
11.7	Statistical Methodology and Inferential Status	68
11.8	Temporal Robustness, Inclusion Sensitivity, and Operator Heterogeneity	69
11.9	Falsifiable Implications	70
12	Policy Implications	70
12.1	The Policy Question Reframed	71
12.2	Interpreting the Probabilities	71
12.3	Risk Profile Summary	71
12.4	EA Adds a New Risk Surface	71
12.5	The Irreversibility Asymmetry	72
12.6	Implications from the Bayesian Model	73
12.7	Architectural Alternatives: Threshold Schemes	73
12.8	Hybrid Client-Side Scanning Architectures	73
12.9	Investment in Characterising Uncertainty	74
13	Conclusion	74
S1	Notation, Conventions, and Reproducibility	76
S1.1	Notation summary	76
S1.2	Reproducibility	76

S2	Stream A: Government High-Security Systems Cohort	77
S2.1	Denominator construction	77
S2.2	Incident classification	77
S3	Stream B: Certificate Authority Cohort	78
S3.1	Inclusion criteria	78
S3.2	Cohort definition and exposure	79
S3.3	Incident list	79
S3.4	Rate estimation and sensitivity	79
S4	Stream C: Platform Incident Base and Operator Inventory	80
S4.1	Per-incident documentation	81
S4.2	Near-miss exclusion: Cloudflare 2023	83
S4.3	Operator inventory ($N_C = 75$)	83
S4.4	Stratified rate calculation	84
S5	Architecture-Conditional Structural Adjustment Dimensions	84
S5.1	The seven adjustment dimensions	84
S5.2	Composition under independence	85
S5.3	Sensitivity to dimension-by-dimension perturbation	85
S5.4	Treatment of dependence in the dimension transfer	86
S6	Prior Sensitivity for Exceedance Probabilities	86
S7	Edge Log-Hazard Specification	87
S8	OTT-EA Parameter Uncertainty Decomposition	87
S9	Pillar II Monte Carlo: Prior Specification	88
S10	Pillar II OTT-EA Sensitivity Grid	88
S11	Pillar III OTT-EA Sensitivity Grid	89
S12	Detailed EVPPI Variance Decomposition	89
S13	Attack Graph Topology Sensitivity	90
S14	Pillar II Sensitivity Figures	90
S15	Non-stationary Cumulative Trajectory	93
S16	Threshold-Scheme Quantitative Contrast	93
S17	Threshold-Scheme Reconstruction Contour	95
S18	Hybrid Client-Side Scanning Architectures	95
S19	Temporal Robustness, Inclusion Sensitivity, and Operator Heterogeneity	96
S19.1	Temporal and Inclusion Robustness	96
S19.2	Operator Heterogeneity and Regulatory Baseline	97
S20	Proof of the Stochastic Dominance Proposition	97
S21	Full EA-Modifier Prior Specifications	98

S22	Cross-Cutting Prior Calibration: Derivation	98
S23	Monte Carlo Stability Diagnostics	99
S24	GPD Goodness-of-Fit Tests	100

Abstract

Lawful exceptional access (EA) systems hold the cryptographic keys that let authorised parties decrypt protected communications. The debate over their risks has been long and qualitative, and it is complicated by two problems: no public dataset of EA-specific compromise events exists, so risk assessment must proceed from sparse and indirect evidence, and prior work has treated structurally different designs as equivalent, although transmission-layer EA in carrier infrastructure (T-EA) and over-the-top EA at the platform layer (OTT-EA) differ in how cryptographic keys relate to ciphertext data.

This paper builds a structured uncertainty framework for evaluating systemic compromise risk in EA architectures. It does not produce predictive forecasts, which the available evidence cannot support; it separates findings robust to assumption choices from findings that depend on calibration. Four analytical layers are applied in parallel to T-EA and OTT-EA: three empirical pillars (historical analogues, a Monte Carlo scenario layer, and a channel-independence decomposition) plus a Bayesian Structural Risk Model on a parallel-subgraph attack graph.

The central findings are structural. *First*, EA-equipped architectures of either class carry strictly higher modelled risk than their no-EA counterfactual, an ordering independent of calibration. *Second*, the classes differ in distribution *shape*: T-EA risk is dominated by central tendency, OTT-EA by the tail under correlated campaigns, a divergence driven by the cross-cutting coupling prior. *Third*, calibration-conditional annual probability ranges span 1.4% to 12.9% for T-EA across the $3\times-15\times$ structured-judgement targeting-premium interval, with Fréchet–Hoeffding intervals of [2.2%, 7.5%] for T-EA and [1.1%, 4.0%] for OTT-EA under any dependence structure, conditional on the Pillar II per-scenario probabilities. Over multi-decade horizons, cumulative compromise is well above zero, and key-material exfiltration is irreversible, an asymmetry weighing heavily on OTT-EA’s larger user populations. The framework quantifies compromise *probability*, not expected harm; consequence modelling and benefit estimation are outside its scope.

Keywords: exceptional access; lawful intercept; quantitative risk; uncertainty quantification; Bayesian hierarchical model; attack graph; tail risk.

1 Introduction

The debate over lawful exceptional access (EA) systems is now three decades old. It dates back at least to the Clipper Chip proposals of the early 1990s [1]. EA systems let authorised parties decrypt data or intercept end-to-end encrypted communications under defined legal conditions. The landmark analyses by Abelson et al. [1, 2] argued, on structural grounds, that any EA system is inherently less secure than the same system without EA. Key-recovery mechanisms introduce attack surfaces that would otherwise not exist. Both papers made this case qualitatively. To our knowledge, the peer-reviewed literature has not yet produced a structured framework for comparative quantitative reasoning across EA architectures. A framework of that kind should not be confused with predictive forecasts of specific compromise probabilities. The available evidence cannot support those.

A second limitation of prior work is that it treats different EA designs as if they were the same. EA proposals fall into at least four recognisable architectural classes (Section 3.1.1). *Transmission-layer EA* (T-EA) operates in carrier infrastructure. The canonical example is CALEA-mandated lawful intercept at US telecommunications carriers. *Over-the-top EA* (OTT-EA) operates at the messaging-platform layer. It covers server-side decryption mandates and the Levy–Robinson “ghost user” proposal. *Hybrid client-side scanning* architectures include the EU Chat Control proposals. *Distributed threshold schemes* are the fourth class. These four differ in how cryptographic key material relates to the ciphertext data it can decrypt. That relationship is a first-order driver of compromise risk, in both form and magnitude. A risk framework that lumps all four together cannot support the comparative reasoning the policy debate requires.

The problem is hard for a structural reason. A forecasting-style risk analysis would estimate a specific quantity: the annual probability that an EA system’s cryptographic keys are exfiltrated, or

that ciphertext is obtained along with enough key material to decrypt the target communications. This quantity cannot be measured directly. No public dataset of EA-specific compromise events exists. The systems whose risk most warrants assessment are prospective by definition. The problem therefore sits in the regime of *deep uncertainty* [3, 4]. In a deep-uncertainty setting, analysts can reasonably disagree about three things at once: parameter values, the structure of the probability distributions, and which historical analogues are relevant. Methods designed for predictive estimation under ordinary parameter uncertainty cannot simply be imported. They assume a level of empirical identification that is not available here.

1.1 Decision Support Objective

This paper takes a decision support stance rather than an estimation stance. The framework does not try to predict the annual compromise probability of a specific deployed EA system. It supports *structured comparative reasoning* about three questions. Which conclusions are robust across the range of defensible assumptions? Which are sensitive to specific calibration choices? Which architectural features drive the divergence between EA classes? The intended output is not a calibrated point projection. It is an explicit account of what has to be assumed, and what cannot be assumed, for a risk claim of any given magnitude or shape to follow.

Four goals shape the design. *First*, constrain the plausible values within each architectural class to a structurally bounded range. *Second*, identify the architectural features driving the comparison between classes. *Third*, make explicit which conclusions are sensitive to unobservable assumptions and which are not. *Fourth*, characterise the distributional uncertainty that any specific projection conceals. These goals are different in kind. No single analytical method delivers all four, and the design of this paper is shaped by that fact.

Two scoping choices are explicit from the outset. First, the framework addresses the risk side of EA evaluation only. A complete risk-benefit determination requires comparable quantitative estimates of operational benefits: counterfactual law-enforcement effectiveness, the case-fraction in which EA access is decisive, harm reduction attributable to EA-enabled interceptions, and displacement and substitution effects. None is estimated here. No published analogue of the present framework synthesises that literature into comparable quantitative form. The output is one input to a net-benefit determination, not a substitute for it. Second, the empirical inputs draw predominantly from Western liberal-democratic jurisdictions: Stream A from US National Security Systems, Five Eyes infrastructure, and CALEA-mandated carriers; Stream B from Western-rooted browser trust stores; Stream C from US-based operators disclosed under US/EU breach-notification regimes. The calibrated central magnitudes are specific to these jurisdictional contexts. The architectural-ordering, Fréchet–Hoeffding interval, and tail-shape findings rest on structural arguments (particularly $\gamma_X/\gamma \geq 1$) that are jurisdiction-independent and survive transfer to other EA regimes, even though their calibrated magnitudes there would differ.

We use four layers, applied in parallel to T-EA and OTT-EA. The first three form a *Three-Pillar Empirical Framework* that approaches the problem through distinct evidence types and inferential methods. Each pillar produces architecture-conditional outputs that bound the problem from a different direction: empirical analogy, scenario-conditional projection, and architectural-channel decomposition. The fourth layer, a *Bayesian Structural Risk Model*, replaces those point estimates with full prior predictive distributions and explicitly models the dependence structure that the three-pillar approach can only bound. For OTT-EA, the Bayesian attack graph is extended with parallel key-side and data-side subgraphs joined by an operational-compromise AND-node, with a latent campaign variable $Z(t)$ coupled to cross-cutting attack paths.

1.2 The Four Analytical Layers

Pillar I. Historical Analogy Analysis. Three data streams provide empirical anchors covering different architectural classes. Stream A applies six statistical methods to a 13-year dataset

of major breaches of analogous high-security government systems, anchoring the T-EA class. Stream B applies Poisson cohort methods to Certificate Authority private-key compromises across 130 trusted CAs over 19 years, providing an architectural bridge that holds keying material at scale across a well-defined operator population. Stream C provides the OTT-leaning anchor through a documented incident base of platform-level key-or-data compromises (Storm-0558, LastPass 2022, Okta 2022/2023, Microsoft Midnight Blizzard 2024, and related incidents), classified by whether keys, data, both, or neither were obtained. Pillar I establishes empirical grounds: an upper bound from the general analogue population ($\sim 36\%$ T-EA-leaning), a lower-magnitude base rate from the CA cohort (0.54% per system-year), and an architecture-conditional rate for OTT-leaning analogues from Stream C.

Pillar II. Prospective Scenario Model. A formally specified Monte Carlo simulation integrating EPSS, MITRE ATT&CK, the Verizon DBIR, and adversary-tier intelligence parameterises seven attack scenarios across a two-tier adversary model. The conditional key-material probability $p_i^{\text{cond, key}}$ is decomposed differently for each architectural class: for T-EA, $p_i^{\text{cond, key, T}} = P_1 \cdot P_2$ (reach key-management layer; HSM extraction), and for OTT-EA, $p_i^{\text{cond, key, OTT}} = P_1 \cdot P_2 \cdot P_3 \cdot P_4$ (the same two stages plus segregated-data acquisition P_3 and multi-stage detection avoidance P_4). Under independence, central projections fall in the low single-digit percentage range (around 7% for T-EA; lower for well-segregated OTT-EA, with magnitude depending on the segregation parameter and cross-cutting attack-path fraction). A Fréchet–Hoeffding bounding analysis establishes the model-consistent intervals under any dependence structure, and these intervals (not the point projections) are the framework’s primary policy-relevant output from Pillar II.

Pillar III. Architectural Heuristic Decomposition. An analysis of the minimum viable EA architecture identifies four non-eliminable risk channels (insider, zero-day, supply chain, operational error). Combining empirical best-in-class component performance under independence across the four channels gives the *channel-aggregate projection* ($1 - \prod_c (1 - P_c)$), used as a single-number reference within the plausibility range. For T-EA this yields a value in the low single-digit percentage range (around 5% annually). For OTT-EA, each channel is weighted by its cross-cutting fraction (the proportion of that channel’s risk that simultaneously compromises $\mathcal{K}$ and $\mathcal{D}$), with non-cross-cutting risk attenuated by the segregation factor $P_3 \cdot P_4$.

Layer IV. Bayesian Structural Risk Model. A Bayesian hierarchical model combines a directed attack-graph representation, a non-homogeneous Poisson hazard process with log-normal priors on edge hazard rates, domain transfer from analogue systems, an explicit latent-variable dependence model for coordinated adversarial campaigns, and Monte Carlo simulation. For the OTT-EA case the attack graph is extended with parallel key-side and data-side subgraphs joined by an operational-compromise AND-node, with the campaign variable $Z(t)$ coupled specifically to cross-cutting edges. The model’s priors are calibrated, separately for each architectural class, to produce prior predictive outputs consistent with the architecture-matched three-pillar empirical range. Consequently, the per-class median is not independent corroboration of that range. The model’s unique contributions are (1) tail shape, (2) dependence quantification, and (3) exceedance probabilities conditional on the calibration. Three key findings follow. (a) Explicit dependence modelling inflates the annual 95th percentile substantially for both architectural classes. The inflation is larger for OTT-EA, where correlated campaigns collapse the segregation gain. (b) Exceedance probabilities at low annual thresholds (e.g. 1%) are above 0.9 under the primary calibration for both classes. This is conditional on prior choice, with full prior-sensitivity reported. (c) EA-equipped architectures of either class carry strictly higher modelled risk than the no-EA counterfactual. This is grounded in the empirically supported observation that EA infrastructure attracts adversarial targeting above and beyond comparable non-EA systems.

1.3 Motivating Cases

The threat model is not hypothetical for either architectural class. Real incidents from both, summarised below and discussed at length in Sections 5.1 and 5.3, make the modelled scenarios

concrete.

T-EA cases. The 2024 Salt Typhoon campaign, in which Chinese state-sponsored actors compromised CALEA-mandated lawful-intercept infrastructure at nine or more US telecommunications carriers and obtained the government’s active wiretap target list [5, 6], provides the most recent operational demonstration that T-EA systems constitute high-value, specifically targeted attack surfaces. The Greek Vodafone incident of 2004–2005, in which malicious software was installed on the country’s lawful-intercept infrastructure enabling surveillance of over 100 senior government officials [7], provides an earlier independently documented precedent. The Crypto AG disclosures (Operation Rubicon, declassified 2020) [8] illustrate a third class of T-EA-relevant compromise, in which the cryptographic infrastructure itself was operated as a covert intelligence channel.

OTT-EA cases. No public OTT-EA-specific compromise is documented, because no jurisdiction has yet mandated OTT-EA at scale. The closest empirical analogues are platform-level key-or-data compromise incidents in non-EA contexts, which constitute the Stream C empirical base (Section 5.3). The Storm-0558 campaign (Microsoft 2023), in which a Chinese state-sponsored actor obtained a Microsoft consumer signing key and forged tokens to access Outlook Web Access mailboxes of US government officials, demonstrates the catastrophic outcome of master-key compromise at platform scale. The LastPass 2022 incident, in which an attacker obtained both encrypted password vaults and source code revealing encryption details across two compromise stages, illustrates the multi-stage compromise pattern characteristic of OTT-relevant attacks. The Microsoft Midnight Blizzard incident (2024), in which the same Russian state-sponsored actor that conducted SolarWinds obtained source code and internal systems access through password-spray and OAuth abuse, illustrates the persistence of platform-level targeting against trusted infrastructure operators. These incidents do not establish frequency in the EA-mandated case, no such case yet exists, but they document that platform-level compromise at the relevant scale is operational.

Role of these cases in the framework. The T-EA incidents enter the quantitative parameter calibration only via Stream A, with Salt Typhoon treated as a sensitivity case (Supplementary §S19.1); they are not used as frequency calibration points individually. The OTT-leaning incidents enter the calibration via Stream C, with explicit inclusion criteria documented in Section 5.3. No incident from either set is used to fix a probability point estimate. Their function is to establish scenario plausibility and to provide architecturally matched prior calibration for the Bayesian layer.

1.4 Structure of the Paper

The paper is laid out as follows. Section 2 situates the work in the existing literature and lists the empirical sources we draw on. Section 3 fixes our system and threat model and gives formal compromise definitions. Section 4 sets out the four-layer scheme. The three pillars then occupy Sections 5–7, in order: historical analogy, the scenario model, and the channel-aggregate projection. The Bayesian structural risk model follows in Section 8. Results from all four layers are gathered in Section 9, with the cross-layer synthesis in Section 10. Sections 11 and 12 address limitations and policy implications respectively.

1.5 Principal Findings at a Glance

Reader’s guide to the principal claims. Different findings of the framework carry different assumption-robustness status, and the synthesis hierarchy (S1 most assumption-robust, through S6) gives each one an explicit tier. Table 1 maps each principal claim to the section where it is established and to its tier in the synthesis hierarchy; full definitions of the tiers are given in §10.

Table 1: Reader’s guide to the principal claims of the framework. The “Assumption-robustness tier” column refers to the synthesis hierarchy of §10, with S1 the most assumption-robust (structural finding holding under any defensible parameter choice) and S6 the most calibration-dependent. The tier is conservative: where a claim spans tiers (typically because its direction is structural but its magnitude is calibration-conditional) the lower-tier (more robust) qualifier is shown.

Claim	Established in	Assumption-robustness tier
EA-equipped architectures carry strictly higher modelled compromise risk than the no-EA counterfactual within the same architectural class, conditional on the superset-graph and $\delta \geq 1$ assumptions	Proposition 1 (§8)	S1: structural
OTT-EA risk distribution has a heavier upper tail than T-EA under correlated-campaign conditions. The direction follows from the cross-cutting coupling constraint $\gamma_X/\gamma \geq 1$ and is unconditional on prior width within the defensible range	§9.4, Table 10	S2: direction structural, magnitude conditional
Upper-quantile risk ordering: OTT-EA upper quantiles exceed T-EA’s across the upper 5–10% of the prior predictive distribution, with the difference widening under correlated-campaign dependence (direct empirical percentile comparison, distribution-free; the parametric GPD characterization is supported for T-EA but rejected for OTT-EA, Supplementary §S24)	§9.5, Supplementary §S24	S2–S3: structural mechanism, parametric tail-index claim weakened
Empirical anchor cohorts (Streams A, B, C) project baseline compromise rates on the order of 1% per system-year (pre-EA targeting premium)	§5.1–5.3	S4: empirical-anchor plausibility
Annual EA-projected compromise probability lies in the Fréchet–Hoeffding interval [2.2%, 7.5%] for T-EA and [1.1%, 4.0%] for OTT-EA under any dependence structure compatible with the seven-scenario model	§6.5	S4: interval dominance
The T-EA-versus-OTT-EA comparison is not first-order stochastic dominance but a central-tendency-versus-tail-risk trade-off: T-EA exceeds OTT-EA at the median, OTT-EA exceeds T-EA in the upper tail	Remark 2	S6: cross-architecture trade-off
Multi-decade (10–25 year) cumulative compromise probability is materially above zero under any defensible parameter choice	§9.4, Table 14	S1–S4: qualitative direction structural; specific magnitudes calibration-conditional

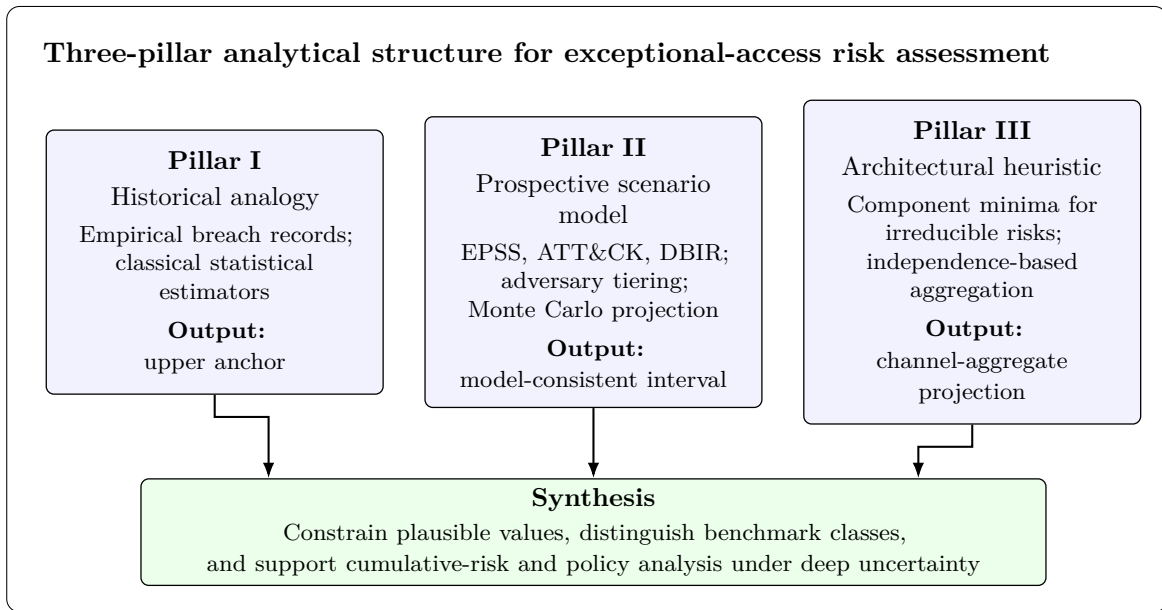


Figure 1: Overview of the three-pillar framework. Each pillar uses a distinct evidence type and inferential role; their outputs are complementary rather than interchangeable, and are interpreted as decision-support inputs rather than as point estimates.

Alt text: Diagram of the three-pillar framework: three labelled boxes (Pillar I: historical analogy; Pillar II: Monte Carlo scenarios; Pillar III: structural decomposition) feed into a synthesis node, with arrows indicating complementary evidence types and inferential roles.

2 Background and Related Work

2.1 Exceptional Access Systems

Three closely related terms recur in the policy and technical literature and are worth distinguishing at the outset. *Lawful intercept* (LI) denotes the authorised real-time interception of communications content under a specific legal warrant, typically implemented at carrier infrastructure (the CALEA architecture in the United States is the canonical instance). *Key escrow* denotes any architectural arrangement that deposits cryptographic key material with a third party to make it recoverable independently of the communicating parties. The 1990s Clipper Chip proposal is the historical exemplar. *Exceptional access* (EA) is the broader category, encompassing both LI and key-escrow mechanisms as well as later proposals (split-key schemes, server-side decryption mandates, ghost-user constructions, client-side scanning). Where this paper analyses a specific architectural class (transmission-layer EA / T-EA; over-the-top EA / OTT-EA), the term EA refers to the umbrella concept. Where it analyses historical incidents at carrier infrastructure (Salt Typhoon, the Athens affair), LI refers specifically to that subset.

The term *exceptional access* encompasses key escrow, key recovery, split-key schemes, and server-side decryption mandates [2, 9, 10]. All such schemes share the structural property of creating an alternative access path to protected communications that is available independently of the communicating parties [1]. At the protocol-engineering level, the Internet Engineering Task Force formally adopted a policy in 2000 declining to support wiretap capabilities in IETF protocols [11]. The Internet Architecture Board has since reaffirmed that IETF protocol work prioritises the interests of end users [12], reflecting a sustained architectural objection from the protocol-design community. Synthesising the technical literature on exceptional access [1, 2], we distinguish five structural risk classes that separate EA systems from their non-EA counterparts: (1) single point of failure at the key store; (2) insider threat through privileged EA roles; (3) increased complexity correlated with vulnerability density; (4) forward-secrecy degradation; and (5) scale risk from deployment across diverse operators.

Related proposals include the “ghost user” model of Levy and Robinson [13], which attracted substantial cryptographic critique [14], and EU-level client-side scanning approaches [15], assessed technically by Kulshrestha and Mayer [16]. Formal cryptographic attacks against key-escrow and malicious cryptography constructions are surveyed by Young and Yung [17]. The provable-security framework for analysing cryptographic primitives, within which EA schemes would be formally evaluated, is exemplified by Bellare and Rogaway [18].

2.2 Cyber Risk Quantification

Quantitative cyber risk has been approached through several frameworks. The FAIR methodology [19] decomposes risk into probability and magnitude factors estimated from expert judgment and analogical data. The Gordon-Loeb model [20] addresses security investment optimisation. Bayesian belief networks have been applied to network intrusion risk [21] and software defect prediction [22]. Attack-graph approaches are developed by Ou *et al.* [23] (scalable logical-graph generation) and Wang *et al.* [24] (attack-graph-based alert correlation and prediction), while Homer *et al.* [25] contribute probabilistic aggregation of per-vulnerability metrics across attack graphs. Models for the time to compromise a system, as a function of attacker skill and visible vulnerabilities, have also been developed [26]. None of this literature specifically addresses the structural properties of EA key-management infrastructure.

For the empirical pillars, application of Poisson-process models, Bayesian Gamma–Poisson conjugate inference, exponential survival analysis, actuarial modelling, and bootstrap resampling to security incident data follows standard treatments [27–29]. The rule-of-three zero-event estimator [30] and actuarial compound-Poisson models [31] complete the methodological repertoire. Allodi and Massacci [32] provide foundational empirical work on vulnerability severity and

exploitation frequency distributions.

2.3 Empirical Sources and Evidential Status

Pillar II draws on four published empirical sources, each documented and applied in detail in the methodology section. The Exploit Prediction Scoring System (EPSS) [33, 34] is an open framework assigning daily exploitation-probability scores to published CVEs. It is used here as an empirically motivated prior for the opportunistic adversary tier. MITRE ATT&CK v15 [35, 36] provides externally auditable mappings from attack scenarios to documented adversary techniques. The Verizon DBIR [37, 38] supplies breach-frequency statistics and the actor-mix data used to bound the EA targeting premium: the share of breaches attributable to state-aligned espionage actors, resolved by target sector. Mandiant M-Trends 2024 [39] provides adversary dwell-time and detection statistics. The CrowdStrike Global Threat Report 2024 [40] and CISA Joint Advisories [41, 42] provide complementary nation-state campaign documentation.

The framework treats EA risk estimation as a problem of *deep uncertainty* [3, 4]. This is a regime in which analysts may disagree about parameter values, about the structure of probability distributions, and even about the relevance of historical data. Following established approaches in climate-change economics and infrastructure planning, the goal is not to resolve deep uncertainty. The goal is to identify projections robust across defensible assumptions, specify their conditions of validity, and equip decision-makers to assess net-benefit given the range of possible outcomes consistent with current knowledge.

One methodological objection should be answered at the outset. The decision-under-deep-uncertainty literature holds that where a single prior distribution is not defensible, analysis should characterise performance across the space of plausible assumptions rather than integrate over one [3, 4]. The framework adopts exactly that discipline, in two forms. The Fréchet–Hoeffding analysis (§6.5) bounds the aggregate compromise probability under *every* dependence structure compatible with the scenario model, a bounded-probability treatment that requires no dependence prior at all. And the Bayesian layer is run not under one prior but under a calibration set (primary, conservative, pessimistic), with findings reported by whether they hold across the set or only within members of it (§10.1). Single-prior medians appear in this paper as labelled reference points inside those robustness envelopes, never as the analysis itself. Source versions for the empirical inputs are pinned (MITRE ATT&CK v15, DBIR 2024 and 2025, M-Trends 2024, with the EPSS score snapshot archived at analysis date), and the derived parameter values ship with the reproducibility package.

3 System and Threat Model

3.1 Abstract EA Architecture

Definition 1 (EA System). An *exceptional access system* is a tuple $\Sigma = (\mathcal{C}, \mathcal{K}, \mathcal{P}, \mathcal{T}, \mathcal{D})$, where: $\mathcal{C}$ is the set of communications or storage objects subject to EA; $\mathcal{K}$ is the key management infrastructure, comprising one or more hardware or software modules holding cryptographic material enabling EA; $\mathcal{P}$ is the procedural access-control layer governing requests to $\mathcal{K}$; $\mathcal{T}$ is the trust hierarchy, comprising the set of entities whose correct operation is necessary for the security of $\mathcal{K}$; and $\mathcal{D}$ is the ciphertext-data infrastructure holding the encrypted communications to which EA access pertains.

The earlier literature on EA risk has typically treated $\mathcal{K}$ and the ciphertext-data infrastructure as co-located, since for transmission-layer EA architectures keys and encrypted traffic converge at the intercept point [1, 2]. The explicit inclusion of $\mathcal{D}$ as a separate tuple component is essential for the architectural taxonomy that follows: in some EA architectures $\mathcal{K}$ and $\mathcal{D}$ share a trust boundary and access path, while in others they are deliberately segregated, and this segregation is a first-order determinant of the operational compromise probability.

Definition 2 (Architectural Segregation). An EA system Σ exhibits *architectural segregation* of degree $s \in [0, 1]$ if, conditional on adversarial compromise of $\mathcal{K}$ (unauthorised access to key material), the probability of also obtaining sufficient ciphertext from $\mathcal{D}$ to decrypt target communications, in the absence of additional adversarial effort directed at $\mathcal{D}$, is $1 - s$. The fully co-located case ($s = 0$) describes systems in which $\mathcal{K}$ and $\mathcal{D}$ share a trust boundary, access path, and operational locus. The fully segregated case ($s = 1$) is a theoretical limit not achievable in operationally viable systems, since some shared trust dependency is necessary to reconcile keys with ciphertext under authorised access.

3.1.1 Architectural Taxonomy

We distinguish four architectural classes of EA system, characterised by the relationship between $\mathcal{K}$, $\mathcal{D}$, and the operator’s organisational position:

Class T (Transmission-layer EA, T-EA). EA mandates implemented in network or carrier infrastructure, intercepting traffic in transit. The operator is a telecommunications carrier or equivalent network provider acting under state mandate. Examples: CALEA-mandated lawful-intercept facilities at US telecommunications carriers; ETSI TS 103 221-class retained-data and intercept architectures in European regimes. In Class T, $\mathcal{K}$ and $\mathcal{D}$ are operationally co-located at the intercept point: the same orchestration system that holds session-key material also processes the encrypted traffic flow. Architectural segregation is structurally low ($s \approx 0$). Motivating compromises: Salt Typhoon (2024) [5, 6], the Athens affair (2004–05) [7], and the Crypto AG disclosures (Operation Rubicon, declassified 2020) [8].

Class A (Application-layer or Over-The-Top EA, OTT-EA). EA mandates implemented at the messaging-platform or storage-service layer, where the platform operator is required to retain or escrow keying material enabling decryption of user communications, or to implement server-side decryption under lawful order. Examples: server-side decryption mandates and the Levy–Robinson “ghost user” proposal [13]; the broader policy debate over law-enforcement access to encrypted content, including key-escrow and related approaches, is surveyed by the OECD [10]. (Client-side scanning architectures are a related but architecturally distinct mechanism, treated separately as Class H below.) The storage-service variant of Class A applies to deployed end-to-end-encrypted cloud-storage systems such as Apple’s Advanced Data Protection for iCloud [43], in which user data is encrypted under keys held only by the user’s devices. A storage-layer EA mandate would require the operator to retain or escrow access to data that the architecture is otherwise designed to place beyond operator reach. In Class A, $\mathcal{K}$ (key custody) and $\mathcal{D}$ (encrypted message or file storage) are typically architecturally segregated: keys reside in dedicated key-management infrastructure with access controls distinct from the bulk storage layer holding ciphertext. Segregation s is materially greater than zero, with magnitude governed by platform implementation. No public EA-specific Class A compromise is documented because no jurisdiction has yet mandated Class A EA at scale. The closest empirical analogues are platform-level key-or-data compromise incidents in non-EA contexts (Storm-0558 against Microsoft 2023, LastPass 2022, the Okta 2022 and 2023 incidents, and Microsoft Midnight Blizzard 2024), which form the basis for the Stream C empirical calibration developed in Section 5.3.

Class H (Hybrid client-side scanning, CSS). Architectures in which detection or content-matching is performed on client devices using operator-distributed key material, with positive matches escalated to the operator. The EU Chat Control proposals [15] and historical client-side perceptual hashing systems are the canonical examples. The risk profile combines elements of Class A (operator key custody) with endpoint-distributed key material whose attack surface is governed by mobile-platform security properties [16, 44]. Class H is treated only qualitatively in this paper (Supplementary §S18). Its quantitative analysis requires endpoint risk parameters outside our calibrated set.

Class D (Distributed threshold). Architectures in which key material is split across N independent trustees with a t -of- N reconstruction requirement [45–47]. Class D is treated

through architectural analysis in Section 12.7.

Table 2: Architectural taxonomy of exceptional access systems and their treatment in this paper. The segregation parameter s is defined in Definition 2.

Class	$\mathcal{K}/\mathcal{D}$ relationship	Operator type	Treatment
T-EA	Co-located, $s \approx 0$	Carrier under state mandate	Quantitative
OTT-EA	Segregated, $s \in (0, 1)$	Global platform under state mandate	Quantitative
Hybrid CSS	Endpoint-distributed	Platform with client co-operation	Qualitative (Supp. §S18)
Threshold	Split across t -of- N trustees	Multi-party	§12.7

The EA-specific attack surface arises from $\mathcal{K}$, $\mathcal{P}$, $\mathcal{T}$, and (in segregated architectures) $\mathcal{D}$ jointly. The quantitative analysis in this paper covers Classes T (transmission-layer) and OTT (application-layer). These are the two architectural classes that dominate contemporary EA policy debate, and their parallel treatment is the principal extension of this paper relative to prior risk-quantification work that has implicitly conflated them. Hybrid client-side scanning architectures (Class H) and distributed threshold schemes (Class D) are treated qualitatively and through dedicated architectural analysis respectively.

3.2 Adversary Model

We distinguish three adversary classes:

Nation-state APT ($\mathcal{A}_{\text{NS}}$). Advanced persistent threat actors with high capability (sophisticated zero-day exploitation, long-horizon campaigns), high motivation (strategic intelligence value), and substantial resources.

Insider threat ($\mathcal{A}_{\text{IN}}$). Individuals with legitimate access to components of $\mathcal{K}$ or $\mathcal{T}$ who abuse that access, whether through malice, coercion, or negligence.

Criminal / opportunistic ($\mathcal{A}_{\text{CR}}$). Actors motivated primarily by financial gain, with moderate capability. Relevant because EA infrastructure presents an attractive target for ransomware and data exfiltration.

Assumption 1 (Adversary independence within classes). Within each adversary class, individual actors are modelled as statistically independent except as captured by the shared latent campaign variable Z defined in Section 8.5.

3.3 Compromise Definitions

For architecturally segregated EA systems, multiple distinct compromise outcomes must be distinguished, since the operationally relevant outcome is not equivalent to either of its components alone. We define four annual compromise probabilities corresponding to qualitatively distinct adversarial achievements.

Definition 3 (Technical Compromise). A *technical compromise* occurs when an entity not authorised under $\mathcal{P}$ obtains EA-specific cryptographic key material from $\mathcal{K}$ sufficient to decrypt one or more communications, were the corresponding ciphertext also available. We denote the annual probability of technical compromise by Λ^{key} .

Definition 4 (Data Compromise). A *data compromise* occurs when an entity not authorised under $\mathcal{P}$ obtains EA-pertinent ciphertext from $\mathcal{D}$ in sufficient volume that, were the corresponding key material also available, target communications could be decrypted. We denote the annual probability of data compromise by Λ^{data} .

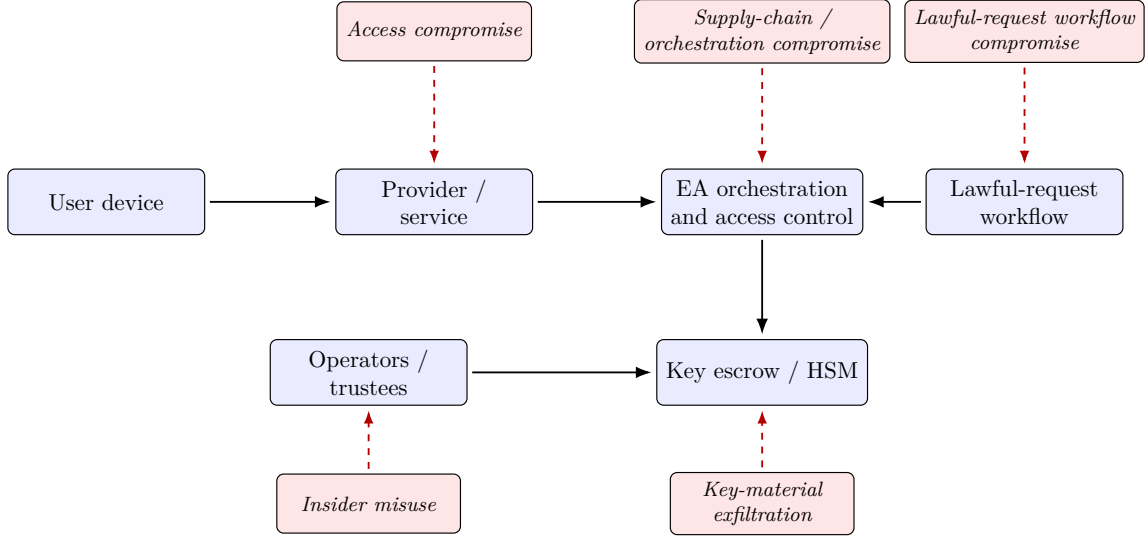


Figure 2: Simplified attack-surface schematic for a transmission-layer (Class T) exceptional-access architecture, in which key material $\mathcal{K}$ and ciphertext data $\mathcal{D}$ are operationally co-located. Solid arrows show the primary data-flow paths; dashed red arrows indicate where each risk class attaches. The mandate creates compromise pathways concentrated around orchestration, escrow, and operator trust boundaries that do not exist in the corresponding non-EA architecture. The corresponding schematic for an OTT-EA (Class A) architecture, with $\mathcal{K}$ and $\mathcal{D}$ architecturally segregated, is given as Figure 6 in Section 8 where the parallel attack graph is developed.

Alt text: Schematic of a transmission-layer EA architecture: cryptographic key material and ciphertext data are operationally co-located; five risk-class attack paths are shown as dashed red arrows attaching at orchestration, escrow, and operational nodes.

Definition 5 (Operational Compromise). An *operational compromise* occurs when an entity not authorised under $\mathcal{P}$ jointly obtains key material from $\mathcal{K}$ and ciphertext from $\mathcal{D}$ sufficient to decrypt one or more target communications. We denote the annual probability of operational compromise by Λ^{op} . The policy-relevant quantity is this, since technical or data compromise alone does not enable the adversarial outcome that motivates concern.

Definition 6 (Access-Pathway Compromise). An *access-pathway compromise* occurs when an entity not authorised under $\mathcal{P}$ obtains unauthorised access to the EA operational interface sufficient to issue interception requests through legitimate-appearing channels. We denote the annual probability by Λ^{acc} . This outcome is distinct from technical, data, or operational compromise: it involves authorisation abuse rather than cryptographic-material or ciphertext exfiltration. For policy purposes Λ^{acc} and Λ^{op} are both relevant: the former enables targeted decryption under the operator’s own infrastructure; the latter enables out-of-band decryption.

Remark 1 (Architectural collapse). For Class T architectures with co-located $\mathcal{K}$ and $\mathcal{D}$, the conditional probability $\Pr(\text{data} \mid \text{technical})$ is approximately unity, and consequently $\Lambda^{\text{op}} \approx \Lambda^{\text{key}}$. The earlier literature’s elision of these outcomes [1, 2] is correct for the Class T case. For Class A (OTT) architectures, $\Pr(\text{data} \mid \text{technical}) = 1 - s < 1$ in the absence of correlated adversarial effort, and 1 under correlated effort exploiting cross-cutting access paths. The joint probability Λ^{op} is therefore strictly less than $\min(\Lambda^{\text{key}}, \Lambda^{\text{data}})$ under independence and approaches $\min(\Lambda^{\text{key}}, \Lambda^{\text{data}})$ under perfect correlation. The gap is the segregation gain, which is the quantity that distinguishes the OTT risk profile from the T-EA risk profile.

Definition 7 (Operational Viability). An EA system is *operationally viable* if it can fulfil its legal mandate: process authorised lawful-intercept requests, maintain audit records, operate continuously, and be staffed and maintained over a multi-year operational lifetime. Any system specification that eliminates a risk channel at the cost of operational viability is excluded from the Pillar III heuristic decomposition.

Definition 8 (Compromise Event – Bayesian Model). A *compromise event* ω occurs at time t if, at time t , an entity not authorised under $\mathcal{P}$ obtains the conditions necessary to decrypt one or more communications in $\mathcal{C}$ without generating a detectable audit record. For Class T architectures, those conditions reduce to obtaining sufficient cryptographic material from $\mathcal{K}$, since $\mathcal{K}$ and $\mathcal{D}$ are co-located. For Class A architectures, those conditions require joint compromise of $\mathcal{K}$ and $\mathcal{D}$, modulated by the segregation parameter s (Definition 2) and the cross-cutting attack-path fraction (Section 8.5). In either class, sufficient authority within $\mathcal{T}$ to authorise issuance of intercept material constitutes a compromise event by the same operational criterion.

We analyse risk over a primary horizon of $T = 10$ years, reflecting a plausible operational deployment window. We also report cumulative risk over $[0, 25]$ years.

3.4 Notation Summary

Table 3 collects the core architectural and probabilistic notation used throughout. Subscripts T and OTT denote the two configurations where disambiguation is required; the full glossary, including secondary symbols, is in Supplementary §S1.

Table 3: Core notation and recurring terms.

q_1	Annual (year-1) compromise probability of the relevant operational outcome (key-material compromise for T-EA; joint key-and-data compromise for OTT-EA).
Q_T	Cumulative compromise probability over T years.
$\Lambda^{\text{acc}}, \Lambda^{\text{key}}$	Pillar II annual access-pathway and technical-compromise probabilities under scenario independence.
$P_3 P_4$	OTT-EA segregation factor: probability that an attacker holding key material also reaches the encrypted-data store before mitigation (central 0.30).
ξ_c	Per-channel cross-cutting fraction: share of channel- c compromises traversing infrastructure shared between key custody and data planes.
$Z(t)$	Latent annual campaign intensity, $Z \sim \text{Gamma}(0.6, 2.0)$ at the primary calibration.
γ, γ_X	Campaign amplification factors (T-EA uniform; OTT-EA cross-cutting), with $\gamma_X/\gamma \geq 1$ by construction (§8.5).
$\delta_{\text{EA}}, \delta_{\text{target}}, \delta_{\text{concen}}$	EA exposure, targeting, and concentration multipliers, all ≥ 1 .
Channel-minimum heuristic	Fréchet lower-bound floor within the four-channel Pillar III model (§7).
Interval dominance	A finding holding at every point of a stated interval, here the Fréchet–Hoeffding brackets (§6.5).

4 Framework Architecture and Epistemic Foundations

4.1 Rationale for a Multi-Method Approach

No single analytical method can credibly estimate the compromise probability of a prospective EA system. Three fundamental challenges preclude any unified approach:

1. *Absence of EA-specific incident data.* Ground-truth compromise frequencies for EA systems do not exist in any public dataset. Any estimate must be an extrapolation from other system classes, a model projection, or a structural argument. Or, as here, a structured combination of all three.
2. *Uncertainty about adversary behaviour and capability evolution.* The threat landscape is non-stationary: adversary capabilities, tooling, and targeting priorities evolve in ways that historical data can at best partially capture.
3. *Unknown dependence structure between risk channels.* The extent to which multiple attack vectors, component vulnerabilities, and operational failures co-occur or are independent is a first-order determinant of system-level risk, but cannot be directly measured for a system that does not yet exist.

Each of the four analytical layers individually is subject to known and significant limitations. Their value lies in their collective ability to bound the problem from multiple directions and to make visible the specific assumptions on which any particular projection depends.

4.2 The Epistemic Status of Framework Outputs

The following taxonomy establishes the interpretation that applies to all numerical results in subsequent sections.

Pillar I: Empirical Upper Anchor. The $\sim 36\%$ population-average rate is an empirical measurement (with associated confidence intervals) of the historical compromise rate of a defined population of analogous systems. The implied multiplicative improvement required to reach the low single-digit annual range under a $3\text{--}10\times$ EA targeting premium is substantial; the projections developed in Section 5 are the quantitative form of that requirement.

Pillar II: Scenario-Conditional Projections. The Monte Carlo outputs are projections conditional on (a) the model structure, (b) specific parameter ranges drawn from adapted empirical sources, and (c) the independence assumption embedded in the aggregation formula. The Fréchet–Hoeffding interval $[2.2\text{--}7.5\%]$ provides the model-consistent range under any dependence structure, and we regard this interval as a more honest representation of Pillar II’s implications than any point estimate.

Pillar III: Channel-Aggregate Projection. A channel-aggregate projection in the low single-digit percentage range (around 5% annually for T-EA) is constructed by combining empirical best-in-class component performance under the independence assumption. It answers the conditional question: “If an EA system can match, but not beat, the best historically observed performance for each of its four irreducible risk components, and if those components fail independently, what combined risk follows?” The channel aggregate is an interpretive reference within the plausibility range, not a best-guess forecast.

Layer IV: Prior Predictive Distributions. The Bayesian model replaces all point estimates with full prior predictive distributions, explicitly preserving the epistemic uncertainty inherent in the problem. Qualitative conclusions stable across wide parameter ranges are distinguished from conclusions that depend on specific parameter choices. The stochastic dominance result (Proposition 1) rests on the empirically grounded observation that EA system modifiers (δ_{EA} , δ_{target} , δ_{concen}) are each ≥ 1 , supported by documented incidents (Salt Typhoon, Athens affair) and structural analysis. It is not a definitional claim.

4.3 Preview of the Synthesis Hierarchy

The four method layers produce findings of varying epistemic weight. Some claims survive any defensible parameter choice; others depend on the independence assumption that Pillars I–III share; still others are conditional on a specific prior calibration. The synthesis hierarchy of §10 distinguishes six tiers (S1 most assumption-robust through S6 most calibration-dependent) and assigns each principal claim to its tier. Table 4 below gives the interpretive status of the framework’s principal numerical outputs as a reading guide for the pillar sections that follow.

Table 4: Interpretive status of the framework’s principal numerical outputs. The values are reference points for structured comparison, not predictions. Each quantity is paired with the epistemic regime in which it should be read.

Quantity	Interpretation	Role in argument
$\sim 1.5\%$	Heuristic component-minima floor (conditional on four-channel exhaustiveness)	Lower reference under stated assumptions (not structural)
$\sim 5\%$	Channel-aggregate projection under Pillar III independence assumption	Single-number reference within the plausibility range
$\sim 7\%$	Independence-based central projection from Pillar II	Scenario-model reference value
$[2.2\%, 7.5\%]$	Fréchet–Hoeffding interval for Pillar II	Model-consistent range under arbitrary dependence (interval dominance)
$\sim 4\%$	Bayesian prior predictive central tendency (Layer IV)	Uncertainty-preserving central reference (by prior design, not independent estimate)
$[1.4\%, 16.5\%]$	Bayesian 90% prior predictive interval (Layer IV) ¹	Full distributional uncertainty range
~ 0.99	$\Pr(\text{annual risk} > 1\%)$ under Bayesian full model	Illustrative exceedance row; full threshold range in Table 15

5 Pillar I: Historical Analogy Analysis

Pillar I establishes architecture-conditional empirical anchors by answering a circumscribed question: at what rate have systems broadly analogous in sensitivity, scale, and architectural class to a prospective EA system been compromised by major breaches in recent history? The pillar comprises three independent data streams, each architecturally aligned with a different EA class, and a formal cross-stream meta-analysis.

Stream A (Section 5.1) covers government high-security systems whose architectural profile most closely matches T-EA: tightly controlled operator population, vetted personnel, classified infrastructure, and co-location of cryptographic material with the operationally relevant data. Stream B (Section 5.2) covers Certificate Authority private-key infrastructure, providing an architectural bridge: CAs hold cryptographic material at scale across defined subscriber populations under unitary operator authority, but without the data co-location that characterises T-EA. Stream C (Section 5.3) covers platform-level key-or-data compromise incidents from major cloud, identity, and SaaS operators, providing the OTT-EA-leaning anchor: large user populations, segregated key and data infrastructure, and the multi-stage compromise pattern characteristic of the OTT case.

The three streams are pooled cautiously: each anchors a different architectural class, and cross-stream meta-analysis is performed only to the extent that common-rate assumptions can be justified. When the streams disagree, that disagreement is itself architecturally informative.

5.1 Stream A: Government High-Security Systems

Stream A is our T-EA anchor. Its constituent incidents share the architectural property of $\mathcal{K}/\mathcal{D}$ co-location: the compromised system was, in each case, a single locus where cryptographic material and the operationally relevant data converged. The Salt Typhoon incident is the canonical instance, with CALEA-mandated lawful-intercept infrastructure compromised at the orchestration layer that holds both session-key material and target-list data. The architectural fit to T-EA is strong, modulo the inherent imperfection of any analogue.

5.1.1 Empirical Dataset

An incident is included in Stream A if and only if it satisfies all three conditions: (C1) the system was a national-scale government system holding or managing cryptographic key material

for critical-infrastructure communications; (C2) operated by or under the direct authority of a national security, signals intelligence, or critical-infrastructure agency; and (C3) the compromise is independently documented in a peer-reviewed publication, government report, or contemporaneous official statement.

The six included incidents over 2011–2024 are listed in Supplementary Table S1 with their tier classification and a brief justification. Three are classified as Tier 1 (direct compromise of an EA-architecture system, whether the breach was of its cryptographic primitives or of its operational infrastructure); one as Tier 2 (the SolarWinds compromise of cryptographic distribution infrastructure via build-chain); two as Tier 3 (contextual analogues: insider exfiltration of cryptographic tooling, and compromise of equivalent-target-class government systems where the mechanism was not architecturally specific to EA). The Salt Typhoon sensitivity (its exclusion from the cohort) is reported in Supplementary §S19.1. Tier-stratified rate estimates are in Table 5.

Table 5: Stratified annual compromise rates by analogical tier. 95% CIs from Garwood exact Poisson intervals. **Population rate:** probability of at least one compromise event across the population of N_A analogous systems in a given year, computed as $1 - \exp(-k/T)$. **Per-system rate:** Poisson rate of compromise per individual system per year, $k/(N_A T)$. The per-system rate is the policy-relevant quantity for an individual operator. The population rate gives the probability that *some* system in the analogue cohort is compromised in a year. The two answer different questions and should not be conflated.

Tier	k	Population rate	95% CI	Per-system rate
Tier 1 only (direct analogue)	3	20.6%	[4.6%, 49.1%]	0.46%/yr
Tier 1+2 (strong analogue)	4	26.5%	[8.0%, 54.5%]	0.62%/yr
Tier 1+2+3 (all)	6	37.0%	[15.6%, 63.4%]	0.92%/yr

5.1.2 Maximum Likelihood and Bayesian Estimation

The denominator $N_A = 50$ comprises the count of national-scale systems active during 2011–2024 that satisfy inclusion criteria C1–C2 above and fall within the analogue class motivated by the requirements analysis of Abelson et al. [1], which argued that secure third-party access infrastructure would have to operate at the assurance level of the most sensitive existing government cryptographic systems. The cohort is the union of five sovereign cryptographic sub-populations: US National Security Systems (~ 14), Five Eyes sovereign infrastructures (~ 10), EU national frameworks (~ 12), NATO collective infrastructure (~ 8), and CALEA-mandated or ETSI-equivalent lawful-intercept carriers (~ 6), with the documented construction in Supplementary §S2. The enumeration unit is an independently operated and accredited cryptographic domain: a system with its own key-management infrastructure, personnel, and accreditation boundary. The boundary depends on definitional choice in two respects—which programmes qualify, and at what granularity a sovereign framework is counted, with programme-level enumeration yielding the coarser count and installation-level enumeration the finer—so N_A could plausibly be defended at any value between 35 (coarse) and 75 (fine), and the denominator bracket below is simultaneously a unit-of-analysis sensitivity. The qualitative finding (a per-system compromise rate of order 1%/yr) is robust across this range: at $N_A = 35$ the per-system rate becomes $6/(35 \cdot 13) = 1.32\%/yr$ (projecting to $\sim 12\%$ at $10\times$), and at $N_A = 75$ it becomes $6/(75 \cdot 13) = 0.62\%/yr$ (projecting to $\sim 6\%$ at $10\times$). Both bracket the primary projection.

Breach events are modelled as a Poisson process with rate λ across a population of $N_A = 50$ analogous systems over $T = 13$ years. (The 2011–2024 window is counted as $T = 13$ years of exposure, treating the endpoint years as partial; counting the window inclusively as 14 calendar years would lower the full-cohort per-system rate from 0.92% to 0.86%/yr without affecting any qualitative finding. Streams B and C count their windows inclusively.) The *cohort-level* MLE rate (compromises per year across the whole analogue cohort) is $\hat{\lambda}_{MLE}^{cohort} = k/T = 6/13 = 0.462$

breaches per year, giving the cohort-annual population rate $P_{MLE}^{cohort} = 1 - \exp(-k/T) = 37.0\%$ with 95% CI [15.6%, 63.4%]. The *per-system* MLE rate (the policy-relevant quantity for an individual operator) is $\hat{\lambda}_{MLE}^{sys} = k/(N_A T) = 6/650 = 0.92\%$ per system-year. The two answer different questions. Both are used below.

Under three Bayesian prior specifications (working prior Gamma(2, 5); moderately optimistic Gamma(2, 100); and extreme strong Gamma(2, 400) with an MTTF prior of 200 years), the posterior means are 35.9%, 6.8%, and 1.9% respectively. The structurally significant finding is that under either parameterisation of an extreme 200-year MTTF prior, the empirical data prevent the posterior mean from falling below approximately 2% (strong prior) or 5.6% (diffuse prior). The five non-Weibull methods yield a consensus central estimate of approximately 36%.

5.1.3 Summary

Pillar I Stream A produces two distinct headline quantities that must not be conflated. The *population rate* (probability that at least one system in the 50-system analogue cohort is compromised in a given year) is $\sim 37\%$ under the full cohort. This is not the policy-relevant quantity for an individual EA operator. The *per-system rate* (Poisson rate per individual system per year) is the policy-relevant baseline. Its value depends on which inclusion criterion is applied:

- Tier 1 only (direct T-EA architectural analogue, $k = 3$): 0.46%/yr
- Tier 1+2 (adding build-chain compromise, $k = 4$): 0.62%/yr
- Tier 1+2+3 (adding contextual analogues, $k = 6$): 0.92%/yr

Applying the projection formula $1 - \exp(-\lambda \cdot \text{premium})$ across this range and across the defensible EA targeting-premium range $[3\times, 15\times]$ yields the joint range [1.4%, 12.9%] annually for the per-system Stream A Pillar I projection. The central cell of the grid (full cohort, $10\times$ premium) gives 8.8%; the Tier 1 cell at $10\times$ gives 4.5%; the most aggressive cell (full cohort, $15\times$) gives 12.9%. Under the most optimistic Bayesian prior (Gamma(2, 400) with an MTTF prior of 200 years), the empirical data hold the posterior mean above 1.9%. The Salt Typhoon sensitivity (full cohort with it excluded, $k = 5$) is reported in Supplementary §S19.1 and does not change the qualitative range.

5.2 Stream B: Certificate Authority Cohort

Stream B provides an architectural bridge between Stream A (T-EA-leaning) and Stream C (OTT-EA-leaning). Certificate Authorities resemble T-EA operators in operating under regulatory oversight with unitary corporate authority and concentrated cryptographic-key custody, but resemble OTT-EA operators in serving large distributed subscriber populations through key infrastructure that is operationally segregated from the certificate issuance and revocation data flows. The architectural fit to either pure class is partial. We treat Stream B as anchoring the centralised single-operator class generally, and use it as a check on the consistency of Stream A and Stream C estimates rather than as a primary anchor for either architectural extreme.

Stream B applies Poisson cohort methods to a 19-year record of Certificate Authority private-key compromises across 130 trusted CAs. This provides a completely independent dataset against a known population denominator. Key incidents include DigiNotar (2011) [48], the Comodo reseller breaches (2008, 2011), TURKTRUST (2013) [49], the WoSign/StartCom back-dating disclosures (2016), and the Symantec mis-issuance pattern (2017). The complete eleven-incident list with documentation and inclusion criterion is given in Supplementary Section S2. Stream B's standalone MLE rate is $11/2,470 = 0.445\%$ per CA-year (Garwood 95% CI [0.222%, 0.797%]). The annual incident counts are consistent with the Poisson specification: the dispersion index across the 19 cohort-years is 0.83 (slightly under-dispersed; χ^2_{18} dispersion test $p = 0.67$), and a negative-binomial refit collapses to the Poisson boundary (dispersion MLE of zero). The test has limited power at these counts, but the practical point stands either way: overdispersion-robust intervals would be no wider than the Garwood intervals reported. Projected through a $10\times$

EA targeting premium (a value in the upper-mid of the structured-judgement $3\text{--}15\times$ range; §11.3 derives the range and reports the range-median projections) this yields an annual range of $[2.20\%, 7.66\%]$, which overlaps with the Pillar II Fréchet–Hoeffding interval of $[2.2\%, 7.5\%]$ derived from per-scenario probabilities. Both anchors place the centralised single-operator class in the low single-digit annual range. Stream B and Pillar II share calibrating evidence on cryptographic-infrastructure operator failure modes, so the agreement is partial corroboration within a coherent evidence base rather than independent verification. Pooling with Stream A under a common-rate Poisson model gives the fixed-effect estimator $\hat{\lambda} = k/E = 17/3,120 = 0.545\%$ per system-year (Garwood 95% CI $[0.32\%, 0.87\%]$). Under the common-rate assumption this is the inverse-variance weighted estimator. We use it as the headline pooled rate for the centralised single-operator class generally, while noting that Stream A and Stream B individually anchor different architectural sub-cases. The two streams have visibly different observed per-system rates (Stream A $0.92\%/yr$; Stream B $0.45\%/yr$), and a strict-inclusion sensitivity restricting Stream B to clearly adversarial compromises (Supplementary Section S2) yields a lower pooled rate. Both choices produce a $10\times$ projection in the low-single-digit range.

5.3 Stream C: Platform-Level Key/Data Compromise Cohort

Stream C is the OTT-EA case’s empirical anchor. Its constituent incidents share the architectural property that the compromised operator is a major platform provider holding cryptographic key material, authentication infrastructure, or encrypted user data at scale across a large user population, with $\mathcal{K}$ and $\mathcal{D}$ operationally segregated within the operator’s infrastructure. The architectural fit to OTT-EA is partial in the same sense that Stream A’s fit to T-EA is partial. No public EA-specific compromise of either class exists, but the Stream C cohort captures the multi-stage, segregation-traversing compromise pattern that distinguishes OTT-EA risk from T-EA risk, and provides the empirical foundation for the P_3 (segregated-data acquisition) and P_4 (multi-stage detection avoidance) parameters introduced in Section 6.

5.3.1 Inclusion Criteria

An incident is included in Stream C if and only if it satisfies all four conditions: (D1) the system was operated by a major platform provider holding cryptographic key material, authentication tokens, or encrypted user data on behalf of an external user population numbering in the millions or larger; (D2) the compromise involved unauthorised access to, or exfiltration from, infrastructure components serving the platform’s key custody, identity, or encrypted-data-handling functions; (D3) the operator was not a national-security or critical-infrastructure agency in the sense of Stream A’s C2 criterion (which would route the incident to Stream A) and was not a Certificate Authority in the sense of Stream B (which would route the incident there); and (D4) the compromise is independently documented in a vendor post-mortem or transparency report, a regulatory disclosure (8-K, ICO, or equivalent), a national CERT or CISA advisory, or a peer-reviewed publication. Criteria D1–D3 jointly ensure that Stream C is disjoint from Streams A and B and that included incidents have plausible architectural relevance to a hypothetical OTT-EA deployment.

5.3.2 Empirical Dataset

Fourteen incidents over $T = 7$ years (2018–2024) satisfy the inclusion criteria. One further candidate (Cloudflare 2023) is documented in the near-miss appendix (Supplementary §S4.2) but not counted in any rate calculation, on the basis that no customer data or service keys were accessed. Each incident is classified along four binary or ordinal dimensions: whether key material was obtained ($K \in \{Y, P, N\}$, with P denoting partial or downstream key acquisition); whether ciphertext or otherwise-encrypted user data was obtained ($D \in \{Y, P, N\}$); whether *joint* key-and-data compromise occurred at a level sufficient to map operationally onto a hypothetical OTT-EA

decryption ($J \in \{Y, P, N\}$); and whether the attack path traversed *cross-cutting* infrastructure shared between the key-management and data-storage subsystems ($X \in \{Y, P, N\}$). The J classification is the most consequential for OTT-EA calibration. The X classification informs the cross-cutting fraction parameter used in Section 7.

The complete classification table is Supplementary Table S3; the per-incident documentation, including the source for each $K/D/J/X$ classification and the rationale for inclusion or exclusion, is in Supplementary §S4.

5.3.3 Cohort Population and Rate Estimation

The relevant population denominator for Stream C is the count of platform operators meeting the D1 criterion: major platform providers holding cryptographic key material, authentication infrastructure, or encrypted user data at scale, active during the 2018–2024 window. We estimate this population at $N_C = 75$ operators, drawing on the union of: top-tier cloud infrastructure providers (~ 8); major SaaS and productivity platforms (~ 15); identity and authentication providers (~ 8); password and secret managers (~ 6); code hosting and CI/CD platforms (~ 6); content delivery and edge providers (~ 5); messaging and communications platforms (~ 8); and other globally significant platform operators (~ 19). The full operator inventory is provided in Supplementary §S4 and in the reproducibility archive (Section 13). We treat $N_C = 75$ as the central value and report sensitivity across $N_C \in \{50, 100\}$.

The exposure is $E_C = N_C \cdot T = 75 \cdot 7 = 525$ operator-years. Stratified rates by classification dimension:

Table 6: Stream C rate estimates by classification. Per-system rate computed as $k/(N_C \cdot T)$; population rate (probability of at least one qualifying incident across the N_C -operator cohort in a given year) computed as $1 - \exp(-k/T)$. Garwood exact Poisson 95% CIs. The recommended headline anchor is the **Tier 0 + Tier 1, $J = Y$ strict-joint** row at 0.95%/yr, which is the rate restricted to architecturally clean OTT-EA analogues where joint key-and-data compromise is documented rather than interpretive. The Tier 0 row is the very-conservative lower bracket. The all-tiers, inclusive-joint row is the upper bracket. The qualitative ordering Stream B < Stream A $\approx$ Stream C at the order of 1%/yr holds across the full range.

Classification	k	Per-system rate	95% CI	Population rate
<i>Architectural-fit stratification</i>				
Tier 0 only (gold standard)	3	0.57%/yr	[0.12%, 1.67%]	34.9%
Tier 0 + Tier 1	5	0.95%/yr	[0.31%, 2.22%]	51.0%
Tier 0 + Tier 1 + Tier 2	12	2.29%/yr	[1.18%, 4.00%]	82.0%
All tiers (incl. Tier 3)	14	2.67%/yr	[1.46%, 4.48%]	86.5%
<i>Joint-compromise stratification (J)</i>				
$J = Y$ strict, all tiers	7	1.33%/yr	[0.54%, 2.75%]	63.2%
$J = Y$ strict, Tier 0 + 1	5	0.95%/yr	[0.31%, 2.22%]	51.0%
$J \in \{Y, P\}$ inclusive	13	2.48%/yr	[1.32%, 4.23%]	84.4%
<i>Robustness checks</i>				
$J = Y$ strict, no Microsoft	6	1.14%/yr	[0.42%, 2.49%]	57.6%
$J = Y$, Tier 0+1, no Microsoft	4	0.76%/yr	[0.21%, 1.95%]	43.5%
$J = Y$ strict, $N_C = 50$	7	2.00%/yr	[0.80%, 4.12%]	63.2%
$J = Y$ strict, $N_C = 100$	7	1.00%/yr	[0.40%, 2.06%]	63.2%

The headline Stream C estimate is the architectural-fit-restricted strict-joint rate $\hat{\lambda}_C^{T0+T1,J=Y} = 0.95\%$ per operator-year ($k = 5$ over $E_C = 525$ operator-years, Garwood 95% CI [0.31%, 2.22%]). This is the rate restricted to architecturally clean OTT-EA analogues: incidents where the operator’s key-custody role is documented (Tier 0 or 1) and the compromise involved *joint* key-and-data acquisition at a level operationally sufficient to map onto OTT-EA decryption ($J = Y$). We also report a very-conservative Tier 0 lower bracket of 0.57%/yr ($k = 3$) and an all-tiers inclusive- J upper bracket of 2.48%/yr ($k = 13$). The substantive comparison to

Stream A ($\sim 0.92\%/yr$) and Stream B ($\sim 0.45\%/yr$) is robust to this interval. The all-tiers strict-joint rate of $1.33\%/yr$ ($J = Y$ across all tiers; coincidentally also the rate implied by the seven cross-cutting incidents, $X = Y$) provides a closely related upper anchor specifically for the correlated-campaign analysis in Section 8.

5.3.4 Architectural Caveats and Cross-Stream Comparison

Caveats. (i) *Denominator imprecision.* $N_C = 75$ is constructed from rough subcategory estimates and is less precisely defined than $N_A = 50$ or $N_B = 130$. The central value could plausibly be defended at any value in $[50, 100]$, with rate sensitivity reported in Table 6. (ii) *Operator clustering.* Three of the fourteen incidents involve Microsoft. The no-Microsoft sensitivity rows ($k = 6$ across all tiers, $1.14\%/yr$; $k = 4$ restricted to Tier 0+1, $0.76\%/yr$) bracket the alternative interpretation that Microsoft’s incident clustering reflects within-operator concentration rather than a population-level rate. (iii) *Disclosure visibility bias.* Selection is driven by disclosure visibility, and the bias runs in both directions. Toward overstatement: catastrophic compromises of prominent operators are far more visible than the quiet operating history of the broader cohort, so an incident-led literature can inflate perceived base rates. Toward understatement: SEC-reporting US-based public companies are over-represented relative to private operators and operators in jurisdictions without mandatory cyber-incident disclosure, so incidents outside that visibility regime are missing from the numerator while the denominator counts the operators. The construction here controls the first direction by fixing the denominator to an explicit operator inventory ($N_C = 75$, Supplementary §S4) rather than letting prominence define the cohort, which leaves the missing-incident direction as the residual bias. On that basis the headline rate is treated as a lower bound, while the two-sided character of the selection problem is acknowledged rather than assumed away. (iv) *Time-window selection.* The 2018–2024 window is bounded below by EPSS introduction (2018) and post-2018 maturation of cloud-platform architectures matching the OTT-EA reference class; earlier candidates (Yahoo 2013–2014, RSA SecurID 2011, Adobe 2013) would shift the central rate toward the lower bracket without changing the qualitative ordering.

Cross-stream ordering. The Stream C strict-joint Tier-0+1 rate ($0.95\%/yr$) exceeds Stream B’s CA-cohort rate ($0.45\%/yr$) and is close to Stream A’s per-system rate ($0.92\%/yr$ at the primary inclusion criterion). Two architectural factors are consistent: platform operators present larger and more dynamic attack surfaces than tightly controlled CA infrastructure, and the joint-compromise classification specifically counts the multi-stage compromise pattern characteristic of OTT-relevant attacks. The ordering Stream B < Stream A $\approx$ Stream C, all on the order of $1\%/yr$, is robust across the full range of Tier and J stratifications, the no-Microsoft sensitivity, and the N_C population sensitivity.

5.4 Cross-Stream Meta-Analysis

The three streams provide architecture-conditional empirical anchors: Stream A for T-EA, Stream C for OTT-EA, and Stream B as the centralised single-operator bridge. We do *not* pool all three streams into a single rate, because the architectural classes they anchor differ in ways that the common-rate Poisson model would obscure. Instead, we report stream-conditional projections and use the cross-stream disagreement itself as architectural information.

The appropriate targeting premium is uncertain and likely architecture-conditional. The most directly relevant external calibration is the Verizon DBIR’s actor-mix data: the share of breaches attributable to state-aligned espionage actors is several times higher for high-value and government target classes than the cross-sector base rate, a disparity of roughly $3\times$ to $10\times$ depending on sector and reporting year [37, 38]. The Salt Typhoon incident demonstrates successful targeting of CALEA infrastructure, and the Storm-0558 incident equivalently successful targeting of

platform-level signing-key infrastructure; neither incident provides a frequency multiplier on its own. We instead present projections across a range of premiums ($3\times$, $5\times$, $10\times$, $15\times$), applied separately to each stream’s empirical base rate.

T-EA projection (Stream A anchor). Applying targeting premiums of $3\times$ to $15\times$ across the three concentric inclusion criteria (Tier 1, Tier 1+2, full cohort) for Stream A’s per-system rate yields a joint projection range of 1.4% to 12.9% annually. The central cell (full cohort, $10\times$ premium) gives 8.8%; the most conservative cell (Tier 1, $3\times$) gives 1.4%; the most aggressive (full cohort, $15\times$) gives 12.9%. The Tier 1 cell at $10\times$ gives 4.5%. The defensible T-EA empirical-projection interval is therefore 1.4–12.9%, with the centre of the grid in the low single-digit range.

Centralised single-operator projection (Stream B anchor). At a $10\times$ premium applied to Stream B’s 0.45%/yr, the projection is 4.4% annually. At $3\times$, 1.3%; at $15\times$, 6.5%. (All premium projections in this section use the transform $1 - \exp(-\text{premium} \cdot \lambda)$.)

OTT-EA projection (Stream C anchor). At a $10\times$ premium applied to Stream C’s architectural-fit-restricted strict-joint rate of 0.95%/yr, the projection is 9.1% annually (or 12.5% at the all-tiers strict-joint upper bracket of 1.33%/yr). However, the appropriate targeting premium for OTT-EA relative to the Stream C base may be *lower* than the T-EA analogue, because the platform-operator base rate already reflects substantial existing targeting (these operators are already high-priority adversarial targets), whereas Stream A’s government-system base rate reflects systems that are largely shielded from non-EA-related routine targeting. Treating the EA-specific premium as $3\text{--}5\times$ over the Stream C headline base gives an OTT-EA projection of 2.8–4.7% annually under independence (3.9–6.4% at the 1.33%/yr all-tiers upper bracket), before applying the segregation discount that distinguishes OTT-EA from T-EA at the operational-compromise level (Section 6).

Figure 3 illustrates the premium sensitivity across all three Pillar I streams (Stream A T-EA-anchored, the pooled Stream A+B centralised single-operator class, and Stream C OTT-EA-anchored), with the applicable premium range differing across architectures.

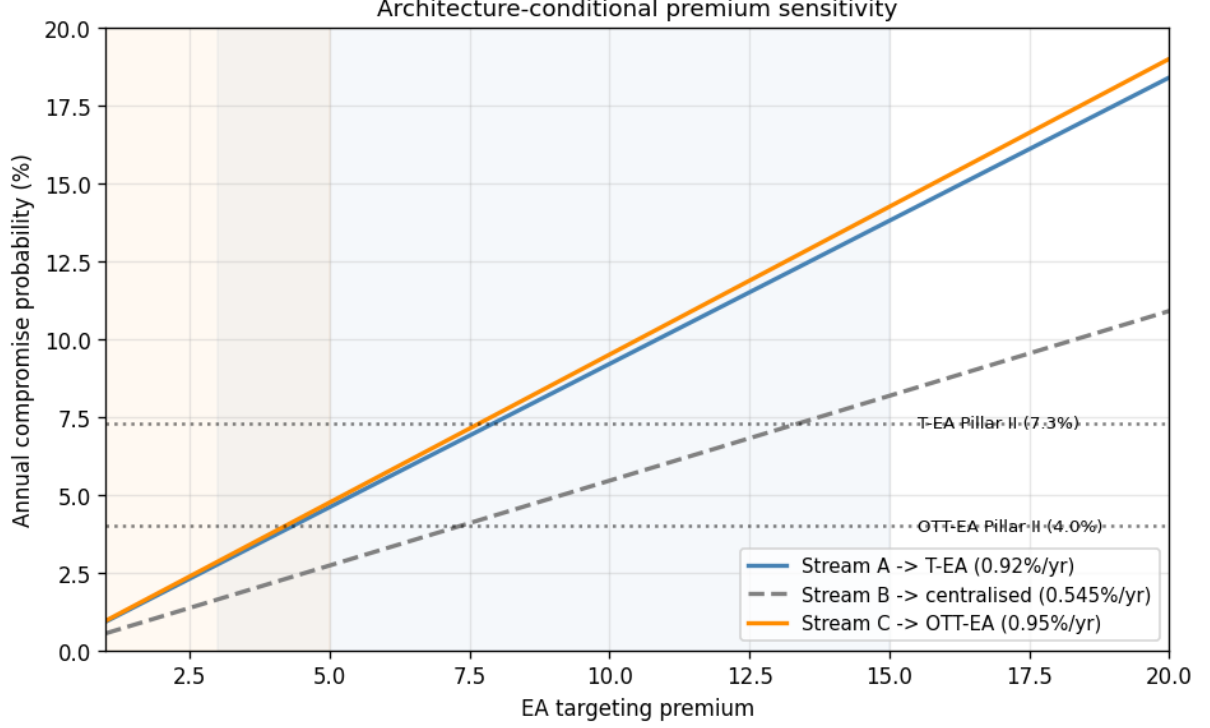


Figure 3: Architecture-conditional sensitivity of the meta-analysis projection to the EA targeting premium. The empirical base rates (pooled centralised single-operator: 0.545%/yr, $k = 17$, $E = 3,120$ system-years from Streams A and B; Stream A T-EA-anchored: 0.92%/yr; Stream C OTT-EA-anchored: 0.95%/yr) are multiplied by a premium representing elevated EA targeting. Applicable premium ranges differ across architectures: T-EA and the pooled centralised class span $3\times$ – $15\times$; OTT-EA’s defensible range is $1\times$ – $5\times$ (because Stream C’s base rate already reflects substantial existing platform targeting). At the centralised $10\times$ choice the projection is 5.3%, close to the Pillar III channel-aggregate projection of 5.4%; $5\times$ gives 2.7% and $15\times$ gives 7.8%. All projections use the transform $1 - \exp(-\text{premium} \cdot \lambda)$. At their respective central premium choices, the per-stream projections converge in the low-single-digit annual range. Shaded bands: 95% CIs transformed through each premium. **No single premium is empirically identified:** the $10\times$ value used in subsequent text is an illustrative upper-central choice rather than a measurement.

Alt text: Line plot of projected annual EA compromise probability as a function of the EA targeting premium (1x to 20x) for three base-rate anchors. Pooled centralised single-operator at 0.545%/yr (Streams A+B), Stream A T-EA-anchored at 0.92%/yr, and Stream C OTT-EA-anchored at 0.95%/yr; projections remain in low single-digit percent across the 3x to 15x defensible range.

6 Pillar II: Prospective Scenario Model

Pillar II uses Monte Carlo simulation to project the annual EA compromise probability under a defined set of threat scenarios. The model fixes seven scenarios spanning insider misuse, supply-chain attacks, zero-day exploitation, advanced persistent threats, operational failures, cryptographic compromise, and architectural exploits. For each scenario, parameter values are drawn from probability distributions calibrated to public threat-intelligence data (Mandiant M-Trends, EPSS). The pillar produces both an annual compromise probability under independence between scenarios and a Fréchet–Hoeffding bracket of the rate under any dependence structure compatible with the marginal distributions. Both T-EA and OTT-EA configurations are evaluated with a common scenario set and a common adversary parameterisation, so divergence between projections reflects architectural difference rather than calibration choices. The reader may take the headline FH brackets ($[2.2\%, 7.5\%]$ for T-EA and $[1.1\%, 4.0\%]$ for OTT-EA) as the Pillar II contribution to the framework’s calibration-conditional output ranges, and skip the technical details of scenario calibration and Monte Carlo implementation.

6.1 Model Architecture and Epistemic Framing

Pillar II is an explicit scenario-projection model, not a calibrated predictive model: no EA compromise events exist against which to validate it. Its contributions are the decomposition of risk into specific parameterised threat vectors, transparent propagation of input uncertainty, and quantification of the sensitivity of projections to the independence assumption through Fréchet–Hoeffding bounding.

The Pillar II model is structured to produce architecture-conditional projections. A common scenario set $S_1, \dots, S_7$ and a common two-tier adversary parameterisation are applied across both architectural classes, with the architectural distinction entering through the conditional outcome decomposition (Section 6.3): T-EA outcomes follow a two-stage decomposition $p_i^{\text{cond, key}} = P_1 \cdot P_2$, while OTT-EA outcomes follow a four-stage decomposition incorporating the segregated-data acquisition and multi-stage detection parameters. This structure ensures that the architecture-conditional projections share their underlying threat-model parameterisation, so that the divergence between T-EA and OTT-EA projections is interpretable as an architectural effect rather than a parameterisation choice.

6.2 Two-Tier Adversary Model and Parameter Structure

Each scenario S_i ($i = 1, \dots, 7$) has a mixing weight $w_i^{\text{APT}} \in [0, 1]$ representing the fraction of attempts from nation-state actors. For iteration k :

$$T_{ki} \sim \text{Bernoulli}(w_i^{\text{APT}}), \quad (1)$$

$$P_{ki}^{\text{EPSS}} = T_{ki} \cdot X_{ki}^{\text{APT}} + (1 - T_{ki}) \cdot X_{ki}^{\text{opp}}, \quad (2)$$

where $X_{ki}^{\text{opp}} \sim \text{Beta}(\alpha_i^{\text{opp}}, \beta_i^{\text{opp}})$ is calibrated to the EPSS score P_{10} – P_{90} range for CVEs in the relevant ATT&CK technique class, and X_{ki}^{APT} applies an APT-tier exploitation uplift to the opportunistic midpoint, modelled as a log-normal multiplier with median $2\times$ and examined over a $1.2\times$ – $3.0\times$ sensitivity range. Scenarios S_1 , S_3 , and S_4 form a coordinated-campaign group with campaign-activation probability $p^{\text{camp}} \in [0.10, 0.20]$ and boost factor $b \in [1.30, 1.80]$.

6.3 Architecture-Conditional Outcome Decomposition

Each scenario is parameterised with sequential conditional probabilities that decompose differently for the two architectural classes. The first stage, in which a scenario attempt E_i produces access-pathway compromise, is common across architectures:

$$C_{i}^{\text{acc}} \mid E_i = 1 \sim \text{Bernoulli}(p_i^{\text{cond, acc}}), \quad (3)$$

representing the probability of obtaining unauthorised operational access to the EA system given an attempt via scenario i .

6.3.1 T-EA Outcome Decomposition

For T-EA, the second stage, technical compromise (key-material exfiltration) given access, uses a two-factor decomposition:

$$C_i^{\text{key, T}} \mid C_i^{\text{acc}} = 1 \sim \text{Bernoulli}(p_i^{\text{cond, key}}), \quad p_i^{\text{cond, key}} = P_1 \cdot P_2, \quad (4)$$

where P_1 is the probability of reaching the key-management layer given system access, and P_2 is the HSM-tier-conditional probability of key extraction. Because $\mathcal{K}$ and $\mathcal{D}$ are co-located in T-EA architectures (Definition 2, Remark 1), operational compromise collapses to technical compromise: $C_i^{\text{op, T}} = C_i^{\text{key, T}}$.

6.3.2 OTT-EA Outcome Decomposition

For OTT-EA, the technical compromise stage is identical. Obtaining key material from $\mathcal{K}$ has the same mechanics regardless of whether $\mathcal{D}$ is co-located, but operational compromise additionally requires obtaining ciphertext from architecturally segregated $\mathcal{D}$ and completing the multi-stage operation without detection-and-block:

$$C_i^{\text{key,OTT}} \mid C_i^{\text{acc}} = 1 \sim \text{Bernoulli}(p_i^{\text{cond,key}}), \quad (5)$$

$$C_i^{\text{op,OTT}} \mid C_i^{\text{key,OTT}} = 1 \sim \text{Bernoulli}(p_i^{\text{op,seg}}), \quad (6)$$

where $p_i^{\text{op,seg}}$ is the conditional probability of completing operational compromise given technical compromise. This factor decomposes into two terms reflecting the two ways an attacker reaches operational compromise from a position of having obtained keys:

$$p_i^{\text{op,seg}} = \xi_i + (1 - \xi_i) \cdot P_3 \cdot P_4, \quad (7)$$

where:

- $\xi_i \in [0, 1]$ is the *cross-cutting fraction* for scenario i : the probability that a scenario- i attack path traverses shared infrastructure (identity provider, build pipeline, privileged-role credentials) so that segregation between $\mathcal{K}$ and $\mathcal{D}$ does not present an additional barrier;
- $P_3 \in [0, 1]$ is the conditional probability of obtaining ciphertext from $\mathcal{D}$ given key access in the *non-cross-cutting* case;
- $P_4 \in [0, 1]$ is the conditional probability of completing the multi-stage operation without detection-and-block in the non-cross-cutting case.

A fraction ξ_i of attack paths inherently bypass segregation (operational factor = 1); the remaining $(1 - \xi_i)$ must traverse a multi-stage chain with conditional success $P_3 \cdot P_4$.

6.3.3 System-Level Aggregation

System-level outcomes aggregate using the complement-of-product formula:

$$\Lambda^{\text{acc}} = 1 - \prod_{i=1}^7 (1 - C_i^{\text{acc}}), \quad (8)$$

$$\Lambda^{\text{key}} = 1 - \prod_{i=1}^7 (1 - C_i^{\text{key,T}}), \quad (9)$$

$$\Lambda^{\text{op,T}} = \Lambda^{\text{key}} \quad (\text{architectural collapse, Remark 1}), \quad (10)$$

$$\Lambda^{\text{op,OTT}} = 1 - \prod_{i=1}^7 (1 - C_i^{\text{op,OTT}}). \quad (11)$$

This formula is exact under mutual independence of scenario outcomes. That is a strong assumption, and its implications are bounded in Section 6.5 and addressed structurally in Section 8.

6.3.4 Calibration of ξ_i , P_3 , and P_4

The cross-cutting fractions ξ_i are calibrated against the Stream C incident base (Section 5.3; Supplementary Table S3), mapping each Stream C incident's documented attack path onto the nearest of the seven scenarios. The Stream C aggregate cross-cutting fraction $X = Y$ is $7/14 = 0.50$. Per-scenario values reflect the architectural specificity of each scenario:

The conditional probabilities P_3 and P_4 are calibrated against the Stream C incidents that did not exhibit cross-cutting attack paths, and against Mandiant M-Trends 2024 dwell-time and

Table 7: Per-scenario cross-cutting fractions for the OTT-EA outcome decomposition. Values calibrated against Stream C (Section 5) with sensitivity range reflecting classification uncertainty. These are Pillar II scenario-level quantities, distinct from the Pillar III per-channel fractions of Table 8.

Scenario	Description	Central ξ_i	Range	Calibration
S_1	Stolen credentials	0.30	[0.20, 0.45]	Shared identity provider risk
S_2	External app exploit	0.20	[0.10, 0.30]	Typically subsystem-localised
S_3	Edge exploitation	0.45	[0.30, 0.60]	Edge appliances commonly cross-cutting
S_4	Lateral / supply chain	0.55	[0.40, 0.70]	Cross-cutting by design
S_5	Insider	0.30	[0.15, 0.50]	Privileged insider variability
S_6	HSM extraction	0.10	[0.05, 0.20]	Highly key-specific
S_7	Cryptographic protocol	0.10	[0.05, 0.20]	Highly key-specific

detection-block data respectively. Central values: $P_3 = 0.50$ (range [0.30, 0.80]), $P_4 = 0.60$ (range [0.40, 0.80]). The product $P_3 \cdot P_4$ has central value 0.30 with range [0.12, 0.64].

These calibrations are deliberately wide. The Stream C incident base of 14 incidents is too small to support tight P_3 or P_4 estimates, and the ξ_i values above are primarily judgement-based mappings of Stream C incident classifications onto the seven scenarios. The sensitivity analysis in Section 6.6 reports how the OTT-EA projection varies across the full joint range, and Supplementary §S10 tabulates the P_3P_4 -by- ξ grid in full.

6.4 System-Level Annual Projections

The central independence-based projection aggregates the seven per-scenario technical-compromise probabilities at their central values; computed in closed form, it carries no prior-width parameter. A Monte Carlo with $N = 200,000$ iterations propagates parameter uncertainty around this projection, drawing the per-scenario rates and the shared aggregation parameters from the priors specified in Supplementary §S9. The Monte Carlo median agrees with the closed-form central to within rounding and, because each prior is centred on the corresponding central value, the central figures reported below are governed by those central values rather than by the prior *widths*. The widths affect only the dispersion of the simulated distribution. That dispersion is examined in the sensitivity analysis of Section 6.6 and is not reported as a confidence interval on the central projection. The projections are reported separately for each architectural class.

6.4.1 T-EA projections

For T-EA, the central independence-based projections are: EA access-pathway $\Lambda^{\text{acc}} = 16.8\%$; EA technical compromise $\Lambda^{\text{key}} = 7.3\%$; operational compromise $\Lambda^{\text{op,T}} = \Lambda^{\text{key}} = 7.3\%$ (architectural collapse); non-EA baseline access-pathway 12.3%; non-EA baseline technical compromise 0% by construction. The dominant contributors to system-level risk are S_1 (stolen credentials, $\sim 2.2\%$ technical compromise per scenario), S_3 (edge exploitation, $\sim 1.8\%$), and S_5 (insider, $\sim 1.7\%$). EA-specific scenarios S_6 (HSM extraction) and S_7 (cryptographic protocol) each contribute less than 0.5% on average, reflecting the rarity of the underlying technique classes while marking the existence of risk channels unique to EA systems.

6.4.2 OTT-EA projections

For OTT-EA, the same per-scenario technical compromise probabilities $\Pr(C_i^{\text{key}})$ are propagated through Equations (6)–(7), with the per-scenario cross-cutting fractions from Table 7 and the central values $P_3 = 0.50$, $P_4 = 0.60$ (so $P_3 \cdot P_4 = 0.30$).

The per-scenario operational-compromise factor $p_i^{\text{op,seg}} = \xi_i + (1 - \xi_i) \cdot 0.30$ takes values ranging from 0.37 (S_6, S_7 , where the architectural specificity limits cross-cutting) to 0.69 (S_4 , where

supply-chain attack paths are cross-cutting by design). Applied to the per-scenario technical compromise probabilities and aggregated, this gives:

$$\Lambda_{\text{central}}^{\text{op,OTT}} \approx 3.9\%. \quad (12)$$

The dominant contributors shift modestly relative to T-EA: S_3 and S_4 retain or strengthen their relative contribution under OTT because their higher cross-cutting fractions reduce the segregation discount, while S_6 and S_7 become less significant because their high architectural specificity attracts the full segregation discount. S_1 and S_5 remain prominent contributors with intermediate cross-cutting fractions.

6.4.3 T-EA and OTT-EA central comparison

The central projection ratio $\Lambda^{\text{op,OTT}}/\Lambda^{\text{op,T}} \approx 0.54$ at the central parameterisation expresses the segregation gain as a near-halving of the T-EA central operational compromise probability for OTT-EA under independence. The interpretation is architectural: well-segregated OTT systems benefit from the multi-stage AND-chain at the central tendency, but, as the next two subsections show, this gain is strongly conditional on the cross-cutting fraction and substantially attenuated at the tail.

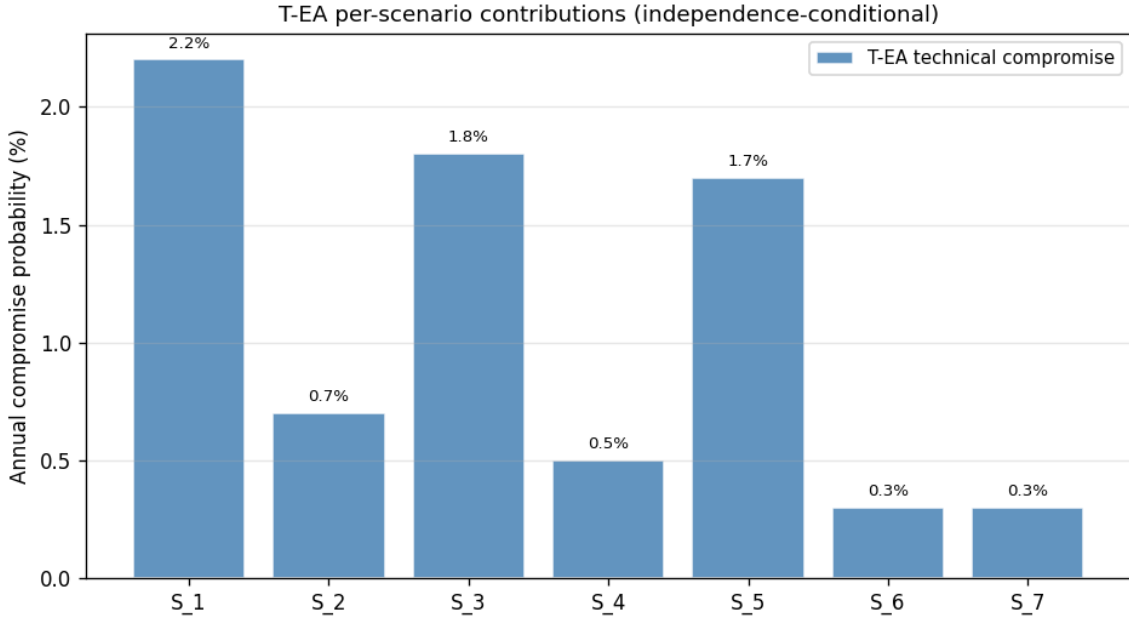


Figure 4: Per-scenario mean annual compromise contribution under the Pillar II central parameterisation (10^5 iterations, seed 2024). Error bars show 5th–95th percentile range on access-pathway probability. Hatched bars give mean technical compromise probability per scenario. The dominant contributors are S_1 (stolen credentials, $\sim 2.2\%$), S_3 (edge exploitation, $\sim 1.8\%$), and S_5 (insider, $\sim 1.7\%$). EA-specific specialist scenarios S_6 (HSM extraction) and S_7 (cryptographic protocol) each contribute less than 0.5%. **Independence-conditional values for the T-EA projection.** The parallel OTT-EA contributions are given in Figure 5 (Section 9), where each scenario’s contribution is reweighted by its operational-compromise factor $p_i^{\text{op,seg}}$.

Alt text: Bar chart of mean annual compromise contribution per scenario S_1 through S_7 under the Pillar II T-EA central parameterisation. Three scenarios dominate: S_1 (stolen credentials, approximately 2.2%), S_3 (edge exploitation, approximately 1.8%), and S_5 (insider); remaining scenarios contribute under 1%.

Error bars show 5th to 95th percentile ranges.

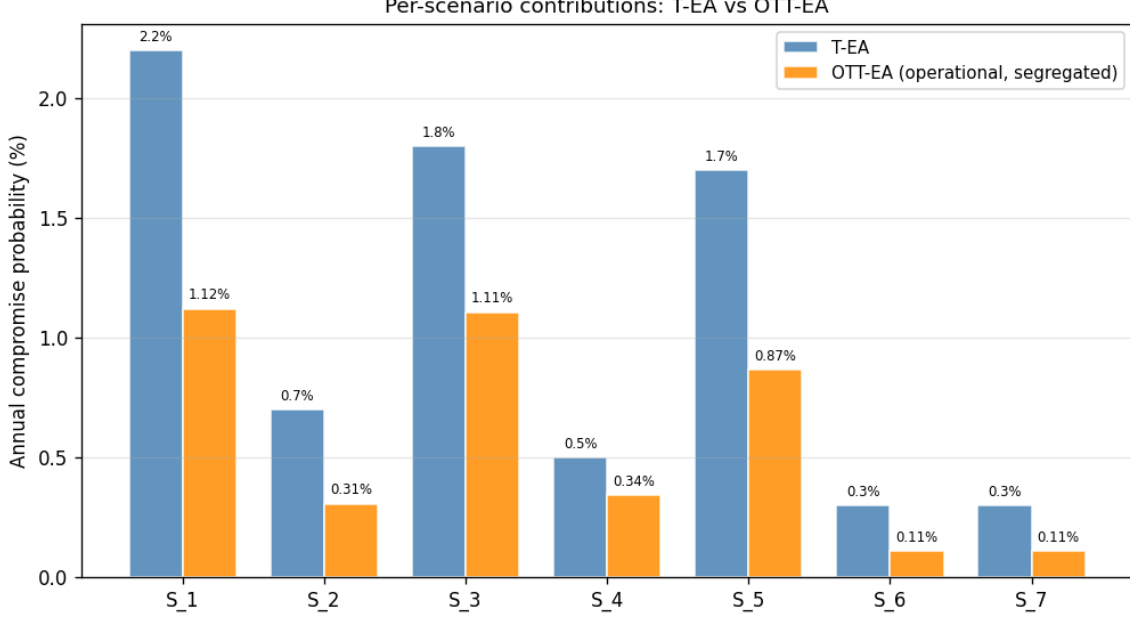


Figure 5: Per-scenario mean annual operational compromise contribution under the Pillar II OTT-EA central parameterisation, with each scenario’s contribution weighted by its operational-compromise factor $p_i^{\text{op,seg}} = \xi_i + (1 - \xi_i)P_3P_4$. Side-by-side comparison with T-EA contributions shows that S_4 (lateral / supply chain) retains its relative contribution because of its high cross-cutting fraction ($\xi = 0.55$), while S_6 (HSM extraction) and S_7 (cryptographic protocol) are further attenuated because of their low cross-cutting fractions and consequent near-full segregation discount. 10^5 iterations, seed 2024.

Alt text: Bar chart of per-scenario operational-compromise contributions under the Pillar II OTT-EA central parameterisation, with each scenario weighted by its operational-compromise factor. S_4 (lateral / supply chain) retains its relative contribution because of high cross-cutting fraction; remaining scenarios are attenuated by the multi-stage detection structure.

6.5 Fréchet–Hoeffding Bounding Analysis

The independence-based projections are conditional on the complement-of-product formula. To bound the effect of this assumption, we apply the Fréchet–Hoeffding limits for the union of dependent events, separately to each architectural class. The Fréchet–Hoeffding bounds are mathematically valid for any dependence structure given the per-scenario marginal probabilities estimated from the model. The qualifier “model-consistent” acknowledges that the marginals themselves are model outputs, not known constants. The bounds are sharp with respect to the dependence assumption but inherit any uncertainty in the marginal calibration.

6.5.1 T-EA bounds

For T-EA, the Fréchet–Hoeffding bounds take the standard form:

$$\max_i \Pr(C_i^{\text{key,T}}) \leq \Pr\left(\bigcup_i C_i^{\text{key,T}}\right) \leq \min\left(1, \sum_i \Pr(C_i^{\text{key,T}})\right). \quad (13)$$

Substituting per-scenario technical compromise means: lower bound (maximum individual, S_1) $\approx 2.2\%$; upper bound (sum of means) $\approx 7.5\%$. The independence-based projection of 7.3% sits near the upper bound. The model-consistent T-EA interval under any dependence structure is therefore approximately $[2.2\%, 7.5\%]$.

6.5.2 OTT-EA bounds

For OTT-EA, the same bounding formula applies to the per-scenario operational compromise events $C_i^{\text{op,OTT}}$, whose marginal probabilities satisfy $\Pr(C_i^{\text{op,OTT}}) = \Pr(C_i^{\text{key}}) \cdot p_i^{\text{op,seg}}$:

$$\max_i \Pr(C_i^{\text{op,OTT}}) \leq \Pr\left(\bigcup_i C_i^{\text{op,OTT}}\right) \leq \min\left(1, \sum_i \Pr(C_i^{\text{op,OTT}})\right). \quad (14)$$

Because each $\Pr(C_i^{\text{op,OTT}}) = \Pr(C_i^{\text{key}}) \cdot p_i^{\text{op,seg}}$ and $p_i^{\text{op,seg}} \leq 1$, both bounds for OTT-EA are *less than or equal to* the corresponding T-EA bounds under independence. Substituting per-scenario means at the central parameterisation:

- Lower bound (maximum individual): $\Pr(C_{S_1}^{\text{op,OTT}}) \approx 2.2\% \times 0.51 \approx 1.1\%$ (where $0.51 = \xi_{S_1} + (1 - \xi_{S_1}) \cdot 0.30 = 0.30 + 0.70 \cdot 0.30$);
- Upper bound (sum of per-scenario means): $\sum_i p_i^{\text{op,seg}} \cdot \Pr(C_i^{\text{key}}) \approx 4.0\%$ (equivalently, the $\Pr(C_i^{\text{key}})$ -weighted average of $p_i^{\text{op,seg}}$ is approximately 0.53, so the upper bound is approximately $0.53 \times 7.5\% \approx 4.0\%$).

The model-consistent OTT-EA interval under any dependence structure is therefore approximately $[1.1\%, 4.0\%]$ at the central P_3, P_4, ξ_i parameterisation.

6.5.3 Architectural comparison and the segregation gain

The architecturally interesting comparison is between the T-EA interval $[2.2\%, 7.5\%]$ and the OTT-EA interval $[1.1\%, 4.0\%]$. The OTT-EA interval is shifted downward, reflecting the segregation gain. The *interval width* is also smaller for OTT, reflecting that the segregation factor compresses the effect of underlying parameter variation. However, this comparison is at independent risk channels within each class. The architecturally distinctive feature of OTT-EA is that under correlated campaigns the segregation gain partially or fully collapses (Section 8).

Caveat on the OTT-EA lower bound. The Fréchet–Hoeffding lower bound is the comonotonic case, in which the seven scenarios are treated as if perfectly positively correlated. For OTT-EA, perfect correlation across scenarios is the worst case from the segregation perspective: it corresponds to a single APT campaign exploiting all seven attack vectors simultaneously, which is precisely the condition under which cross-cutting infrastructure (large ξ_i effective values) would be activated. The OTT-EA Fréchet lower bound therefore *understates* the worst-case dependence risk, because the $p_i^{\text{op,seg}}$ values used to derive it are calibrated against the average cross-cutting fraction rather than the campaign-correlated worst case. It is this limitation that motivates the explicit correlated-campaign treatment in Section 8, where $Z(t)$ is coupled specifically to cross-cutting edges.

Caveat on the upper bound. As in the T-EA case, the Fréchet–Hoeffding upper bound corresponds to the antitonic case under the assumption that the seven scenarios exhaust the attack surface. The seven scenarios cover the dominant attack vectors documented in DBIR, ATT&CK, and CISA advisory sources but do not constitute a mathematically complete enumeration. The bound is “model-consistent” rather than “model-free”.

The OTT-EA interval $[1.1\%, 4.0\%]$ is the honest representation of what Pillar II tells us about the OTT-EA central tendency under the calibrated parameterisation, with the caveat that tail behaviour under correlated campaigns is governed by the cross-coupling structure addressed in Section 8 rather than by Pillar II alone.

6.6 Sensitivity Analysis

Sensitivity analysis is reported separately for each architectural class, and also for the OTT-EA-specific parameters P_3 , P_4 , and ξ_i that have no T-EA analogue.

6.6.1 Common parameters: APT mixing and uplift

A two-way grid varying global APT mixing weight (10–50%) and APT EPSS uplift factor ($1.2\times\text{--}3.0\times$) yields T-EA technical-compromise central projections spanning 5.5–7.8% (the grid minimum 5.5% is the Pillar II parametric floor under independence). The corresponding OTT-EA grid spans 3.0–4.3%, shifted downward by roughly the central segregation factor (~ 0.55). Dominant sensitivity drivers in both grids are the conditional compromise probabilities for S_1 , S_3 , and S_5 and the global APT mixing weight, each contributing more than 1.5 percentage points of swing.

6.6.2 OTT-specific parameters: P_3 , P_4 , and ξ_i

The OTT-EA-specific parameters introduce a sensitivity dimension with no T-EA analogue. A three-way analysis over $P_3 \in [0.30, 0.80]$, $P_4 \in [0.40, 0.80]$, and a global multiplier $m_\xi \in [0.5, 1.5]$ on the central ξ_i values from Table 7 yields an OTT-EA central projection spanning 2.0%–6.0% across the full joint range. The defensible central interval at intermediate $m_\xi \in [0.75, 1.25]$ and central $P_3 \cdot P_4$ is [3.5%, 4.3%]. The full $(P_3 \cdot P_4, m_\xi)$ sensitivity grid is reported in Supplementary §S10, Table S7.

6.6.3 Scenario ordering and sensitivity reporting

The relative ordering of the seven scenarios should be treated as an informed modelling choice rather than an externally validated ranking. The same caveat applies to the per-scenario ξ_i values. The two-way sensitivity grid and one-way tornado for the Pillar II central projection are reported in Supplementary §S14.

7 Pillar III: Architectural Heuristic Decomposition

Pillar III provides a structural lower-bound check on the Pillar II projections by treating compromise risk as the union of risk across four irreducible channels (insider, zero-day, supply-chain, and operations) and computing the architecture-conditional compromise probability under the assumption that channels operate independently. The point is to show that EA compromise probability cannot be reduced below a structural floor determined by these four channels, regardless of the calibration choices made in the more detailed Pillar II scenario model. Pillar III is not a separate empirical analysis. It is an internal consistency check that the Pillar II projections sit above (or near) a defensible floor. The reader may take the channel-aggregate projections (approximately 5.4% per system-year for T-EA and 3.0% for OTT-EA under independence, with channel-minimum heuristic floors of 1.5% and 1.03% respectively) as the Pillar III contribution, and skip the per-channel parameter calibration. The architectural ordering (T-EA > OTT-EA at the central tendency under independence) holds under this construction, reflecting the additional operational steps OTT-EA requires for a full compromise.

7.1 Rationale and Approach

Pillars I and II both work *outwards* from data: historical incidents (Pillar I) and parameterised scenarios (Pillar II). Pillar III works *inwards*, from architecture. The question it asks is this: given the components any operationally viable EA system must contain, and given the best historically observed security performance for each component class in analogous domains, what is the lowest combined risk we can prudently project? The output is a heuristic aggregate, not a structural law, and the contrast with the other pillars is itself useful: agreement across all three is more than three times one method’s confirmation, but disagreement tells us which assumptions are doing the work.

The decomposition uses the same cross-cutting weighting machinery introduced for Pillar II (Section 6.3). The four non-eliminable risk channels are architecture-independent: any operationally viable EA system must employ cleared personnel, contain non-trivial code, depend on supply chain, and admit operational error, regardless of whether it is T-EA or OTT-EA. The architectural distinction enters at conversion. We distinguish *channel-triggered compromise* (the channel produces unauthorised access to some part of the system) from *operational compromise* (the access is sufficient to decrypt target communications). For T-EA the conversion is automatic by architectural collapse (Remark 1); for OTT-EA it is modulated by a per-channel cross-cutting fraction.

7.2 Four Non-Eliminable Component Risk Channels

Any operationally viable EA system must maintain a key escrow database, access-control mechanisms, cryptographic operations, authorised personnel, network connectivity, and audit systems. The presence of each component class establishes an irreducible attack surface: the component cannot be removed without violating operational viability, and creates at least one exploitable entry point.

1. *Insider threat* ($p_{\text{insider}} \geq 0.015$). Any operational EA system must employ cleared personnel. The CERT *Common Sense Guide to Mitigating Insider Threats* [50] documents insider-threat incidents as a recurring exposure across critical-infrastructure and government-sector organisations. The OPM exfiltration, CIA Vault 7, and Snowden disclosures all occurred within high-security clearance environments. The Stream C platform-incident base (Section 5.3) does not lower this estimate. The LastPass 2022, Microsoft Midnight Blizzard 2024, and several Okta incidents involve insider-mediated initial access at platform operators of comparable scale. We adopt 1.5% as a conservative floor applicable to both architectural classes.

2. *Zero-day vulnerabilities* ($p_{\text{zeroday}} \geq 0.015$). Any system of non-trivial complexity contains latent unpatched vulnerabilities. A minimum viable EA system requires at least $\sim 100,000$ lines of code. Even at 1 defect per 1,000 LOC, far below the industry-average range of 15–50 per 1,000 lines of delivered code documented by McConnell [51] and comparable to the best released-software rates reported there, this implies on the order of 100 latent defects. Bilge and Dumitras [52] document an average zero-day attack window of 312 days before public disclosure. The CISA KEV database confirms that HSM firmware, cryptographic libraries, and access-control middleware are all represented in actively exploited CVEs. OTT platform codebases are typically larger by several orders of magnitude (millions of LOC), but benefit from faster patch cadence and better continuous monitoring; the net effect on zero-day exposure rate is unresolved by the available evidence. We adopt 1.5% as a conservative floor applicable to both architectural classes, with sensitivity to the OTT-specific upward adjustment discussed in Section 7.5.

3. *Supply-chain exposure* ($p_{\text{supply}} \geq 0.015$). No EA operator can achieve complete vertical integration. The SolarWinds (2020) and XZ Utils (2024) incidents demonstrate that supply-chain attacks against specifically targeted security infrastructure are operational. The DBIR 2024 records supply-chain attacks in approximately 4% of breaches of critical-infrastructure organisations. The Stream C incident base contains four documented supply-chain or supply-chain-adjacent compromises (CodeCov 2021, MOVEit 2023, Storm-0558 via consumer-key exposure, Cloudflare via Atlassian) at platform operators, consistent with the floor. We adopt 1.5% as a conservative floor applicable to both architectural classes.

4. *Operational errors* ($p_{\text{ops}} \geq 0.010$). Operational errors (misconfigured access controls, key-management procedure deviations, certificate mismanagement) are distinct from software defects. The Mozilla CA incident dashboard [53] documents formal misissuance incident reports at a rate of 1–3% annually among the largest tier-one CAs (population denominator from CCADB [54]). The lawful-intercept infrastructure compromise in the Athens affair arose from a procedure failure (rogue software installation [7]). We adopt 1.0%.

7.3 Per-Channel Cross-Cutting Fractions

For the OTT-EA case, each channel-triggered compromise additionally requires that the resulting access support operational compromise of architecturally segregated $\mathcal{K}$ and $\mathcal{D}$. We define the per-channel cross-cutting fraction ξ_c as the probability that the channel’s realised compromise traverses cross-cutting infrastructure (shared identity provider, shared build pipeline, common privileged-role credentials, or analogous mechanism), so that the segregation between $\mathcal{K}$ and $\mathcal{D}$ does not present an additional barrier. The remaining $(1 - \xi_c)$ fraction must traverse the multi-stage segregation chain whose conditional success probability is the product $P_3 \cdot P_4$ (Section 6.3).

Table 8: Per-channel cross-cutting fractions for the OTT-EA Pillar III decomposition. Calibrated against the Stream C incident base (Section 6.3) and the per-scenario ξ_i values of Pillar II (Table 7). Architecturally consistent calibration: each channel’s ξ_i is the cross-cutting fraction appropriate for the dominant attack mechanism in that channel.

Channel	Dominant mechanism	ξ_c	Calibration
Insider	Privileged-role abuse	0.30	SRE / security-engineer cross-cutting variability
Zero-day	Software defect	0.30	Some shared-component zero-days, most subsystem-localised
Supply chain	Build/distribution	0.55	Build pipelines and SDKs cross-cutting by design
Operational error	Configuration drift	0.20	Misconfigurations typically subsystem-localised

The effective per-channel OTT-EA rate is

$$P_c^{\text{OTT,eff}} = P_c \cdot [\xi_c + (1 - \xi_c) \cdot P_3 \cdot P_4], \quad (15)$$

which reduces to P_c in the limit $\xi_c \rightarrow 1$ (perfect cross-cutting, no segregation gain) or $P_3 \cdot P_4 \rightarrow 1$ (no segregation effect), recovering the T-EA case. At the central calibration ($P_3 \cdot P_4 = 0.30$):

- Insider: $0.015 \cdot [0.30 + 0.70 \cdot 0.30] = 0.015 \cdot 0.51 = 0.77\%$
- Zero-day: $0.015 \cdot [0.30 + 0.70 \cdot 0.30] = 0.015 \cdot 0.51 = 0.77\%$
- Supply chain: $0.015 \cdot [0.55 + 0.45 \cdot 0.30] = 0.015 \cdot 0.685 = 1.03\%$
- Operational error: $0.010 \cdot [0.20 + 0.80 \cdot 0.30] = 0.010 \cdot 0.44 = 0.44\%$

7.4 Architecture-Conditional Channel-Aggregate Projection Estimates

Assuming independence among the four component risk channels (an assumption examined in Section 7.6), the channel-aggregate projection for each architectural class follows from the complement-of-product formula applied to the architecture-conditional effective rates.

7.4.1 T-EA channel-aggregate projection

For T-EA, $\xi_c \cdot 1 + (1 - \xi_c) \cdot P_3 \cdot P_4 \rightarrow 1$ for all channels under the architectural collapse (Remark 1), so $P_c^{\text{T,eff}} = P_c$:

$$\begin{aligned} P_{\text{ref}}^{\text{T}} &= 1 - (1 - p_{\text{insider}})(1 - p_{\text{zeroday}})(1 - p_{\text{supply}})(1 - p_{\text{ops}}) \\ &= 1 - (0.985)(0.985)(0.985)(0.990) = 1 - 0.946 = 5.4\%. \end{aligned} \quad (16)$$

This is the channel-aggregate projection for the centralised single-operator class, applied here to T-EA without architectural modification.

7.4.2 OTT-EA channel-aggregate projection

For OTT-EA, applying the effective rates from Equation (15):

$$\begin{aligned} P_{\text{ref}}^{\text{OTT}} &= 1 - (1 - 0.00765)(1 - 0.00765)(1 - 0.010275)(1 - 0.0044) \\ &= 1 - 0.97035 = 0.02965 \approx 3.0\%. \end{aligned} \quad (17)$$

The OTT-EA channel-aggregate projection of $\sim 3.0\%$ reflects the segregation gain at the central parameterisation of $P_3 \cdot P_4$, ξ_c values. The ratio $P_{\text{ref}}^{\text{OTT}}/P_{\text{ref}}^{\text{T}} \approx 0.55$ is quantitatively consistent with the Pillar II ratio of ~ 0.54 , because both pillars apply the same architectural correction mechanism through the segregation factor.

Independence-conditional only, both architectures. These estimates assume the four risk channels fail independently within each architectural class. The Bayesian model (Section 9.4) shows that realistic dependence inflates the annual 95th percentile substantially for both classes, with larger inflation for OTT-EA because correlated campaigns activate cross-cutting infrastructure and collapse the segregation gain. Under dependence, the system-level median may be higher or lower than the independence-based aggregates, but the tail is materially heavier in both cases. The independence-based aggregates should be read as lower-anchors for central tendency under independence, not as robust central estimates. The architecture-conditional Fréchet–Hoeffding intervals from Pillar II ($[2.2\%, 7.5\%]$ for T-EA; $[1.1\%, 4.0\%]$ for OTT-EA) are preferred for policy use.

7.4.3 Channel-minimum heuristics

The T-EA *channel-minimum heuristic* of 1.5% requires two assumptions that are not structurally guaranteed: (a) the four channels are the **dominant** risk sources, and (b) they are collectively **exhaustive** of all plausible compromise paths. If additional risk channels exist (e.g., compromised hardware supply chain, side-channel attacks on HSMs), the true floor would be higher than 1.5%. The figure follows from the Fréchet lower bound *within the four-channel model*: the probability of the union cannot be less than the maximum of the individual component probabilities so long as the four channels span the relevant compromise space.

The OTT-EA channel-minimum heuristic under the same logic is the maximum of the effective per-channel rates: $\max_c P_c^{\text{OTT,eff}} = 1.03\%$ (supply chain). The result is approximately one-third lower than the T-EA channel-minimum heuristic under the same assumptions. The same exhaustiveness caveat applies, with the additional caveat that the OTT-specific calibration parameters (P_3 , P_4 , ξ_c) are themselves only weakly empirically identified.

7.5 Sensitivity Analysis

The OTT-EA channel-aggregate projection is sensitive to two clusters of parameters that have no T-EA analogue: the segregation factor $P_3 \cdot P_4$ and the per-channel cross-cutting fractions ξ_c . The full joint $(P_3 \cdot P_4, m_\xi)$ sensitivity grid is reported in Supplementary §S11, Table S8. The OTT-EA Pillar III aggregate spans 1.5–4.5% across the full joint sensitivity range, with the defensible central interval at intermediate ξ -multiplier values approximately $[2.6\%, 3.3\%]$. An alternative calibration in which OTT channel base rates are taken higher than T-EA rates (doubling p_{zeroday} and p_{supply}) gives an OTT-EA channel-aggregate projection of approximately 4.7%, narrowing the gap to T-EA. This is reported as a sensitivity rather than the headline because the empirical evidence on whether platform zero-day and supply-chain rates exceed those of T-EA infrastructure is mixed.

7.6 Independence Assumption and Its Status

The single most powerful driver of the within-class agreement across Pillars I–III is the shared independence assumption. Positive correlation between risk channels places the combined risk

closer to the Fréchet lower bound (the maximum individual channel) than to the independence-based aggregate. This is the plausible case in which a single APT campaign simultaneously exploits insider access, a zero-day vulnerability, and supply-chain positioning.

For T-EA, this positive correlation moves the combined risk from 5.4% toward 1.5% (the maximum individual channel rate). For OTT-EA, the behaviour under correlation is qualitatively different: positive correlation activates cross-cutting infrastructure, the very mechanism through which ξ_c is realised at above-average values, so the correlated case both moves the combined risk toward the maximum individual rate *and* inflates the effective ξ_c toward 1. The combined effect is that under correlated campaigns, the OTT-EA combined risk approaches the T-EA combined risk, eroding the segregation gain that distinguishes them under independence. As the Bayesian model demonstrates in Section 8, this is the structural mechanism by which OTT-EA tail risk grows faster than T-EA tail risk under correlated-campaign conditions.

The independence assumption therefore produces results that are neither systematically conservative nor liberal: it underestimates tail risk in both architectural classes, while potentially overestimating the median for OTT-EA more than for T-EA. The Bayesian model in the next section is specifically designed to address this structural limitation with explicit cross-cutting coupling.

8 The Bayesian Structural Risk Model (Layer IV)

The Bayesian Structural Risk Model (Layer IV) provides the formal probabilistic framework underlying the paper’s tail-risk and dependence-related findings. It represents EA compromise as a path-based attack-graph problem with hazard rates on individual edges, common-mode correlated-campaign coupling, and EA-specific modifier factors that adjust baseline edge hazards by mechanism-specific multipliers (≥ 1). The OTT-EA model adds a parallel-subgraph structure: a key-side subgraph for cryptographic-key access, a data-side subgraph for ciphertext access, joined at an operational-compromise AND-node, with cross-cutting edges that traverse both subgraphs and a cross-cutting amplification factor $\gamma_X/\gamma \geq 1$. This structure produces the OTT-EA tail-divergence finding: under correlated campaigns, cross-cutting edges amplify more than subgraph-internal edges, inflating the upper-tail compromise probability. The reader may take the central output, a prior predictive distribution on annual compromise probability with 90% prior predictive intervals [1.4%, 16.5%] for T-EA and [0.8%, 17.4%] for OTT-EA, and skip the formal hierarchical-prior specification, hyperprior structure, and dependence-coupling derivations.

8.1 Overview and Rationale

The three-pillar framework produces empirically grounded estimates under stated assumptions, but its outputs are conditional on their assumptions, in particular the independence assumption, which cannot be validated for a prospective system. The Bayesian Structural Risk Model (Layer IV) produces full prior predictive distributions that propagate uncertainty from all model parameters through to the final output. It is implemented in two parallel architectural configurations, T-EA and OTT-EA, sharing common infrastructure (hierarchical priors, domain transfer, latent campaign variable) but differing in attack-graph topology and in the coupling of $Z(t)$ to cross-cutting edges.

Prior predictive, not posterior inference. No public dataset of EA-specific compromise events exists, so the Bayesian model is evaluated by forward sampling from the joint prior rather than by updating against an EA-specific likelihood. The outputs $\{q_1^{(r)}\}$ and $\{Q_T^{(r)}\}$ are prior predictive distributions whose informativeness comes from the empirical content of the priors (calibrated via domain transfer from Pillar I analogues), not from posterior conditioning on direct observations. “Bayesian” here refers to hierarchically structured priors, latent variables, and probabilistic forward modelling. No MCMC posterior inference is performed. The contribution

is not specific numerical estimates but a structured framework for uncertainty-aware deliberation in which qualitative conclusions robust across wide parameter ranges are explicitly distinguished from those that are not.

Status of the Bayesian medians: a calibration disclosure. The edge-hazard priors are calibrated, separately for each architectural class, to produce prior predictive outputs consistent with the architecture-matched three-pillar empirical range (3–6% annually for T-EA, 1.5–4% annually for OTT-EA). The Bayesian medians (4.0% T-EA; $\sim 2.6\%$ OTT-EA) therefore *cannot* be presented as independent corroboration of three-pillar near-equivalence. They are consistent with the within-class agreement by prior design. The genuinely additive contributions of this layer are: (i) tail shape (architecture- conditional), (ii) quantification of dependence uplift (which differs sharply between architectures because of cross-cutting coupling), (iii) exceedance probabilities at policy thresholds (conditional on calibration), and (iv) parameter uncertainty decomposition. Each is developed in §§9–10.

The model comprises five layers, applied in parallel for both architectures: (1) *Attack-graph layer*: a directed graph representing multi-step adversarial paths. For T-EA a single graph terminating at a unitary compromise node, for OTT-EA a compound graph with parallel key-side and data-side subgraphs joined at an operational-compromise AND-node with explicit cross-cutting edges. (2) *Bayesian hierarchical layer*: hierarchically specified priors over edge hazards, informed by analogous incident data via domain transfer (Stream A for T-EA, Stream C for OTT-EA). (3) *Dependence layer*: a latent campaign variable $Z(t)$ inducing positive correlation among attack events. For T-EA $Z(t)$ couples uniformly to all edges, for OTT-EA preferentially to cross-cutting edges. (4) *Adversarial targeting layer*: a utility-based model for adversary attention. (5) *Simulation layer*: Monte Carlo sampling from the joint prior, propagating uncertainty to produce prior predictive distributions over annual and cumulative compromise probabilities.

8.2 Attack Graph Model

8.2.1 T-EA attack graph

For T-EA, the attack graph is the standard directed-acyclic-graph formulation:

Definition 9 (T-EA Attack graph). Let $\mathcal{G}^T = (\mathcal{V}^T, \mathcal{E}^T)$ be a directed acyclic graph where $\mathcal{V}^T = \{v_0, v_1, \dots, v_n\}$ is the set of nodes, each representing a security-relevant system state (v_0 : adversary prior to any compromise; v_n : full operational compromise under architectural collapse, Definition 8 and Remark 1), and $\mathcal{E}^T \subseteq \mathcal{V}^T \times \mathcal{V}^T$ is the set of directed edges, each representing a feasible attack step.

8.2.2 OTT-EA compound attack graph

For OTT-EA, the architectural segregation between $\mathcal{K}$ and $\mathcal{D}$ is represented through a compound graph structure with parallel key-side and data-side subgraphs joined at an operational-compromise AND-node:

Definition 10 (OTT-EA Compound attack graph). Let $\mathcal{G}^{\text{OTT}} = (\mathcal{V}^{\text{OTT}}, \mathcal{E}^{\text{OTT}})$ be a compound directed acyclic graph with node set

$$\mathcal{V}^{\text{OTT}} = \{v_0\} \cup \mathcal{V}^{\text{X}} \cup \mathcal{V}^{\text{K}} \cup \mathcal{V}^{\text{D}} \cup \{v_{\text{op}}\},$$

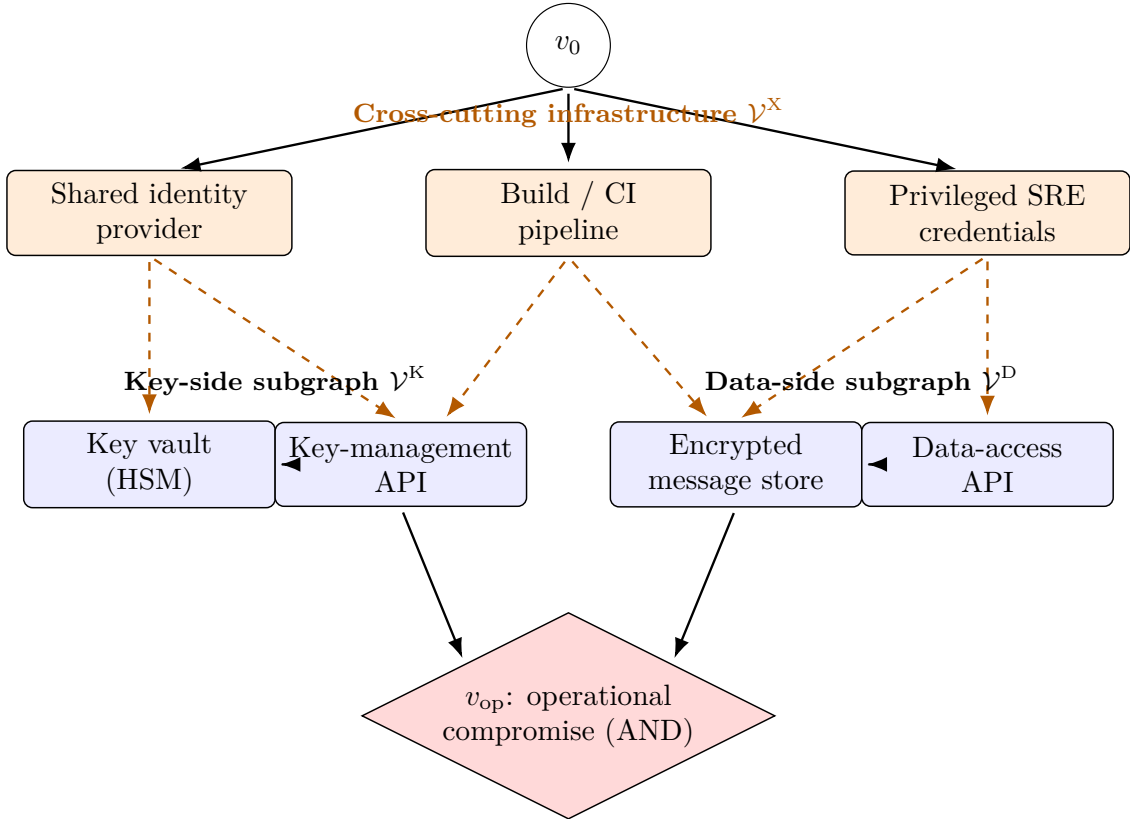
where v_0 is the adversary’s initial state; $\mathcal{V}^{\text{X}}$ is the set of *cross-cutting* nodes representing shared infrastructure (identity provider, build pipeline, privileged-role credentials, shared network perimeter); $\mathcal{V}^{\text{K}}$ is the set of *key-side* nodes representing the key-management subsystem; $\mathcal{V}^{\text{D}}$ is

the set of *data-side* nodes representing the encrypted-data subsystem; and v_{op} is the operational-compromise terminal state. Edge set

$$\mathcal{E}^{\text{OTT}} = \mathcal{E}_{0 \rightarrow X} \cup \mathcal{E}_{0 \rightarrow K} \cup \mathcal{E}_{0 \rightarrow D} \cup \mathcal{E}_{X \rightarrow K} \cup \mathcal{E}_{X \rightarrow D} \cup \mathcal{E}_{K \rightarrow \text{op}} \cup \mathcal{E}_{D \rightarrow \text{op}},$$

with v_{op} reached only through the joint condition: the adversary has reached at least one node in $\mathcal{V}^K$ and at least one node in $\mathcal{V}^D$.

The AND-condition at v_{op} is the formal representation of operational compromise (Definition 5): unauthorised key access is necessary but not sufficient. Data access is necessary but not sufficient. Both are required for decryption of target communications. The cross-cutting nodes $\mathcal{V}^X$ are the architectural feature that allows the AND-condition to be satisfied through a single infrastructure compromise rather than through two distinct attack campaigns: a node in $\mathcal{V}^X$ has outgoing edges to nodes in both $\mathcal{V}^K$ and $\mathcal{V}^D$, so that traversing through $\mathcal{V}^X$ provides simultaneous access to both subgraphs.



Solid arrow: subgraph-internal edge Dashed orange: cross-cutting edge ($Z(t)$ -coupled)

Figure 6: Compound attack-graph schematic for an OTT-EA (Class A) architecture. Cross-cutting infrastructure nodes (top, orange) have outgoing edges to both the key-side subgraph $\mathcal{G}_{\text{key}}^{\text{OTT}}$ and the data-side subgraph $\mathcal{G}_{\text{data}}^{\text{OTT}}$ (dashed orange edges). Reaching the operational-compromise AND-node requires either (i) traversing both subgraphs independently through their respective subgraph-internal edges, or (ii) traversing a cross-cutting node that provides simultaneous access to both. The latent campaign variable $Z(t)$ couples preferentially to cross-cutting edges (Section 8), so under correlated-campaign conditions the segregation gain that distinguishes OTT-EA from T-EA at the median is eroded.

Alt text: Compound attack-graph schematic for OTT-EA showing a key-side subgraph (left) and a data-side subgraph (right), with cross-cutting infrastructure nodes at top whose edges (dashed orange) reach both subgraphs. The operational-compromise AND-node requires either traversing both subgraphs independently or using the cross-cutting path.

8.2.3 Hazard rates and attack-path aggregation

For both architectures, each edge $(v_i, v_j) \in \mathcal{E}$ is assigned a hazard rate function $\lambda_{ij}(t) \geq 0$ under a piecewise-constant approximation within annual periods. The system-level hazard rate is derived by combining minimal attack-path sets $\{M_1, \dots, M_K\}$ (minimal sets of edges whose joint traversal achieves the compromise condition) via inclusion–exclusion. For computational tractability and dimensional consistency, we adopt a *weakest-link (bottleneck) approximation* for the per-path hazard,

$$\lambda_{M_k}(t) = \min_{(i,j) \in M_k} \lambda_{ij}(t), \quad (18)$$

which is exact in the limit where one edge in the path has a hazard rate substantially smaller than the others. In the present model, edge log-hazards differ by ~ 3 log-units across adversary tiers (Supplementary Table S5), so the approximation error from this step is small relative to other modelling uncertainties.

For T-EA, minimal $v_0 \rightarrow v_n$ attack paths are enumerated following standard reliability-graph path-set methodology. For OTT-EA, the AND-condition at v_{op} requires a generalised path-set construction: a minimal attack-path set must *either* (a) comprise at least one $v_0 \rightarrow V^K$ path and at least one $v_0 \rightarrow V^D$ path *jointly* (traversing the two subgraphs separately), *or* (b) traverse at least one cross-cutting node in $\mathcal{V}^X$, which provides simultaneous access to both subgraphs. The second class dominates when cross-cutting edges have high hazard rates: compromising a single cross-cutting node simultaneously elevates the traversal hazard on both subgraphs.

The system hazard for either architecture is then

$$\lambda_{\text{sys}}(t) = \sum_{k=1}^K \lambda_{M_k}(t) - \sum_{k < \ell} \lambda_{M_k \cup M_\ell}(t) + \dots, \quad (19)$$

where $\lambda_{M_k \cup M_\ell}(t) = \min_{(i,j) \in M_k \cup M_\ell} \lambda_{ij}(t)$ and any negative result from inclusion–exclusion truncation is clamped to zero (occasional sign reversals arise from the min-rate heuristic; the clamped fraction is below 1% in our runs). The exact reliability formulation in terms of path-traversal probabilities $\prod_{(i,j) \in M_k} (1 - \exp(-\lambda_{ij} \Delta t))$ would not reduce to a closed-form hazard rate. The topology-sensitivity analysis (Section 11) bounds the consequence of the weakest-link approximation at approximately $\pm 10\%$ on median estimates, and the qualitative dependence-uplift findings are reliable across these variations. Under the piecewise-constant hazard assumption, the probability of at least one compromise in $[0, t]$ follows a non-homogeneous Poisson process:

$$\Pr(T_{\text{comp}} \leq t) = 1 - \exp\left(-\int_0^t \lambda_{\text{sys}}(s) ds\right). \quad (20)$$

The graphs are stylised representations. Sensitivity analysis (Section 11) shows that plausible topological variations change median estimates by approximately 10%. The dependence-uplift findings are robust to these variations.

8.3 Bayesian Hierarchical Model

8.3.1 Priors for edge hazard rates

For each edge $(i, j) \in \mathcal{E}^A$ (architecture $A \in \{\text{T}, \text{OTT}\}$), we adopt a log-normal prior:

$$\log \lambda_{ij}^A \sim \mathcal{N}(\mu_{ij}^A, (\sigma_{ij}^A)^2), \quad (21)$$

chosen for support on $\mathbb{R}_{>0}$ and widespread use in reliability modelling. The architecture-conditional location parameters μ_{ij}^A are derived from architecture-matched domain transfer (§8.4): T-EA priors are calibrated against Streams A and B; OTT-EA priors against Streams B and C, weighted by architectural fit.

8.3.2 Hyperpriors

The hyperparameters μ_{ij}^A and σ_{ij}^A are themselves assigned priors:

$$\mu_{ij}^A \sim \mathcal{N}(\hat{\mu}_{ij}^{\text{transfer},A}, \tau_\mu^2), \quad (22)$$

$$\sigma_{ij}^A \sim \text{HalfNormal}(\tau_\sigma), \quad (23)$$

where $\hat{\mu}_{ij}^{\text{transfer},A}$ is the architecture-conditional log-scale point estimate from domain transfer, and $\tau_\mu, \tau_\sigma > 0$ govern additional variance from domain mismatch. Defaults $\tau_\mu = 1.0$, $\tau_\sigma = 0.5$ in the primary analysis; sensitivity to $\tau_\mu \in [0.5, 1.5]$ reported for both configurations.

8.3.3 EA-specific system modifiers

Three multiplicative modifiers are applied to all baseline hazard rates:

$$\tilde{\lambda}_{ij}^A = \delta_{\text{EA}}^A \cdot \delta_{\text{target}}^A \cdot \delta_{\text{concen}}^A \cdot \lambda_{ij}^A, \quad (24)$$

where $\delta_{\text{EA}}^A \geq 1$ represents increased attack surface from the EA mechanism; $\delta_{\text{target}}^A \geq 1$ captures elevated adversarial targeting; and $\delta_{\text{concen}}^A \geq 1$ reflects key-aggregation concentration risk. The architecture-conditional priors on these modifiers differ between T-EA and OTT-EA reflecting documented structural differences: δ_{target}^A is anchored on Salt Typhoon and the Athens affair for T-EA, Storm-0558 and Microsoft Midnight Blizzard for OTT-EA (with OTT-EA placing more mass at higher values reflecting larger user populations); δ_{concen}^A is per-carrier for T-EA (millions of users) versus per-platform for OTT-EA (hundreds of millions to billions), with the OTT-EA prior median shifted upward by approximately 0.8 natural-log units (a multiplicative factor of ≈ 2.2 ; Supplementary §S21). The constraint that all three modifiers are ≥ 1 for both architectures is structural (definitional), not an empirical calibration, and underwrites Proposition 1. Full modifier prior specifications and supporting calibration evidence are in Supplementary §S21.

8.4 Domain Transfer

In the absence of EA-specific incident data, baseline hazard rates are estimated by transferring information from architecturally analogous systems. The streams of Pillar I provide the appropriate analogue classes: T-EA transfer draws primarily on Stream A (government high-security systems) with Stream B (CA cohort) as secondary, reflecting fit to $\mathcal{K}/\mathcal{D}$ co-located operator-bounded infrastructure; OTT-EA transfer draws primarily on Stream C (platform-level key/data compromises) with Stream B as secondary, reflecting fit to segregated infrastructure with large user populations and multi-stage compromise patterns. The Stream C-to-OTT-EA transfer is the most analogically direct mapping in the framework, since Stream C incidents themselves come from the architectural class to which OTT-EA belongs.

The domain transfer applies a transport function:

$$\hat{\lambda}_{ij}^{\text{transfer},A} = \hat{\lambda}_{ij}' \cdot \exp\left(\sum_r \phi_{ij,r}^A \cdot \Delta_r^A\right), \quad (25)$$

where Δ_r^A are signed log-scale adjustment factors for structural dimension r (architecture-conditional), and $\phi_{ij,r}^A \sim \mathcal{N}(0, \tau_\phi^2)$ are random weighting coefficients propagating transport uncertainty. This formalises what Pillar I does informally through its analogical distance criteria and makes the uncertainty in that mapping explicit. The full set of structural adjustment dimensions $\{\Delta_r^A\}$, their per-dimension calibration against the Stream C incident base, and the dimension-by-dimension sensitivity analysis are in Supplementary §S5.

8.5 Dependence Modelling

A fundamental structural limitation of the complement-of-product aggregation used in Pillars I–III is the failure to capture correlated attack campaigns. An advanced adversary conducting a coordinated operation does not attack each component independently. Reconnaissance, tooling, and timing are shared across attack vectors. A single latent campaign variable $Z(t) \geq 0$ induces positive correlation across attack events.

8.5.1 T-EA dependence: uniform coupling

For T-EA, $Z(t)$ couples uniformly to all edges:

$$\lambda_{ij}^{\text{eff},T}(t | Z(t)) = \tilde{\lambda}_{ij} \cdot e^{\gamma Z(t)}, \quad (i, j) \in \mathcal{E}^T, \quad (26)$$

where $\gamma > 0$ is the campaign amplification factor governing the sensitivity of edge hazard rates to campaign intensity, and $Z(t)$ evolves as a non-negative process with prior $Z(t) \sim \text{Gamma}(\alpha_Z, \beta_Z)$. In high-campaign-intensity periods (large Z), all edge hazards are elevated simultaneously, producing the correlated tail risk that independence-based models cannot describe.

8.5.2 OTT-EA dependence: cross-cutting coupling

For OTT-EA, the architectural distinction between subgraph-internal edges and cross-cutting edges motivates a structured coupling specification. Edges into $\mathcal{V}^X$ and from $\mathcal{V}^X$ to either subgraph receive a higher amplification factor than subgraph-internal edges, reflecting the architectural feature that correlated campaigns preferentially exploit shared infrastructure:

$$\lambda_{ij}^{\text{eff},\text{OTT}}(t | Z(t)) = \begin{cases} \tilde{\lambda}_{ij} \cdot e^{\gamma_X Z(t)} & \text{if } (i, j) \text{ is a cross-cutting edge,} \\ \tilde{\lambda}_{ij} \cdot e^{\gamma Z(t)} & \text{otherwise,} \end{cases} \quad (27)$$

where $\gamma_X \geq \gamma > 0$. The constraint $\gamma_X \geq \gamma$ formalises the architectural argument that correlated campaigns preferentially exploit cross-cutting infrastructure: an APT seeking simultaneous access to key custody and data storage will preferentially compromise shared identity providers, build pipelines, or privileged-role credentials over mounting two distinct subsystem-specific campaigns.

The cross-cutting coupling ratio γ_X/γ is treated as a random variable with prior

$$\gamma_X/\gamma = 1 + \text{LogNormal}(\log(m - 1), \sigma^2), \quad (28)$$

where $m = 2$ is the prior median and $\sigma = 0.40$ is the log-space spread. The shift by 1 enforces the structural constraint $\gamma_X/\gamma \geq 1$ by construction. Because the log-normal component is strictly positive, the prior in fact places probability one on $\gamma_X/\gamma > 1$: the weak constraint guarantees that the OTT-EA cross-cutting amplification is never below T-EA’s uniform coupling, and the strict inequality, which holds almost surely under the prior, is what produces the tail divergence. The default $(m, \sigma) = (2, 0.40)$ gives a 90% credible range of approximately $[1.52, 2.93]$.

Calibration anchor. The prior median $m = 2$ is *derived* from, not merely consistent with, the Stream C cross-cutting fraction $\hat{p}_X = 7/14 = 0.50$ (seven of fourteen incidents exhibited documented cross-cutting attack paths, $X = Y$ in Supplementary Table S3): under the attack-graph specification, a cross-cutting incident share of one-half at central campaign intensity maps to an amplification ratio of approximately 2, with the derivation given in Supplementary §S22. The Salt Typhoon record, in which a single campaign traversed lawful-intercept and adjacent administrative infrastructure together, independently rules out values close to 1. The $\sigma = 0.40$ choice matches the prior width used in the variance-decomposition and tornado analyses (§9.9.1) to keep sensitivity treatments internally consistent. The architectural-divergence finding (OTT-EA upper-tail inflation exceeding T-EA’s) is robust across $\sigma = 0.25, 0.40, 0.50, 0.60$,

0.75 (Table 11). The specific magnitude is calibration-dependent and reported as the prior-integrated value at $\sigma = 0.40$ with explicit sensitivity. Full prior-calibration derivation and the empirical-anchor mapping from Stream C are in Supplementary §S22. Empirical considerations constraining σ more tightly are discussed in §11.5.

Treating γ_X/γ as sampled rather than fixed has two substantive consequences: the headline distributional results absorb the uncertainty in γ_X/γ directly (no separate sensitivity number needed to interpret a published quantile), and the prior-integrated upper tail is heavier than the tail at the prior median in isolation, because exponential amplification $e^{\gamma_X Z}$ is convex in γ_X and high realisations dominate the upper tail.

8.5.3 Architectural consequence: tail expansion under correlation

The substantive consequence of the cross-cutting coupling specification is that under high- $Z(t)$ realisations, which dominate the upper tail of the prior predictive distribution, the segregation gain that distinguishes OTT-EA from T-EA at the median is partially or fully eroded. Concretely, at $Z(t) = 0$ (no campaign activity), cross-cutting edges have the same nominal hazard as subgraph-internal edges, and the effective ξ_c values realised through the graph structure are at their architectural defaults. At large $Z(t)$, cross-cutting edges receive amplification $e^{\gamma_X Z(t)} \geq e^{\gamma Z(t)}$, raising the proportion of attack-graph traversals that pass through $\mathcal{V}^X$ and effectively inflating the realised cross-cutting fraction toward 1. The OTT-EA tail therefore behaves like the T-EA tail with the segregation gain progressively erased, while the T-EA tail behaves under uniform coupling. This is the structural mechanism by which the OTT-EA distribution exhibits a lower median but a heavier right tail than the T-EA distribution (Section 9).

8.6 Adversarial Targeting Layer

The probability that each adversary class directs resources toward the EA system in a given period is modelled through a utility-based framework. The expected utility of targeting an EA system for nation-state actors ($\mathcal{A}_{NS}$) is proportional to the intelligence value of the system’s content, its vulnerability to the actor’s tooling, and the probability of successful exfiltration without attribution. Operationally, this is captured by the system modifier δ_{target} , with the constraint $\delta_{\text{target}} \geq 1$ reflecting the structural observation that EA systems are, by design, higher-value targets than their non-EA analogues.

8.7 Simulation Procedure

The Monte Carlo simulation is run independently for the T-EA and OTT-EA configurations, sharing common hyperprior structure but differing in attack-graph topology and in the $Z(t)$ -coupling specification. For each architectural class $A \in \{\text{T}, \text{OTT}\}$, the simulation proceeds for each replicate $r = 1, \dots, R$ ($R = 8,000$ in the primary analysis):

1. **Sample parameters** $\theta^{A,(r)}$ from the architecture-conditional joint prior over all model parameters, including the architecture-conditional hazard hyperpriors (Section 8.3), the EA modifiers, and the architecture-conditional dependence parameters γ and (for OTT) γ_X .
2. **Compute effective hazards:** for each year k and edge $(i, j) \in \mathcal{E}^A$, compute $\lambda_{ij}^{\text{det}, A, (r)}(k)$ via Equations (24) and the architecture-appropriate coupling specification (Equation (26) for T-EA; Equation (27) for OTT-EA), conditioning on the sampled campaign state $Z^{A,(r)}(k)$ and applying the detection-adjusted formula $\lambda_{ij}^{\text{det}} = (1 - \rho_{ij}) \cdot \lambda_{ij}^{\text{eff}}$.
3. **Compute annual compromise probability:** For T-EA, $q_k^{\text{T}, (r)} = 1 - e^{-\lambda_{\text{sys}}^{\text{T}, (r)}(k)}$ via standard path-set aggregation. For OTT-EA, the AND-condition at v_{op} is enforced by computing the operational-compromise probability through the generalised path-set construction (Section 10):

$$q_k^{\text{OTT}, (r)} = q_k^{\text{xcut}, (r)} + \left(1 - q_k^{\text{xcut}, (r)}\right) \cdot q_k^{\text{K}, (r)} \cdot q_k^{\text{D}, (r)}, \quad (29)$$

where $q_k^{\text{xcut},(r)}$ is the probability that traversal reaches v_{op} via at least one cross-cutting node, $q_k^{\text{K},(r)}$ is the probability of subgraph-internal traversal of $\mathcal{V}^{\text{K}}$ in absence of cross-cutting, and similarly $q_k^{\text{D},(r)}$ for $\mathcal{V}^{\text{D}}$. This is the Bayesian-model analogue of the Pillar II/III formula $\xi + (1 - \xi)P_3P_4$ (Equation (7)), with the architectural feature that under correlated-campaign conditions $q_k^{\text{xcut},(r)}$ inflates faster than the subgraph-internal probabilities.

4. **Compute cumulative probability:** $Q_T^{\text{A},(r)} = 1 - \prod_{k=1}^T (1 - q_k^{\text{A},(r)})$.

The outputs $\{q_1^{\text{T},(r)}\}_{r=1}^R$, $\{q_1^{\text{OTT},(r)}\}_{r=1}^R$, and the corresponding cumulative distributions constitute prior predictive samples from which architecture-conditional summary statistics, credible intervals, and exceedance probabilities are computed (Section 9).

Monte Carlo numerical stability. All headline results derive from the $R = 8,000$ primary run (seed 2024). A four-stream diagnostic bounds the Monte Carlo error at ≤ 0.08 pp on the annual medians, with effective sample sizes above 7,700; the full diagnostic is in Supplementary §S23.

8.8 Structural Lower Bound and Stochastic Dominance

A result of the Bayesian model follows from the constraints on the system modifier parameters, once those constraints are empirically grounded.

Empirical basis for the modifier constraints

The model posits three EA-specific multipliers $\delta_{\text{EA}}^{\text{A}}, \delta_{\text{target}}^{\text{A}}, \delta_{\text{concen}}^{\text{A}} \geq 1$ for each architectural class $\text{A} \in \{\text{T}, \text{OTT}\}$. For these constraints to carry policy weight they must reflect structural properties of EA systems rather than modelling definitions. Two independent lines of evidence support each, with class-specific anchoring where the architectural distinction is material:

$\delta_{\text{EA}}^{\text{A}} \geq 1$ (*attack surface increase*). Any operationally viable EA architecture introduces additional codebase, interfaces, and key-management components, and the documented relationship between software complexity and latent vulnerability density [55, 56] makes the added surface weakly risk-increasing. The relationship is unvalidated for minimal-firmware hardware security modules, so its strength varies by implementation, but equality with the non-EA baseline would require an EA subsystem of literally zero added complexity.

$\delta_{\text{target}}^{\text{A}} \geq 1$ (*elevated adversarial targeting*). Salt Typhoon (2024) and the Athens affair (2004–05) demonstrate that T-EA lawful-intercept infrastructure attracts adversarial attention absent from the non-EA counterfactual; Storm-0558 (2023) and Midnight Blizzard (2024) demonstrate the equivalent for platform-level signing-key and identity infrastructure. $\delta_{\text{target}}^{\text{A}} = 1$ would assert that EA systems attract no incremental targeting, which the incident record contradicts for both classes.

$\delta_{\text{concen}}^{\text{A}} \geq 1$ (*key concentration premium*). An EA system aggregates an entire user population’s key material in one component, whose compromise value strictly exceeds that of any single device; under any rational targeting model, greater expected payoff implies at least equal targeting intensity. $\delta_{\text{concen}}^{\text{OTT}}$ exceeds $\delta_{\text{concen}}^{\text{T}}$ by roughly the log-ratio of populations served, but both are bounded below by unity.

Proposition

The proposition below should be read with its logical type in view. Its mathematical content is deliberately slight: once the three modifier bounds above are granted, first-order dominance follows in two lines of monotonicity. Its scientific content lies entirely in the empirical case for those bounds—that any operationally viable EA mechanism adds attack surface, attracts incremental targeting, and concentrates key-material value—which the preceding paragraphs

argue from the incident record rather than assume. A reader who rejects the conclusion must therefore identify which of the three modifiers can credibly fall below unity, and for which architectural class; the proposition’s role is to make that the only available line of attack.

Proposition 1 (First-Order Stochastic Dominance, Both Architectural Classes). *Under the assumptions that (i) the attack graph of an EA system is a superset of the no-EA graph (adding EA-specific nodes and edges; see Section 5.1 for Salt Typhoon as a Tier 1 Stream A incident, Section 7 for the Athens affair as a historical channel-rate analogue, and Section 5.3 for Storm-0558 and Midnight Blizzard for OTT-EA) and (ii) the EA-specific modifiers $\delta_{\text{EA}}^A, \delta_{\text{target}}^A, \delta_{\text{concen}}^A \geq 1$, the model’s annual compromise probability is larger for the EA configuration than for an otherwise-identical configuration without EA. Formally, within the model of Section 8, for each architectural class $A \in \{\text{T}, \text{OTT}\}$, let F_{EA}^A denote the CDF of the compromise probability under the EA configuration of class A, and let F_{noEA}^A denote the CDF under the same architecture with all three modifiers fixed at unity (the counterfactual non-EA parameterisation of class A). Then*

$$F_{\text{EA}}^A(x) \leq F_{\text{noEA}}^A(x) \quad \forall x \in [0, 1], \quad A \in \{\text{T}, \text{OTT}\}.$$

That is, in each architectural class, the EA-configured model stochastically dominates (is riskier than) the same architecture with $\delta^A = 1$. The ordering is structural in the modelling sense and does not depend on prior calibration.

Proof sketch. A monotonicity argument: the modifier product ≥ 1 raises every edge hazard, the per-period compromise probability is increasing in total hazard, and both architectural aggregation maps are monotone in their components, so the inequality holds at every parameter realisation and therefore distributionally. The full proof is in Supplementary §S20. $\square$

Status and scope of the assumptions. Both assumptions are empirically supported, neither is logically necessary, and the conclusion is a structural claim about the model conditional on them, not an empirical finding about the EA-versus-no-EA difference in the wild; what would defeat the assumptions is set out in §10.1. The no-EA counterfactual is a model-internal construction (the same graph with the modifiers at unity), not a claim about specific deployed carriers, which may host lawful-intercept infrastructure for other regulatory reasons: for those, the relevant counterfactual is “no additional EA mandate”, and the proposition speaks to that reading. The relationship of this model-internal counterfactual to the empirical baseline carried by the Pillar I analogue rates is stated in §12 (one decomposition, three expressions).

Remark 2 (Cross-architecture ordering is not stochastic dominance). *Proposition 1 establishes EA-versus-no-EA stochastic dominance within each architectural class. It does not establish a stochastic dominance ordering between the T-EA and OTT-EA EA-configured distributions. As Section 9 shows, the relationship between F_{EA}^{T} and $F_{\text{EA}}^{\text{OTT}}$ is not first-order: under the central calibration the T-EA distribution lies above the OTT-EA distribution at the median (T-EA is riskier on average), but the OTT-EA distribution can exceed the T-EA distribution in the upper tail under correlated-campaign conditions (because of the cross-cutting coupling specified in Section 8.5). This is a structural feature of architectural segregation, not a defect of the model. The policy implication is that T-EA-versus-OTT-EA comparison must engage with the full distribution rather than reducing to median or any single quantile.*

Caveat on scope. The proposition compares two parameterisations of the *same* graph in each class; it does not formally compare an EA system against a real non-EA system, whose topology would differ (no key-escrow node, no orchestration layer). The policy inference that EA adds risk rests on the separate empirical claim that no operationally viable deployment achieves $\delta^A = 1$ on all three dimensions. The consequence is that the debate is not about *whether* an EA mandate adds risk within its class but about how much, in what form (median versus tail), and whether the increment is justified by benefits outside this paper’s scope.

9 Results

This section reports the quantitative outputs of the framework: annual and multi-decade compromise probabilities, distributional shape (mean, percentiles, tail behaviour), the effect of dependence on the headline values (with comparison to Fréchet–Hoeffding bounds), the relative importance of different parameters (variance decomposition), and the prior-sensitivity of headline numbers. The principal findings: T-EA annual compromise probability has a Bayesian median of 4.0% (90% credible interval [1.4%, 16.5%]); OTT-EA has a lower median (2.6%) but a heavier upper tail (95% upper at 17.4%). Over a 10-year deployment horizon, cumulative compromise reaches 37% for T-EA and 32% for OTT-EA at the median. Under conservative priors, these become approximately 19% and 13%, respectively, still well above zero. The dependence layer (Z, γ, γ_X) inflates the upper tail more for OTT-EA than for T-EA, with a tail-shape divergence guaranteed by the cross-cutting coupling constraint. The reader may take these headline values and skip the technical sensitivity analyses without losing the principal contribution.

Note: All numerical results from Layer IV are outputs of the model under the parameter priors described in Section 8. They are explicitly conditional on all stated modelling assumptions and should not be interpreted as empirical measurements of historical or projected compromise rates.

9.1 Three-Pillar Framework: Consolidated Outputs

Table 9 reproduces the principal reference estimates produced by the framework, with their critical assumptions and epistemic status, stratified by architectural class. The table is deliberately compact: the assumption-conditional estimates within each architectural class cluster narrowly only because they share the independence assumption, and the T-EA and OTT-EA clusters differ by approximately the central segregation factor. A longer enumeration of every variant floor estimator would obscure rather than support these two findings.

Two architectural patterns are visible in the table. First, within each architectural class the independence-conditional reference points cluster in a narrow range: T-EA in the upper-single-digit range; OTT-EA in the low-single-digit range. The dominant driver of within-class clustering is the shared independence assumption. The limited genuinely independent evidence is discussed in Section 10. Second, the OTT-EA cluster sits at approximately half the T-EA cluster across all three pillar methodologies, confirming that the architectural correction mechanism is applied consistently across pillars and that the segregation gain is the quantitatively dominant architectural effect at the central tendency.

The Bayesian 90% credible intervals tell a different story. The OTT-EA upper bound modestly exceeds the T-EA upper bound: under correlated-campaign conditions OTT-EA upper-tail behaviour overtakes T-EA as the segregation gain is eroded and the cross-cutting amplification engages. The OTT-EA lower bound is also below T-EA’s, reflecting the segregation gain at the lower tail where campaign activity is low. The upper-to-lower interval ratio is therefore wider for OTT-EA, formalising the tail-heavier character of the OTT-EA distribution.

9.2 Which Quantity Answers Which Question

The framework reports three families of numbers, and they are different quantities rather than competing estimates of one quantity. The Fréchet–Hoeffding intervals bound the Pillar II seven-scenario aggregation: they hold under every dependence structure among the scenarios, conditional on the per-scenario probabilities, and they include neither the EA modifiers nor the campaign amplification of Layer IV. One asymmetry is worth making explicit: a scenario omitted from the decomposition can only raise the union probability, so the Fréchet–Hoeffding *lower* bound is robust to scenario incompleteness while the *upper* bound is conditional on the seven scenarios covering the dominant attack surface. The Bayesian percentiles describe the full prior-

Table 9: Principal reference estimates by architectural class: values, critical assumptions, and epistemic status. The T-EA estimates apply to transmission-layer EA architectures with $\mathcal{K}/\mathcal{D}$ co-location. The OTT-EA estimates apply to application-layer architectures with central-calibration segregation factor $P_3 \cdot P_4 = 0.30$ and the per-channel cross-cutting fractions of Table 8.

Reference point	T-EA	OTT-EA	Critical assumptions	Epistemic status
Channel-minimum heuristic (Pillar III)	1.5%	1.0%	Four channels are dominant AND exhaustive; empirical minima are architecture-appropriate	Conditional heuristic; not a structural bound
Fréchet–Hoeffding lower (Pillar II)	2.2%	1.1%	Seven scenarios cover the dominant attack surface	Model-consistent lower bound
Bayesian median (Layer IV)	4.0%	2.6%	Architecture-conditional priors calibrated to architecture-matched Pillar I empirical range	Prior-conditional; not independent corroboration
Channel-aggregate projection (Pillar III)	5.4%	3.0%	Independence; architecture-conditional channel weighting	Independence-conditional
Pillar II central (independence)	7.3%	3.9%	Independence; scenario completeness	Independence-conditional
Fréchet–Hoeffding upper (Pillar II)	7.5%	4.0%	Same as lower bound	Model-consistent upper bound
Bayesian 90% interval (Layer IV)	[1.4%, 16.5%]	[0.8%, 17.4%]	Same as Bayesian median	Distributional uncertainty

predictive distribution with those mechanisms switched on. The FH interval therefore does not bound the Bayesian outputs, and the Layer IV 95th percentiles (approximately 16–17% annually for both architectures) sitting above the FH uppers (7.5% and 4.0%) is not an inconsistency: the bracket and the tail answer different questions. The usage rule is as follows. For comparative architecture questions, and for a dependence-robust envelope of the scenario model, use the FH intervals together with the structural orderings. For tail and stress questions, where correlated campaigns and EA-specific targeting matter, use the Layer IV upper percentiles. For a single calibration-conditional central reference, use the Layer IV medians, with the channel-minimum heuristics as independence-conditional floors. Table 9 states the assumptions each family carries; Table 17 presents the families side by side under this convention.

9.3 Bayesian Layer: Distributional Results

Prior predictive distributions over the annual compromise probability q_1 are produced separately for the two architectural classes under the primary parameterisation ($R = 8,000$ replicates, seed 2024). The full quantile sets are reproducible via the bundled scripts. The narration below emphasises qualitative shape rather than specific quantiles.

T-EA distribution. The central tendency sits in the low-single-digit percentage range (median in the neighbourhood of 4%), consistent with the three-pillar T-EA empirical range (3–6%) to which the priors were calibrated. The 90% credible interval spans approximately an order of magnitude, with the lower bound near 1% and the upper bound in the mid-teens. The upper tail extends further: at the 95th percentile the distribution sits in the mid-to-upper teens, with non-negligible probability mass reflecting scenarios combining elevated campaign intensity, high targeting probability, and poor detection performance.

OTT-EA distribution. The central tendency is lower than T-EA’s, with a median in the low-single-digit range (roughly two-thirds of the T-EA median, consistent with the segregation gain). The 90% credible interval is slightly wider than T-EA’s, with both a lower lower bound (under 1%) and a higher upper bound (upper teens). The upper tail is the distinctive feature: at the 95th percentile OTT-EA modestly exceeds T-EA despite its lower median, the structural signature of cross-cutting coupling (§8.5). Further into the tail the gap widens substantially, with the OTT-EA 99th percentile in the upper-half percentage range and T-EA’s in the mid-thirties.

Architectural comparison. The two paragraphs above reduce to three contrasts: a median ratio of roughly two-thirds, consistent with the Pillar II and Pillar III architectural ratios; a tail crossover near the 95th percentile, below which T-EA is stochastically riskier and above which OTT-EA is; and a markedly larger OTT-EA tail-to-median ratio, the signature of segregation interacting with correlated campaigns under prior integration over γ_X/γ (Equation 28). The interval widths themselves are the primary result: the model cannot rule out annual risk near 1% or in the mid-teens for either class.

9.4 Effect of Dependence

The latent campaign variable $Z(t)$ has a substantial impact on both the central tendency and the tail of the compromise distribution, with qualitatively divergent effects across architectural classes.

T-EA and OTT-EA dependence effects. For T-EA, moving from the independence baseline ($Z \approx 0$) to the full dependence model raises the year-1 median modestly (by ≈ 1 percentage point, a $\approx 30\%$ relative increase) and the upper percentile more substantially: the annual 95th-percentile uplift is approximately $1.5\times$. For OTT-EA the analogous comparison gives a comparable absolute median uplift (≈ 0.9 pp, a larger relative increase from the lower base) but a substantially larger upper-percentile uplift, around $3\times$ (prior-integrated over γ_X/γ). The reported $\times 1.53$ (T-EA) and $\times 2.83$ (OTT-EA) values in Table 10 are reproducibility-grade ratios from the headline replicates. In policy discussion they should be read as “around $1.5\times$ ” and “around $3\times$ ” respectively. Cumulative 10-year upper-percentile uplifts are smaller in absolute multiplier (roughly $1.2\times$ T-EA, $2\times$ OTT-EA), since the cumulative distribution is bounded by unity and compresses the upper tail.

The architectural divergence is concentrated in the tail, not the median: median uplifts are comparable across architectures, but the annual upper-percentile uplifts differ by roughly a factor of two, through the segregation-erosion mechanism specified in §8.5 and the prior-integration convexity quantified in the conditional sensitivity below.

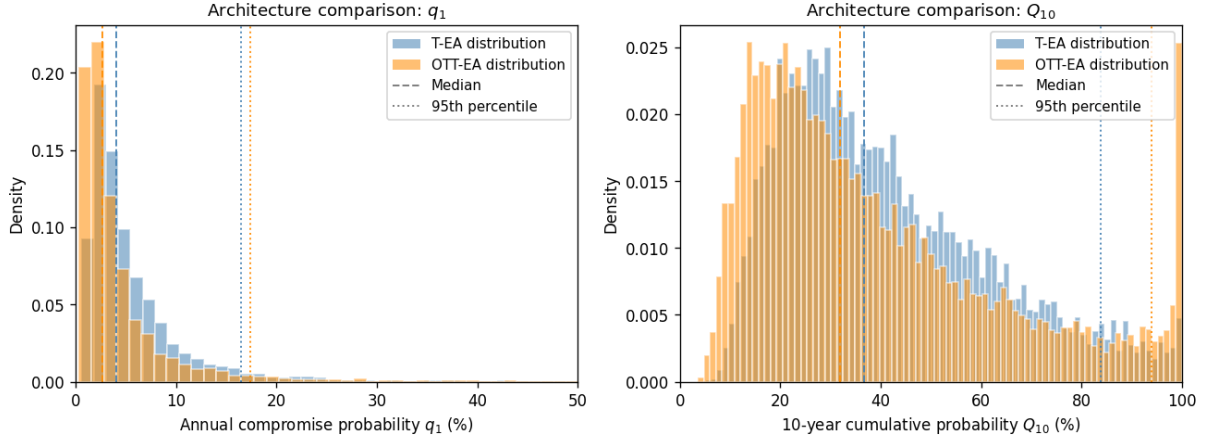


Figure 7: Architecture-conditional comparison of prior predictive distributions for the year-1 annual probability q_1 (left) and 10-year cumulative Q_{10} (right) under the full dependence model. T-EA distribution (blue) and OTT-EA distribution (orange) overlaid. The OTT-EA distribution sits below the T-EA distribution at the median but the upper tails cross over at approximately the 95th percentile, with OTT-EA exhibiting heavier extreme-tail mass under correlated-campaign conditions. Vertical markers indicate the median, 5th, and 95th percentiles for each distribution. Results from $R = 8,000$ Monte Carlo replicates per architecture (seed 2024); conditional on all modelling assumptions in Section 8.

Alt text: Two side-by-side density plots comparing prior predictive distributions of T-EA (blue) and OTT-EA (orange). Left: year-1 compromise probability q_1 ; OTT-EA sits below T-EA at the median but crosses over near the 95th percentile. Right: 10-year cumulative Q_{10} with the same architectural divergence pattern.

Table 10: Comparison of independence baseline and full dependence model outputs by architectural class. The annual 95th-percentile uplift for OTT-EA exceeds the T-EA uplift by a factor of approximately $\times 1.85$, the structural consequence of cross-cutting coupling integrated over the prior on γ_X/γ . The architectural tail crossover (OTT-EA upper-percentile values exceeding T-EA’s despite the lower median) is visible at both the 95th and 99th percentiles under full dependence.

Quantity	T-EA		OTT-EA	
	Indep.	Full dep.	Indep.	Full dep.
Year-1 median q_1	3.05%	4.0%	1.69%	2.63%
Year-1 95th percentile q_1	10.8%	16.5%	6.2%	17.4%
Year-1 99th percentile q_1	19.4%	35.2%	11.4%	58.9%
10-year cumulative median Q_{10}	26.6%	36.6%	15.7%	31.9%
10-year cumulative 95th Q_{10}	68.1%	83.8%	47.0%	93.9%
<i>Architectural tail crossover (full dependence)</i>				
q_1 95th percentile: T-EA vs OTT-EA	16.5%		17.4% (OTT-EA higher)	
q_1 99th percentile: T-EA vs OTT-EA	35.2%		58.9% (OTT-EA higher)	
Annual 95th-pct uplift factor	$\times 1.53$		$\times 2.83$	

9.4.1 Conditional sensitivity to γ_X/γ

The OTT-EA 95th-percentile uplift at four pinned values of γ_X/γ is: $\times 1.52$ at $\gamma_X/\gamma = 1$ (no cross-cutting amplification, equivalent to T-EA uniform coupling, matching T-EA’s $\times 1.53$ to within rounding); $\times 1.93$ at 1.5; $\times 2.54$ at 2 (the prior median); $\times 5.12$ at 3 (above the prior 95th percentile). The prior-integrated uplift of $\times 2.83$ exceeds the value at the prior median ($\times 2.54$) because $e^{\gamma_X Z}$ is convex in γ_X : replicates in the right tail of the prior shift the prior-integrated quantile above its fixed-median equivalent. The qualitative finding (cross-cutting coupling inflates the OTT-EA tail relative to T-EA) holds across the entire defensible γ_X/γ range and is structurally guaranteed by the coupling prior, which places probability one on $\gamma_X/\gamma > 1$ (the weak constraint ≥ 1 alone guarantees non-reversal of the uplift ordering).

The parallel sensitivity to the prior width σ is reported in Table 11: the OTT-EA p95 uplift varies from $\times 2.67$ at $\sigma = 0.25$ (tight prior) to $\times 3.42$ at $\sigma = 0.75$ (wide prior). The architectural divergence claim survives the entire range.

Table 11: OTT-EA 95th-percentile uplift factor under different prior widths σ on γ_X/γ . The prior median is fixed at 2 throughout; only the spread varies. The headline ($\sigma = 0.40$) row is in bold. The architectural divergence (OTT-EA uplift exceeding T-EA’s $\times 1.53$) survives across the full sigma range.

σ	γ_X/γ 95th pct	OTT-EA q_1 p99	OTT-EA q_1 uplift
0.25 (tight)	2.50	51.8%	$\times 2.67$
0.40 (headline)	2.92	58.9%	$\times 2.83$
0.50	3.26	65.4%	$\times 3.04$
0.60	3.66	77.1%	$\times 3.11$
0.75 (wide)	4.39	93.4%	$\times 3.42$

Stream C cohort-stratification sensitivity. The Stream C cohort (Section 5.3, Supplementary Table S3) has fourteen incidents with seven $X = Y$ classifications, giving an aggregate cross-cutting fraction of $7/14 = 0.50$. An alternative inclusion convention that added the Cloudflare 2023 near-miss to the cohort (without counting it as $X = Y$) and treated Snowflake 2024 and AT&T 2024 as architecturally independent events would yield the slightly lower fraction $7/16 = 0.44$. Treating the difference between these conventions purely as a calibration update, shifting the prior median from $\gamma_X/\gamma = 2$ to $2 \times (0.50/0.44) = 2.27$, raises the prior-integrated OTT-EA 95th-percentile uplift from $\times 2.83$ to approximately $\times 3.54$ and the 99th percentile from 58.9% to roughly 79%. We do not adopt this shifted median as the headline because the difference between the two conventions is denominator-driven (the primary convention places Cloudflare 2023 in the near-miss appendix and merges the Snowflake 2024 and AT&T 2024 incidents) rather than driven by new high-cross-cutting incidents: the aggregate-fraction shift reflects a different bookkeeping choice about the Cloudflare and Snowflake/AT&T entries rather than new evidence of higher cross-cutting risk. The prior median $\gamma_X/\gamma = 2$ with width $\sigma = 0.40$ remains the central specification. The alternative median is reported as a sensitivity to make explicit that the alternative convention is consistent with a strengthened tail-risk reading, not just with the unchanged headline.

9.4.2 Robustness

The qualitative dependence finding, both that dependence inflates the tail relative to the independence baseline within each architectural class, and that OTT-EA tail inflation exceeds T-EA tail inflation, is robust to wide variation in the campaign parameters α_Z , β_Z , and γ (and, for OTT-EA, γ_X): in all parameter regions consistent with the prior, the dependence model produces materially elevated risk relative to the independence baseline, and the cross-cutting coupling produces materially larger inflation for OTT-EA than for T-EA. The findings

support the qualitative conclusion that independence assumptions in the three-pillar framework *systematically understate tail risk in both architectural classes*, with the understatement being quantitatively larger for OTT-EA. Models treating EA component attack events as mutually independent will systematically underestimate the probability of severe outcomes, particularly for architecturally segregated systems where the correlated-campaign collapse of the segregation gain is the dominant tail-risk mechanism.

9.5 Tail Risk Characterisation

The upper tail of the year-1 annual compromise probability q_1 is characterised by fitting a generalised Pareto distribution (GPD) separately for each architectural class. The fit is a compact parametric summary of the simulated prior predictive tail—an economical way to report its decay class and to compare the two architectures on a single shape parameter—not an empirical extreme-value finding about observed incidents. The empirical 90th percentile threshold and the fitted GPD parameters are reported in Table 12.

Table 12: GPD fits to the upper tail of q_1 for each architectural class under the primary prior calibration. Threshold u is the empirical 90th percentile of the marginal q_1 distribution ($n_{\text{exc}} = 800$ exceedances per architecture). Shape and scale parameter MLEs are reported with 95% bootstrap confidence intervals ($B = 2,000$ resamples). Both shape parameters are strictly positive, placing both distributions in the Fréchet domain of extreme value theory (power-law tail decay). The bootstrap intervals for $\hat{\xi}$ do not overlap ($\hat{\xi}^{\text{OTT}} \in [0.42, 0.61]$ exceeds $\hat{\xi}^{\text{T}} \in [0.19, 0.36]$), so the architectural distinction in tail shape is statistically distinguishable rather than a noise realisation.

Architecture	Threshold u	$\hat{\xi}$ (shape)	95% CI	$\hat{\sigma}_u$ (scale)	95% CI
T-EA	0.118	0.271	[0.189, 0.356]	0.066	[0.059, 0.074]
OTT-EA	0.104	0.518	[0.424, 0.607]	0.089	[0.077, 0.103]

Goodness-of-fit caveat. Formal goodness-of-fit tests (Anderson–Darling and Kolmogorov–Smirnov, parametric bootstrap, Supplementary §S24) support the T-EA GPD fit at the primary threshold ($p_{\text{AD}} = 0.28$; $p_{\text{KS}} = 0.13$). The OTT-EA fit is rejected by both tests ($p_{\text{AD}} < 0.001$; $p_{\text{KS}} = 0.003$). The proximate cause is the latent-campaign coupling: when $Z(t)$ is suppressed (independence configuration), the OTT-EA upper tail fits a GPD adequately ($p_{\text{AD}} = 0.13$); when $Z(t)$ is active, the GPD is rejected, because $Z(t)$ preferentially activates cross-cutting edges via $\gamma_X/\gamma \geq 1$ and induces a mixture between a subgraph-dominant low- Z regime and a cross-cutting-dominant high- Z regime. A two-component GPD mixture fits the OTT-EA upper tail substantially better than a single GPD (Kolmogorov–Smirnov $D = 0.026$ vs 0.037), with $\sim 80\%$ of upper-tail mass on a moderate-shape component and $\sim 20\%$ on a heavier bounded-support component. The qualitative tail-divergence finding survives: direct percentile comparisons (T-EA 99th percentile $\sim 24\%$; OTT-EA 99th percentile $\sim 36\%$) are distribution-free and confirm a heavier OTT-EA upper tail. $\hat{\xi}^{\text{OTT}} > \hat{\xi}^{\text{T}}$ should therefore be interpreted as a tail-heaviness ordering rather than as formal statistical inference about Pareto tail indices, since the GPD model is misspecified for OTT-EA. The mixture structure is the empirical signature of the model’s structural mechanism rather than a defect of the model.

Both shape parameters are positive under the primary calibration, placing both classes in the *Fréchet domain* of extreme value theory. The characterisation is prior-conditional, and Table 13 reports its full behaviour across the calibration set: the heavy-tail ordering holds with non-overlapping intervals at the primary and conservative calibrations, and under the pessimistic prior the fitted shapes turn negative for both classes as saturation against the $q = 1$ ceiling dominates, the regime analysed below.

The shape-parameter gap (Table 12) is somewhat larger than under a fixed-point evaluation at $\gamma_X/\gamma = 2$, where the OTT-EA $\hat{\xi}$ comes out closer to 0.47: the difference is the convex-in- γ_X

Table 13: GPD shape parameter $\hat{\xi}$ across prior calibrations, with 95% bootstrap confidence intervals ($B = 2,000$ resamples). The architectural heavy-tail ordering ($\hat{\xi}_{\text{OTT}} > \hat{\xi}_{\text{T}}$) holds with non-overlapping CIs across the primary and conservative calibrations. Under the pessimistic calibration both architectures sit in the saturation regime (distribution truncated against $q \leq 1$), so the GPD shape captures saturation geometry rather than tail-decay heaviness.

Calibration	$\hat{\xi}^{\text{T}}$	95% CI	$\hat{\xi}^{\text{OTT}}$	95% CI
Pessimistic (median $\sim 13\%$ / $\sim 10\%$)	-0.11	$[-0.18, -0.03]$	-1.61	$[-2.65, -1.00]$
Primary (median $\sim 4\%$ / $\sim 2.6\%$)	0.27	$[0.19, 0.36]$	0.52	$[0.42, 0.61]$
Conservative (median $\sim 1.2\%$ / $\sim 0.9\%$)	0.39	$[0.30, 0.49]$	0.82	$[0.72, 0.93]$

amplification of right-tail prior mass quantified in §9.4.

The non-monotonic relation between prior pessimism and tail shape merits brief explanation, since intuition suggests that a more pessimistic prior should produce a heavier tail. Two opposing effects operate. First, raising the prior median for the underlying integrated hazard λ_{sys} generates more extreme realisations and would, on its own, increase tail mass. Second, the outcome variable is not λ but $q = 1 - \exp(-\lambda)$, which is bounded above by unity. For large λ the mapping saturates near $q = 1$ and the upper tail is mechanically truncated. Under the pessimistic calibration, the bulk of the q_1 distribution sits near 0.13 but its upper tail compresses against the $q = 1$ ceiling, producing a left-skewed near-saturation distribution with a finite right endpoint, which EVT classifies as light-tailed (reversed-Weibull / bounded-support max-domain of attraction). The heavy-tail finding therefore applies in the regime where saturation does not dominate, which is the policy-relevant regime for any prior consistent with the analogue evidence used in Pillar I.

Within its domain of validity, the result indicates that the tail decays as a power law rather than exponentially, and that the expected value of q_1 conditional on exceedance of the threshold is substantially higher than u itself. Concretely:

- For T-EA: $\Pr(q_1 > 0.50 \mid q_1 > u) \approx 0.03$, giving unconditional $\Pr(q_1 > 0.50) \approx 0.003$.
- For OTT-EA: $\Pr(q_1 > 0.50 \mid q_1 > u) \approx 0.13$, giving unconditional $\Pr(q_1 > 0.50) \approx 0.013$.

Both architectures exhibit non-trivial tail mass from a governance perspective. OTT-EA’s higher conditional exceedance probability above 50% is the architectural signature of cross-cutting tail amplification.

The physical driver of the positive $\hat{\xi}$ is the campaign amplification factor γ (and, for OTT-EA, the cross-cutting amplification γ_{X}) interacting with the latent campaign intensity Z : in the subset of replicates where both amplification factors and Z are large, the effective system hazard is elevated across all attack paths simultaneously. This is precisely the correlated campaign structure modelled in the dependence layer. The positive $\hat{\xi}$ confirms that this structure generates qualitatively different and more adverse tail behaviour than independence assumptions, which produce sub-exponential tails. The architectural amplification of $\hat{\xi}$ for OTT-EA confirms that the cross-cutting coupling specification is operative, not a formal artefact.

9.6 Cumulative Risk

The cumulative probability of at least one compromise grows substantially with the deployment horizon, with magnitude differing between architectural classes. Under T-EA primary-calibration parameter values the 10-year cumulative compromise probability sits in the mid-thirties percentage range, with a 90% credible interval spanning roughly $[7\%, 84\%]$. Under OTT-EA primary-calibration parameter values the 10-year cumulative is broadly comparable in central tendency but with substantially wider credible bounds: the upper bound exceeds T-EA’s, reflecting the tail-heavy character of the OTT-EA distribution under correlated campaigns and the prior-integrated amplification of γ_{X}/γ . Over a 25-year horizon the median cumulative for both architectures rises into the high-fifties to mid-sixties range. Table 14 presents cumulative-risk projections across all methodological reference points and both architectural classes. The interval-width contrast

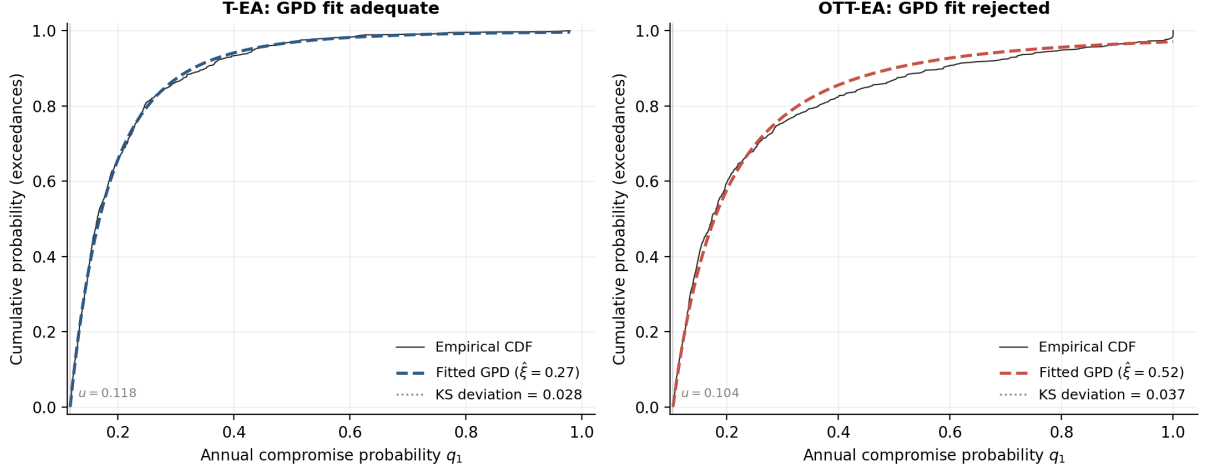


Figure 8: Generalised Pareto Distribution goodness-of-fit comparison across architectures. **Left:** T-EA, where the empirical CDF of exceedances above the 90th percentile (threshold $u = 0.118$) closely tracks the fitted GPD curve ($\hat{\xi} = 0.27$, $\hat{\sigma} = 0.066$); Anderson–Darling $p_{AD} = 0.28$ and Kolmogorov–Smirnov $p_{KS} = 0.13$ both fail to reject the GPD null. **Right:** OTT-EA, where the empirical CDF systematically deviates from the fitted GPD ($\hat{\xi} = 0.52$, $\hat{\sigma} = 0.089$, threshold $u = 0.104$). The empirical distribution carries more mass in the moderate-to-upper tail than the fitted single GPD predicts. Both tests reject the GPD null ($p_{AD} < 0.001$, $p_{KS} = 0.003$). The visible asymmetry is the empirical signature of the mixture structure induced by the cross-cutting coupling $\gamma_X/\gamma \geq 1$: under high realisations of the latent campaign variable $Z(t)$, cross-cutting edges activate preferentially, producing a high- Z tail regime that no single GPD can capture. Full goodness-of-fit tables, threshold sensitivity, and the two-component mixture diagnostic are in Supplementary §S24. Results from $R = 8,000$ Monte Carlo replicates per architecture (seed 2024).

Alt text: Two-panel goodness-of-fit comparison of GPD fits to the upper tail of the annual compromise probability. Left panel (T-EA): empirical CDF (black solid line) closely follows the fitted GPD curve (blue dashed line) with maximum Kolmogorov–Smirnov deviation 0.028; the fit is statistically adequate. Right panel (OTT-EA): empirical CDF (black solid line) systematically deviates from the fitted GPD curve (red dashed line) in the moderate-to-upper tail; maximum deviation 0.037. The fit is rejected by both Anderson–Darling and Kolmogorov–Smirnov tests at $p < 0.005$. The visible asymmetry is the empirical signature of the cross-cutting-coupling mixture structure in the OTT-EA model.

between architectures (OTT-EA intervals materially wider than T-EA’s at long horizons) is the qualitatively important feature, not the specific medians.

The qualitative pattern, that cumulative risk grows non-linearly with the deployment horizon and that the uncertainty range itself expands substantially over time, is robust to parameter variations and is offered as a more confident finding than any specific quantile. Within each architectural class, the cumulative risk over a 10-year horizon exceeds 30–50% at the channel-aggregate projection and remains material even at the channel-minimum heuristic.

9.7 Exceedance Probabilities Over Policy Thresholds

Wide credible intervals do not imply ignorance: the prior predictive distribution can assign high probability to the event that the true risk exceeds a policy-relevant threshold even when the credible interval itself spans several orders of magnitude. Table 15 reports $\Pr(q_1 > \tau)$ and $\Pr(Q_{10} > \tau)$ under both the full dependence model and the independence baseline, separately for each architectural class.

The acceptability threshold τ is a normative, jurisdictional determination outside a technical framework’s scope; no settled benchmark exists for EA systems, and thresholds from other safety-critical domains do not transfer defensibly. The table therefore spans two orders of magnitude (0.5% to 50% annually) so the output combines with whatever criterion the reader brings. The 1% row receives most discussion not as an externally derived bound but because it is

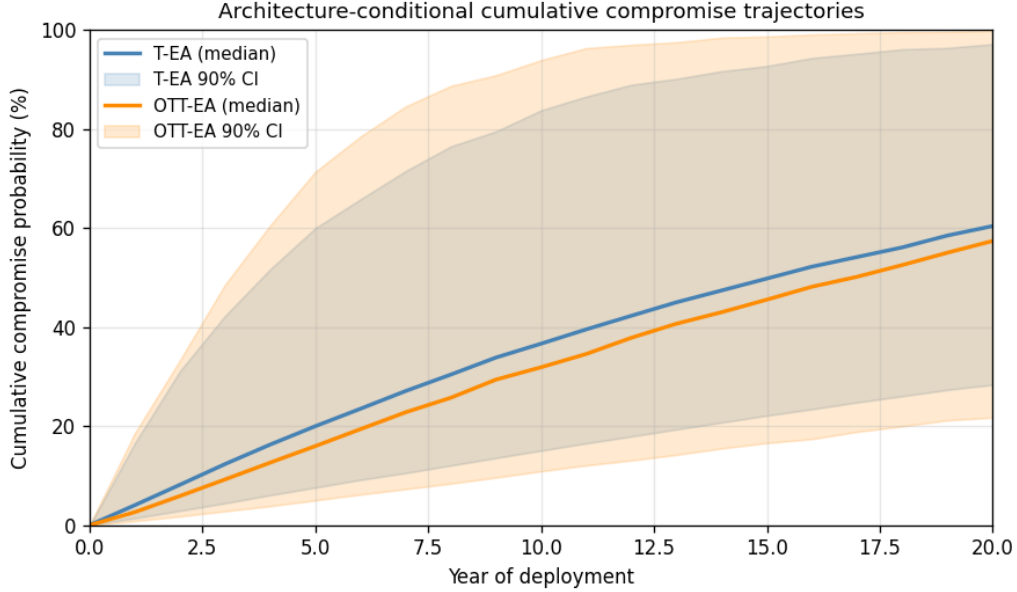


Figure 9: Architecture-conditional comparison of cumulative compromise probability trajectories over a 20-year deployment horizon. T-EA (blue) and OTT-EA (orange) full-dependence trajectories with 90% credible bands. The corresponding independence-baseline trajectories (not shown for clarity) sit below the dependence trajectories at every horizon, with the gap quantified in Table 10. The OTT-EA median sits below the T-EA median throughout the horizon, but the upper credible bound for OTT-EA exceeds that for T-EA at every horizon (consistent with the year-1 values of 17.4% versus 16.5%), reflecting the tail divergence documented in Section 9.5. Trajectories are computed by full re-simulation at each horizon $t = 1, \dots, 20$ with year-by-year campaign-state resampling ($R = 8,000$ replicates per architecture per horizon, seed 2024), so the year-10 values agree with the tabulated Q_{10} quantiles.

Alt text: Two-line plot of cumulative compromise probability over a 20-year horizon for T-EA (blue) and OTT-EA (orange) under the full dependence model. T-EA rises faster and higher than OTT-EA across the horizon; both shown with 90% credible bands.

Table 14: Cumulative operational compromise probability across reference estimates and architectural classes. Three-pillar rows use the compound formula $1 - (1 - q)^T$. The Bayesian median rows use the simulation-derived 10-year values, since the model employs time-varying annual rates whose compounding can differ from the stationary-formula result. The 5- and 25-year values use the formula as lower-bound approximations. **The Bayesian-median rows are included for distributional completeness only; as disclosed in Section 8, the prior calibrations match the architecture-matched three-pillar empirical ranges, so these rows should not be read as independent fourth estimates.** The S-column refers to the synthesis-hierarchy tier (Section 10).

Reference point	S	Annual Λ	5-yr cum.	10-yr cum.	25-yr cum.
<i>T-EA reference points</i>					
Channel-minimum heuristic (four-channel)	S5	1.5%	7.3%	14.0%	31.5%
Fréchet–Hoeffding lower (Pillar II)	S4	2.2%	10.5%	19.9%	42.7%
Bayesian median (Layer IV, prior-cond.)	—	4.0%	18.5%	36.6%	64.0%
Channel-aggregate projection (Pillar III)	S5	5.4%	24.2%	42.6%	75.0%
Pillar II central (independence)	S5	7.3%	31.5%	53.1%	85.0%
Fréchet–Hoeffding upper (Pillar II)	S4	7.5%	32.3%	54.1%	85.8%
<i>OTT-EA reference points</i>					
Channel-minimum heuristic (four-channel)	S5	1.0%	4.9%	9.6%	22.2%
Fréchet–Hoeffding lower (Pillar II)	S4	1.1%	5.4%	10.4%	24.0%
Bayesian median (Layer IV, prior-cond.)	—	2.6%	12.3%	31.9%	48.2%
Channel-aggregate projection (Pillar III)	S5	3.0%	14.1%	26.3%	53.3%
Pillar II central (independence)	S5	3.9%	18.0%	32.8%	63.0%
Fréchet–Hoeffding upper (Pillar II)	S4	4.0%	18.5%	33.5%	64.0%

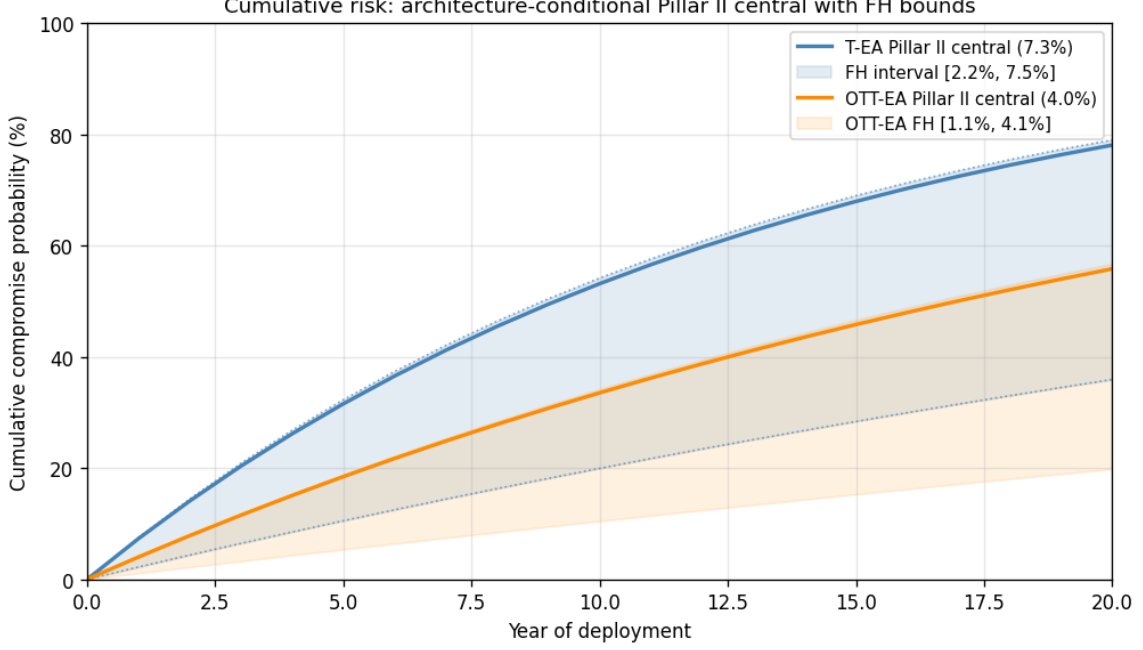


Figure 10: Cumulative EA technical (solid) and access-pathway (dashed) compromise probability under the Pillar II independence-conditional central T-EA parameterisation, with the non-EA baseline and the Fréchet–Hoeffding lower and upper bounds for the technical-compromise curve. The technical-compromise curve under independence crosses 50% near year 10. The lower bound of 2.2% yields approximately 20% over 10 years. The shaded band spans the Fréchet–Hoeffding model-consistent interval under any dependence structure. Seed 2024; $R = 8,000$.

Alt text: Multi-curve plot of cumulative compromise probability over deployment horizon for the T-EA Pillar II independence-conditional central parameterisation. Solid: EA technical compromise crossing 50% near year 10. Dashed: access-pathway compromise. Outer bands give the Fréchet-Hoeffding bracket for the technical curve; non-EA baseline shown for comparison.

the lowest threshold at which the exceedance probability reliably exceeds 0.5 across the primary and pessimistic calibrations for both classes, making it the most prior-separating row.

Table 15: Architecture-conditional exceedance probabilities and maximum defensible deployment horizon $T^*(\tau)$ under the full dependence model ($R = 8,000$ replicates, seed 2024). $T^*(\tau)$ is defined as the first deployment year at which the median cumulative compromise probability Q_T exceeds τ ; the longest horizon over which the median remains within the threshold is therefore $T^*(\tau) - 1$.

τ	T-EA			OTT-EA		
	$\Pr(q_1 > \tau)$ full	$\Pr(q_1 > \tau)$ indep.	T_T^*	$\Pr(q_1 > \tau)$ full	$\Pr(q_1 > \tau)$ indep.	T_{OTT}^*
0.5%	1.000	1.000	—	0.994	0.984	—
1%	0.988	0.974	—	0.907	0.795	—
2%	0.843	0.741	—	0.630	0.411	—
5%	0.386	0.250	yr 2	0.252	0.087	yr 2
10%	0.138	0.058	yr 3	0.104	0.015	yr 4
20%	—	—	yr 6	—	—	yr 9
30%	—	—	yr 9	—	—	yr 14
50%	—	—	yr 17	—	—	yr 26

At a 1% annual threshold, both architectures show high exceedance probabilities under the primary calibration: T-EA exceedance is near saturation (above 0.95); OTT-EA exceedance is substantially above 0.5 but somewhat lower, consistent with OTT-EA’s lower median. That OTT-EA exceedance remains substantially above 0.5 at this threshold indicates that the lower median is not the dominant signal at low thresholds.

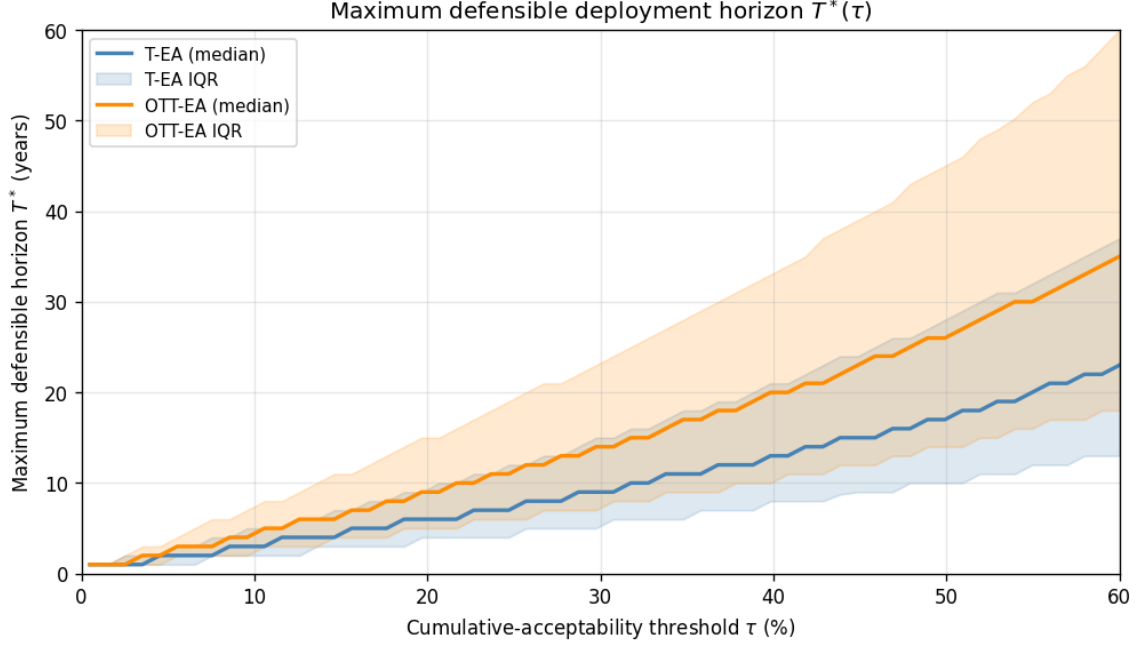


Figure 11: Maximum defensible deployment horizon $T^*(\tau)$ as a continuous function of the cumulative-acceptability threshold τ (defined, as in Table 15, as the first year at which the median cumulative risk crosses τ). Median T^* shown for T-EA (blue) and OTT-EA (orange); shaded bands are interquartile ranges over $R = 8,000$ Bayesian replicates at seed 2024. The figure visualises two structural properties that are compressed in Table 15: the rate at which the OTT-EA horizon diverges from T-EA’s as τ grows, and the substantially wider OTT-EA IQR at higher thresholds, both consequences of OTT-EA’s heavier upper-tail distribution. The step-function appearance of the median curves is the integer-year rounding of T^* . The IQR bands carry the underlying continuous spread.

Alt text: Line plot showing the maximum defensible deployment horizon $T^*(\text{tau})$ (y-axis, years) as a function of the cumulative-acceptability threshold tau (x-axis). T-EA (blue) and OTT-EA (orange) curves with shaded interquartile bands; T-EA’s defensible horizon is shorter than OTT-EA’s by approximately 2 to 4 years across the range.

At higher thresholds the architectural ordering changes character. Even at the 10% annual threshold T-EA exceedance still exceeds OTT-EA (Table 15: 0.138 vs 0.104), but the gap narrows substantially as τ grows: the OTT-EA distribution overtakes T-EA in the upper tail near the 95th-percentile region ($\tau \approx 16\text{--}17\%$), as confirmed by the GPD-fitted upper tails (Table 12) and the architecture-conditional CCDFs of Figure 12. This is the structural signature of OTT-EA’s tail-heaviness: at policy-relevant high thresholds the lower OTT-EA median does not translate into a correspondingly lower exceedance probability, and deep in the tail OTT-EA assigns more mass than T-EA.

The deployment-horizon results follow a similar qualitative pattern (Figure 11). At low acceptability thresholds the median maximum defensible horizons are similar across architectures, both in the low-single-digit-years range. At higher acceptability thresholds the OTT-EA horizons exceed T-EA in central tendency but with substantially wider credible bounds reflecting the tail-heavier distribution. Specific tabulated horizon values for selected thresholds are in Table 15.

Both exceedance and horizon findings are conditional on the primary prior calibration. As the sensitivity analysis below demonstrates, the exceedance findings are materially sensitive to prior choice for both architectures.

9.8 Prior Sensitivity for Exceedance Probabilities

The exceedance findings above are conditional on the primary prior calibrations. Supplementary §S6 reports the architecture-conditional exceedance probabilities under three prior calibrations

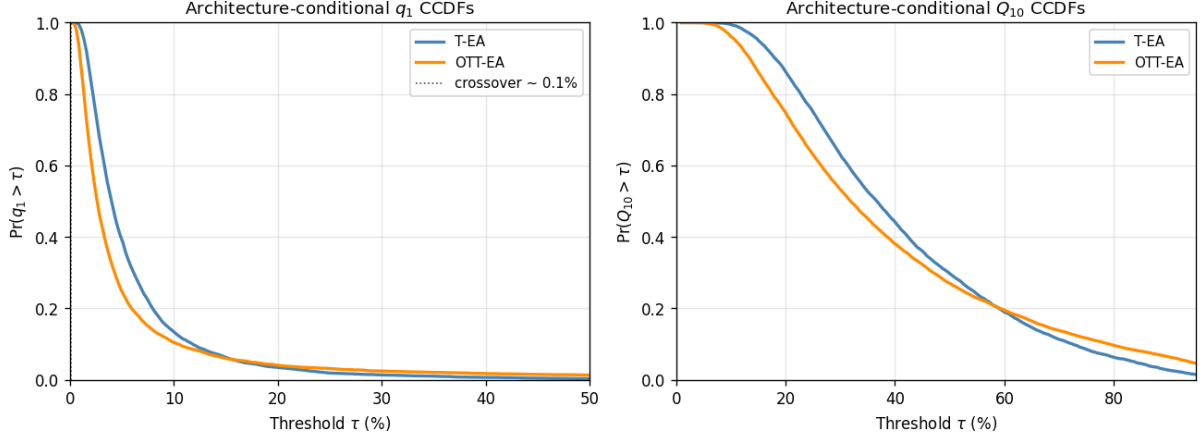


Figure 12: Architecture-conditional CCDFs for q_1 (left) and Q_{10} (right) under the full dependence model. T-EA (blue) sits above OTT-EA (orange) at low thresholds (the median region), but the curves cross deep in the upper tail and OTT-EA exceeds T-EA at the extreme. The crossover threshold for q_1 is approximately $\tau \approx 16$ –17% (near the 95th percentile of both distributions), beyond which OTT-EA assigns higher exceedance probability than T-EA. This is the distributional signature of the cross-cutting coupling specification. The corresponding independence-baseline CCDFs (not shown) sit below the dependence curves at every threshold. The exceedance differences are quantified in Table 10. Results from 8,000 Monte Carlo replicates per architecture (seed 2024).

Alt text: Two-panel complementary cumulative distribution function (CCDF) plot. Left: $P(q_1 > \tau)$ versus τ for T-EA (blue) and OTT-EA (orange); T-EA sits above OTT-EA at low τ but the curves cross near $\tau = 16$ to 17%, after which OTT-EA exceeds T-EA. Right: equivalent CCDF for Q_{10} showing similar crossover behaviour at high thresholds.

spanning the plausible range of analogical evidence (*pessimistic*: analogue population average rate; *primary*; *conservative*: analogue population performing substantially better than the historical record). The qualitative findings are: under the conservative prior the exceedance probability at the 1% threshold drops materially for both architectures (T-EA from $0.988 \rightarrow 0.605$; OTT-EA from $0.907 \rightarrow 0.460$); under the pessimistic prior the same probability rises to saturation (1.000 for both). The architectural ordering (T-EA exceedance $\geq$ OTT-EA at low thresholds) is preserved across all three calibrations, with both architectures saturating under the pessimistic prior. The exceedance probabilities are therefore prior-conditional in magnitude but stable in direction across the defensible prior range. The headline finding that the conservative case lies near $\Pr(q_1 > 1\%) \approx 0.5$ for OTT-EA defines the lower edge of the policy-relevant range.

9.9 Parameter Uncertainty Decomposition

A one-way tornado analysis identifies the architecture-conditional dominant sources of spread in the 10-year cumulative compromise probability Q_{10} . Each parameter is fixed in turn at its prior 10th and 90th percentiles while the others are sampled from their priors. The swing is the resulting change in median Q_{10} . The tornado is taken over the parameters the canonical model treats as uncertain: the three log-normal modifiers for both architectures, plus the cross-cutting coupling ratio γ_X/γ for OTT-EA. Quantities the model holds fixed (γ , $P_3 \cdot P_4$, σ_λ , and the per-channel arrays) have no prior spread to sweep and do not enter.

T-EA decomposition. The three modifiers produce comparable swings in median Q_{10}^T (central 36%): system targeting intensity δ_{target} is the largest (swing of 0.27, range 0.29–0.56), followed by concentration δ_{concen} (swing 0.22, range 0.31–0.53) and the EA-specific attack-surface modifier δ_{EA} (swing 0.21, range 0.31–0.52). No single parameter dominates, consistent with the flat variance decomposition of §9.9.1.

OTT-EA decomposition. The same three modifiers again produce comparable swings in median Q_{10}^{OTT} (central 32%), with $\delta_{\text{target}}^{\text{OTT}}$ the largest (swing of 0.25), followed by $\delta_{\text{concen}}^{\text{OTT}}$ and $\delta_{\text{EA}}^{\text{OTT}}$.

(swing 0.20 each). The OTT-EA-specific cross-cutting coupling ratio γ_X/γ contributes a smaller swing (0.14, range 0.26–0.40). The structural constraint $\gamma_X/\gamma \geq 1$ compresses its prior range substantially (90% credible range [1.52, 2.93]), so the architectural divergence between OTT-EA and T-EA is carried principally by the constraint itself rather than by residual uncertainty about the ratio. As in the EVPPI decomposition of §9.9.1, the three modifiers are comparable in magnitude and the cross-cutting coupling ratio carries a smaller share. The two methods measure different things (range swing versus variance share), so the exact ordering of the three modifiers differs slightly between them.

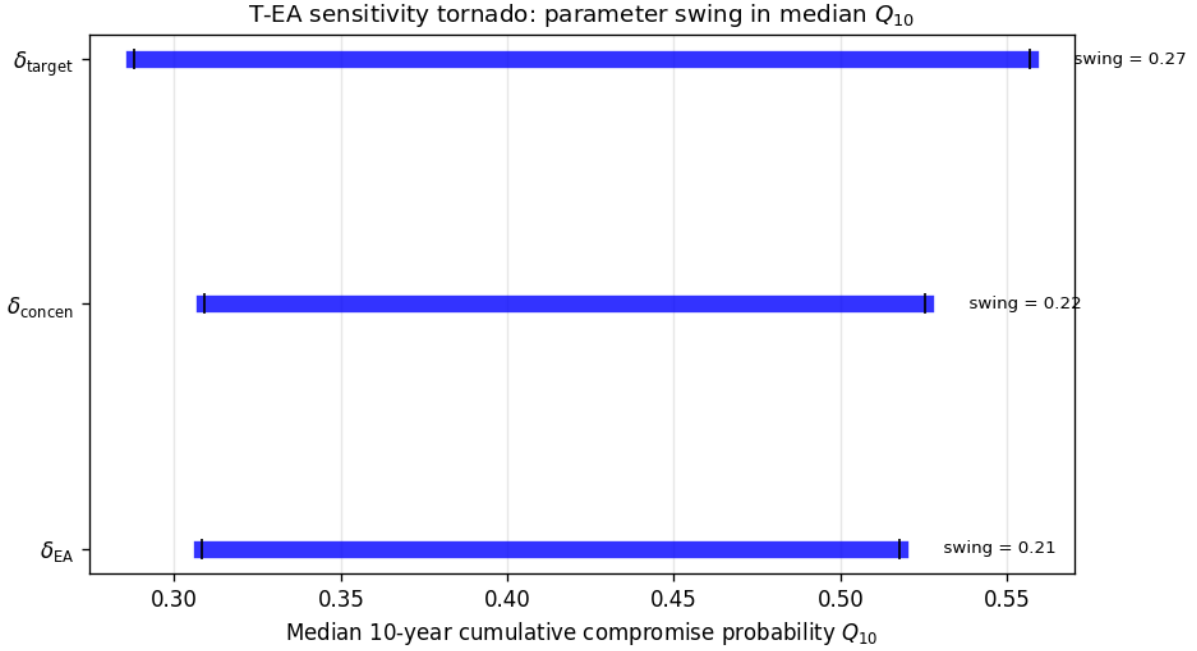


Figure 13: Sensitivity tornado chart: swing in median 10-year cumulative compromise probability Q_{10} when each uncertain parameter is varied across its prior 10th–90th percentile range (T-EA configuration). The three log-normal modifiers produce comparable swings, with system targeting intensity δ_{target} the largest; no single parameter dominates. The OTT-EA tornado, which also includes the cross-cutting coupling ratio γ_X/γ , is given in Figure 14. Results from $R = 4,000$ Monte Carlo replicates per parameter point (seed 2024).

Alt text: Horizontal tornado plot of T-EA configuration: each row shows the swing in median 10-year cumulative compromise probability when one parameter is varied across its prior 10th–90th percentile range. The three log-normal modifiers δ_{EA} , δ_{target} , δ_{concen} and δ_{EA} produce comparable swings, with δ_{target} the largest; no single parameter dominates.

9.9.1 EVPPI-style variance decomposition

A partial parameter-uncertainty decomposition (EVPPI-style variance decomposition) quantifies the contribution of each uncertain parameter to the total output variance $\text{Var}(Q_{10})$, separately for each architectural class. The decomposition is taken over exactly the parameters the canonical Monte Carlo engine treats as uncertain, drawn from the canonical priors: the three log-normal modifiers (δ_{EA} , δ_{target} , δ_{concen}) for both architectures, plus the cross-cutting coupling ratio γ_X/γ for OTT-EA. Quantities the canonical model holds fixed (γ , $P_3 \cdot P_4$, σ_λ , and the per-channel cross-cutting and detection arrays) contribute no output variance and are not decomposed. For T-EA, the three modifiers individually account for approximately 61% of total output variance in sum (the sum of their first-order Sobol indices); resolving them jointly would capture this share plus any interaction terms among them. For OTT-EA, the three modifiers and γ_X/γ account for approximately 49% in sum, the larger residual reflecting the additional interaction structure

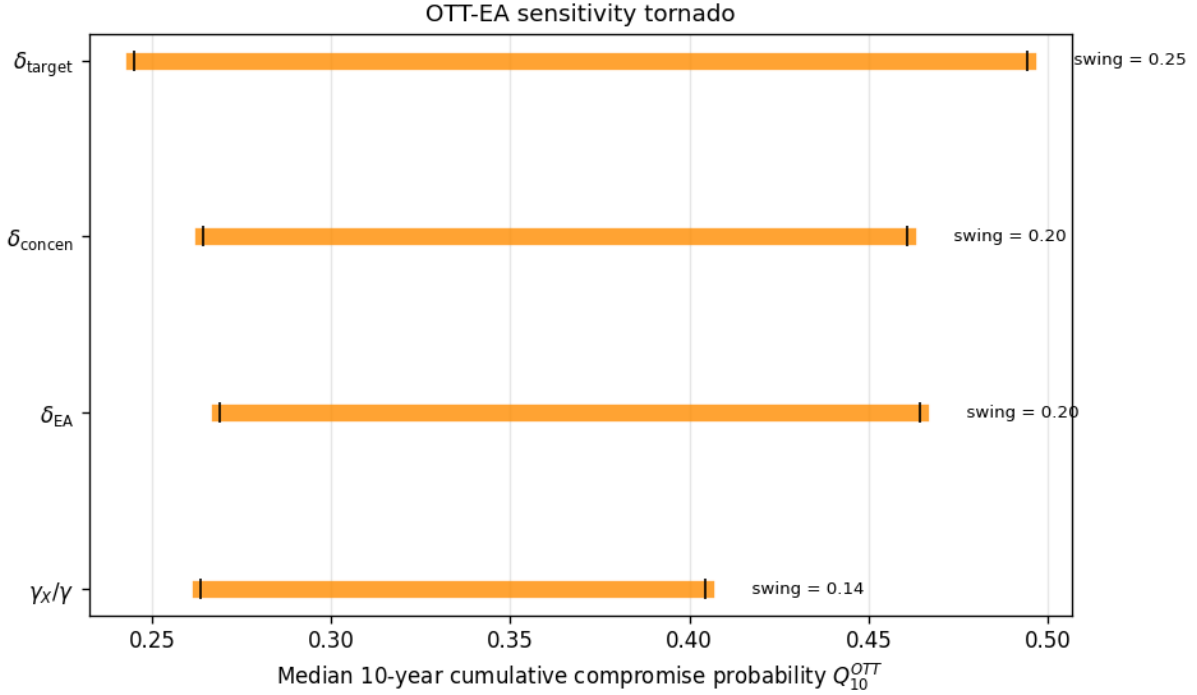


Figure 14: Sensitivity tornado chart for the OTT-EA configuration. The three log-normal modifiers produce comparable swings, with $\delta_{\text{target}}^{\text{OTT}}$ the largest; the OTT-EA-specific cross-cutting coupling ratio γ_X/γ enters as a smaller additional contributor. Under the shifted-lognormal prior on γ_X/γ (Equation 28, with the structural constraint $\gamma_X/\gamma \geq 1$ enforced by construction, 90% credible range [1.52, 2.93]), its prior range is compressed, so the architectural divergence between OTT-EA and T-EA persists structurally through the lower-bound constraint rather than through residual uncertainty about the ratio. Results from $R = 4,000$ Monte Carlo replicates per parameter point (seed 2024).

Alt text: Tornado plot for the OTT-EA configuration showing the three log-normal modifiers plus the OTT-EA-specific cross-cutting coupling ratio γ_X/γ . The modifiers produce comparable swings, with δ_{target} the largest; the coupling ratio enters as a smaller contributor.

introduced by cross-cutting coupling.

The rank-order finding is the principal output, and it is flat: for T-EA the three modifiers contribute comparable shares (each roughly 18–25%), and for OTT-EA likewise (12–15% each) with the coupling ratio adding a smaller first-order index ($\sim 9\%$), limited because the structural constraint $\gamma_X/\gamma \geq 1$ does the architectural work at the prior level rather than through residual value uncertainty. A substantial residual (39% T-EA, 51% OTT-EA) is irreducible to single-parameter learning. As a research-prioritisation finding, no single parameter dominates, so empirical work across the modifiers yields broadly comparable variance reduction; per-parameter detail is in Supplementary §S12.

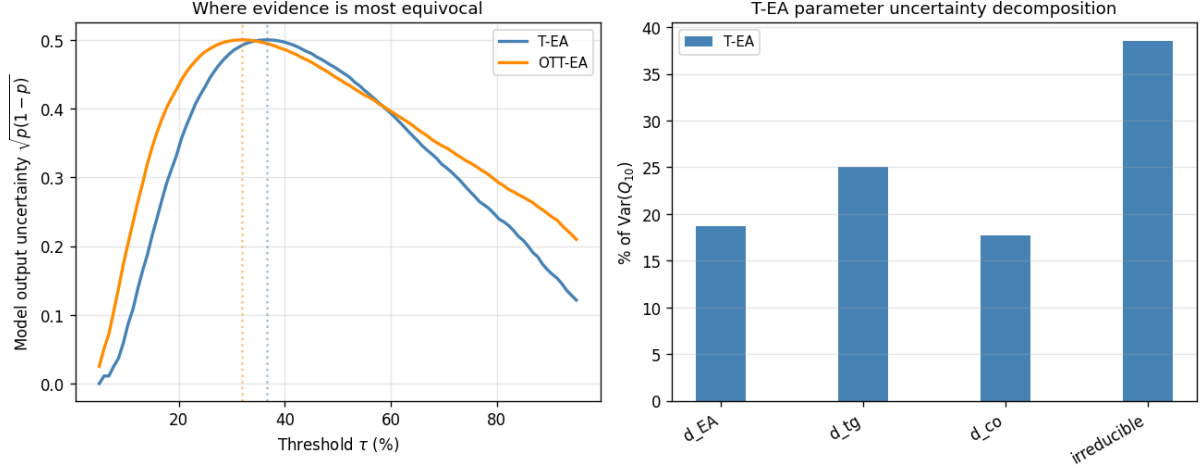


Figure 15: Parameter uncertainty decomposition (T-EA configuration). Left: model output uncertainty as a function of the risk threshold τ , showing where along the risk scale the evidence is most equivocal (peaks near the median q_1 , where the outcome is most uncertain). Right: percentage of $\text{Var}(Q_{10})$ attributable to each uncertain parameter. The three log-normal modifiers contribute comparable first-order shares, with no single parameter dominating; the residual absorbs parameter interactions and the model’s internal stochasticity. The OTT-EA decomposition also includes the OTT-EA-specific cross-cutting coupling ratio γ_X/γ and is reported in Supplementary §S8 (Table S6). First-order Sobol indices from $R = 2,000$ pick-freeze replicates per parameter (seed 2024).

Alt text: Two-panel parameter uncertainty decomposition for T-EA. Left: model output uncertainty as a function of risk threshold tau, peaking near the median q_1 where the outcome is most uncertain. Right: bar chart of percentage of $\text{Var}(Q_{10})$ attributable to each uncertain parameter, with the three log-normal modifiers contributing comparable shares and a large irreducible residual.

10 Synthesis: What the Framework Collectively Establishes

10.1 Structural Versus Calibration-Dependent Results

The findings of this paper fall into three classes, and the weight a reader should place on each differs accordingly. The classes are groupings of the synthesis tiers S1–S6, which are formalised in the enumeration at the end of this section and mapped claim-by-claim in Table 1; one scheme, viewed at two resolutions. The first class follows from architecture alone and survives any defensible calibration: the dominance ordering of Proposition 1, the Fréchet–Hoeffding interval logic, and the direction of the OTT-EA tail divergence, which holds under any coupling prior with support in $[1, \infty)$. The second class holds across the full calibration set examined (primary, conservative, and pessimistic priors) but is not derivable from structure: material multi-decade cumulative risk, the preservation of the T-EA-over-OTT-EA central ordering, and the low-threshold exceedance ordering. The third class is calibration-dependent: the specific medians, GPD shape values, and inflation magnitudes quoted at the primary calibration.

One clarification keeps the strongest tier honest. The structural class is conditional on two premises: the superset-graph assumption (EA deployment adds nodes and edges rather than replacing them) and the $\delta \geq 1$ constraints on the EA modifiers. These premises are not stipulations of convenience. Each is anchored to documented incident properties: Salt Typhoon attacked infrastructure that exists only because of the EA mandate; the Athens affair exploited lawful-intercept capability dormant in a commercial switch; and Storm-0558 demonstrated the concentration property for platform-held key material. But the premises are defeasible, and what would defeat them can be stated. The superset assumption fails if an EA mandate *substitutes* for riskier informal access mechanisms rather than adding a new surface alongside them; the $\delta_{\text{target}} \geq 1$ constraint fails if EA components attract no incremental adversary attention; and mandated defensive standards could in principle offset the added surface (§11, the regulatory-

uplift counterfactual). Evidence for any of these would relegate the dominance ordering from the structural class to a calibration question. The ordering is therefore structural *given premises argued from the incident record*, not true by construction.

The boundary between the second and third classes is demonstrated within the paper’s own robustness set rather than asserted. Under the pessimistic calibration the fitted GPD shape parameter changes sign in both architectures (Table 13): the output distribution saturates against the $q = 1$ ceiling and the heavy-tail characterisation loses its tail-decay interpretation (§9.5). The heavy-tail finding can therefore fail under a prior inside the defensible set. That is what distinguishes it from a hard-wired consequence of the log-normal-and-Gamma machinery: the model is capable of producing the opposite answer, and does so under one of the three calibrations. Findings reported here as structural are precisely those for which no calibration in the set produces a counterexample.

Two conditioning conventions apply throughout and are stated here once rather than repeated at every use. *Calibration-conditional* marks third-class quantities: values computed at the primary calibration whose magnitudes, though not their signs or orderings, move under defensible recalibration. Fréchet–Hoeffding intervals are conditional on the Pillar II per-scenario probabilities: their robustness is to dependence structure within that model, and the quantity-level relationship to the Bayesian outputs is set out in §9.2. Where these labels appear without elaboration in what follows, this paragraph is their definition.

10.2 The Role of the Bayesian Layer

The Bayesian layer contributes five findings to the synthesis. Its prior calibrations use the same architecture-matched analogical evidence as Pillar I (T-EA priors anchored on Streams A and B; OTT-EA priors on Streams B and C), so the architecture-conditional medians it produces are not independent corroboration of the three-pillar ranges. The five contributions divide into two groups by epistemic standing. Three (the dependence-quantification, the cross-cutting coupling mechanism, and the EVPPI decomposition: items 2, 3, and 5 below) are genuinely Bayesian-specific in the sense that they require the explicit correlated-campaign coupling model and cannot be derived from the three pillars alone. The other two (distributional shape and exceedance characterisation: items 1 and 4) could in principle be produced by a sufficiently large Pillar II Monte Carlo, but in this framework are most naturally and efficiently delivered by the Bayesian layer alongside its dependence treatment. The five contributions are:

1. *Architecture-conditional distributional shape.* The prior predictive distributions for both classes are heavy-tailed under the stated model and priors (T-EA $\hat{\xi} = 0.271$; OTT-EA $\hat{\xi} = 0.518$, both Fréchet-domain). The OTT-EA tail is conditionally heavier-tailed, consistent with the cross-cutting coupling specification.
2. *Architecture-divergent dependence quantification.* The annual 95th-percentile uplift from adding campaign dependence is $\times 1.53$ for T-EA and falls in the range $\times 2.67$ to $\times 3.42$ for OTT-EA across the defensible $\sigma \in [0.25, 0.75]$ range (Table 11); the $\times 2.83$ point estimate corresponds to the headline $\sigma = 0.40$ specification, prior-integrated over γ_X/γ (Equation 28). The corresponding conditional values at fixed γ_X/γ span $\times 1.52$ to $\times 5.12$ across $\{1, 1.5, 2, 3\}$. All establish that independence assumptions are optimistic at the tail. The architectural divergence (OTT-EA uplift exceeding T-EA uplift) is structurally guaranteed by the coupling prior ($\gamma_X/\gamma > 1$ almost surely) and survives the entire defensible parameter range. Both findings hold under wide variation in the campaign parameters within the priors.
3. *Cross-cutting coupling as the structural mechanism.* The Bayesian model identifies cross-cutting infrastructure as the architectural mechanism through which correlated campaigns erode the OTT-EA segregation gain. The sensitivity analysis over γ_X/γ shows that this mechanism is durable across the plausible coupling-ratio range.
4. *Architecture-conditional exceedance characterisation (prior-conditional).* The distributions assign $\Pr(q_1 > 1\%) = 0.988$ (T-EA) and 0.907 (OTT-EA) under primary prior calibrations,

with the 1% row reported here as an illustrative entry from the full threshold range in Table 15. Both findings are sensitive to prior choice. The OTT-EA exceedance falls below 0.5 under the conservative prior, the T-EA exceedance does not.

5. *Architecture-conditional parameter uncertainty decomposition.* For T-EA, targeting intensity and concentration are the primary reducible variance sources. For OTT-EA, the cross-cutting amplification ratio γ_X/γ and the segregation factor $P_3 \cdot P_4$ are additional dominant sources, identifying architectural empirical characterisation as a first-order policy research priority that does not arise in the T-EA case.

10.3 The Shared Structural Assumption and Its Limits

Pillars I, II, and III all use the complement-of-product aggregation structure within each architectural class, with architecture-conditional ξ -weighting for OTT-EA. This shared structure is what produces the within-class agreement: three methodologies using the same mathematical aggregation will produce similar outputs when fed comparable inputs. The agreement is therefore a property of the framework’s internal logic under the independence assumption, not externally validated corroboration of either the T-EA 5.4% aggregate or the OTT-EA 3.0% aggregate as frequency estimates.

The Bayesian model provides a critical perspective on this shared assumption, applied in parallel to both classes. The explicit dependence model shows that realistic correlated campaign structure inflates the annual 95th percentile by $\times 1.53$ (T-EA) and $\times 2.83$ (OTT-EA) relative to independence, prior-integrated over γ_X/γ . The OTT-EA magnitude varies between $\times 2.67$ and $\times 3.42$ across the defensible prior-width range $\sigma \in [0.25, 0.75]$ (Table 11). The architectural divergence (OTT-EA uplift exceeding T-EA uplift) is structurally guaranteed by the coupling prior ($\gamma_X/\gamma > 1$ almost surely; §8.5). The shared independence assumption in the three-pillar model is therefore *optimistic* at the tail for both classes, and *more optimistic* for OTT-EA. Both within-class agreement is better understood as a set of conditional central estimates than as central tendencies robust to dependence assumptions.

10.4 The Evidence Base for a Material Risk Finding

Stripping out what is prior-calibration-dependent and what is methodologically shared, the genuinely independent quantitative evidence that EA compromise risk is material in each architectural class comes from the following sources:

T-EA evidence. The Stream A government-system per-system base rate ranges from 0.46%/yr (Tier 1 direct analogues, $k = 3$) to 0.92%/yr (full cohort, $k = 6$); the Tier 1+2 intermediate cohort ($k = 4$) gives 0.62%/yr. Across the $3\times$ to $15\times$ EA targeting-premium range, the joint inclusion-criterion $\times$ premium grid spans 1.4% to 12.9% annually. The grid centre (full cohort, $10\times$) is 8.8%; the Tier 1 centre at $10\times$ is 4.5%. The defensible T-EA empirical-projection interval is therefore 1.4–12.9%, with the breadth reflecting inclusion-criterion and targeting-premium uncertainty rather than empirical-base-rate uncertainty.

OTT-EA evidence. The Stream C architectural-fit-restricted strict-joint base rate is 0.95%/yr (Tier 0+1, $J = Y$, per operator-year), with an all-tiers strict-joint upper bracket of 1.33%/yr. At a $3\text{--}5\times$ EA-specific premium (lower than the T-EA range because Stream C’s base rate already reflects substantial existing platform targeting), the projection is 2.8–4.7% annually at the headline base (3.9–6.4% at the upper bracket). At $1\times$ (no additional EA targeting premium beyond existing platform attention), the projection is 0.95% itself. The defensible OTT-EA empirical-projection interval is therefore 0.9–6.4%.

Centralised single-operator evidence (architectural bridge). The Stream B CA-cohort base rate of 0.545%/yr (pooled) projects to 1.6–5.3% at $3\text{--}10\times$ premiums. This is a consistency check between the two architectural extremes.

Bayesian exceedance findings. The architecture-conditional exceedance probabilities reported in Table 15 are conditioned on the prior. At the illustrative 1% threshold, $\Pr(q_1 > 1\%) = 0.988$ (T-EA) and 0.907 (OTT-EA) at the primary calibration; the corresponding entries at higher and lower thresholds are documented in the same table, and the choice of any specific threshold as the benchmark for policy use is jurisdictional rather than technical (§9.7). The exceedance results are not sensitive to reasonable perturbations of the prior median within each architecture, but are sensitive to priors concentrated below the threshold under consideration.

The independent strands of evidence place annual EA compromise risk most plausibly in the range 1.4–8.8% for T-EA and 0.9–6.4% for OTT-EA, with material probability mass at low-single-digit annual thresholds in both cases and a heavy upper tail driven by dependence structure (more pronounced for OTT-EA). The precise location within these ranges depends on assumptions (the targeting premium, the independence structure, the cross-cutting coupling) that cannot currently be empirically resolved.

10.5 The Stochastic Dominance Floor

Beneath all the conditional quantitative analyses, Proposition 1 establishes a result grounded in the empirically supported structure of EA systems: in either architectural class, EA-equipped architectures carry strictly higher modelled risk than the no-EA counterfactual within the same class. The proposition’s significance is not that it is model-free in the sense of requiring no assumptions, but that it rests on assumptions (that EA increases attack surface, attracts elevated targeting, and concentrates key-material value) for which there is concrete operational evidence in both architectural classes (Salt Typhoon, Stream A Tier 1, and the historical Athens affair as a Pillar III channel analogue, for T-EA; Storm-0558 and Midnight Blizzard for OTT-EA, treated as analogues per Section 5.3). The debate about EA risk is therefore not about whether the mandate adds risk in either architectural class, but about how much, in what distributional form, and whether the architectural choice between classes itself materially affects the expected harm.

Remark 2 notes that the cross-architecture comparison is not first-order stochastic dominance: T-EA dominates OTT-EA at the median (T-EA is riskier on average), but OTT-EA can exceed T-EA in the upper tail under correlated campaigns. This is a substantive policy finding. Architectural choice between T-EA and OTT-EA is not a uniform improvement but a trade-off between expected risk and tail risk.

10.6 What the Full Framework Establishes

The framework supports six findings distinguished by their assumption-robustness. The Reader’s Guide (Table 1) maps each principal claim to its tier. This section formalises the tier content.

- (S1) *Structural ordering.* EA systems in either class carry strictly higher modelled risk than the no-EA counterfactual within the same class. The result follows from documented attack-surface, targeting, and concentration properties of EA infrastructure and does not depend on prior calibration.
- (S2) *Heavy upper tails and dependence inflation.* Annual compromise probability distributions have heavy upper tails in both classes; correlated-campaign modelling inflates the upper-percentile risk more for OTT-EA than for T-EA. The T-EA upper tail is statistically consistent with a Generalised Pareto distribution (positive shape parameter, goodness-of-fit not rejected at the primary threshold). The OTT-EA upper tail is heavier than T-EA’s by direct percentile comparison but does not fit a single GPD across any tested threshold (Supplementary §S24), consistent with a mixture structure induced by correlated-campaign coupling on cross-cutting edges. The architectural divergence is structurally guaranteed by the coupling prior ($\gamma_X/\gamma > 1$ almost surely) and survives the defensible prior-width range; inflation-factor magnitudes are calibration-conditional.

- (S3) *Exceedance behaviour*. Exceedance probabilities at low policy thresholds are elevated under the primary calibration and decline materially under conservative priors. The architectural ordering (T-EA > OTT-EA at low thresholds) is preserved across the full defensible prior range. Which threshold is policy-dispositive is a jurisdictional question.
- (S4) *Plausibility ranges (interval dominance)*. Annual T-EA compromise probability lies in the low single-digit range under any dependence structure compatible with the Pillar II model (Fréchet–Hoeffding bracket); OTT-EA is broadly lower in central tendency but its upper bound exceeds T-EA’s under correlated campaigns. The three empirical streams all project per-system rates on the order of 1% per system-year, supporting these ranges as plausibility ranges.
- (S5) *Channel-aggregate projections (independence-conditional)*. Under independence among irreducible risk channels both architectures yield channel-aggregate projections in the low single-digit range, T-EA higher than OTT-EA. The aggregates are interpretive points within the (S4) ranges rather than methodologically independent estimates.
- (S6) *Cross-architecture trade-off*. The comparison is not first-order stochastic dominance: T-EA is riskier in central tendency, OTT-EA in the upper tail under correlated campaigns. Architectural choice is a central-tendency-versus-tail-risk trade-off rather than a uniform improvement.

Robustness ordering. The mapping of these tiers onto the three classes of §10.1: S1, the direction of S2, and S6 are structural; S4 holds across the calibration set within the Pillar II model structure; S3, the magnitudes within S2, and the specific aggregates of S5 are calibration-conditional.

11 Discussion of Limitations

The limitations below are individually consequential. Collectively, they preclude any reading of the framework as a forecasting or estimation instrument. The outputs are decision-support inputs rather than calibrated empirical projections, and are presented as ranges or qualitative directional findings rather than point estimates. The interval-dominance and structural-ordering findings (§10) survive the limitations identified below; specific magnitude projections do not.

11.1 The Fundamental Epistemic Gap

The deepest limitation cannot be resolved within the approach: no EA system has been deployed at scale and subsequently compromised in a documented, publicly attributable incident that could serve as a calibration data point. All empirical inputs are analogical, and the analogical transfers embedded in every pillar and in the Bayesian domain transfer function carry unverifiable assumptions about structural similarity. This is precisely why a framework designed for deep uncertainty (rather than a conventional statistical calibration) is the appropriate methodological choice.

Forward-secrecy degradation is out of scope. Of the five structural risk classes set out in Section 2, the framework quantifies four (single point of failure, insider threat, complexity-vulnerability correlation, scale risk) and does not quantify forward-secrecy degradation. The reason is methodological: forward secrecy affects the *consequences* of a key compromise (how much prior traffic becomes decryptable) rather than its *probability*, and consequence-side modelling lies outside the risk-side scope declared in §1. An EA-mandated architecture that breaks or weakens forward secrecy increases the harm of any single compromise event without affecting its likelihood. Because forward secrecy affects the harm per compromise rather than its probability, its omission from the probability-side framework implies that the risk numbers reported here would need to be scaled upward in a complete risk-benefit analysis for architectures that weaken or remove

forward secrecy. A complete analysis would integrate this consequence-side magnification with the probability-side estimates this framework produces. That integration is left for future work.

11.2 Bayesian Prior Calibration and the Limits of the Median

The Bayesian edge-hazard priors are calibrated so that the prior predictive distribution produces annual compromise probabilities consistent with the three-pillar 3–6% range. The Bayesian median of 4.0% is therefore not independent confirmation of the three-pillar within-class agreement: a prior calibrated to produce results in a target range will produce them. The calibration keeps the model consistent with the best available analogical evidence but makes the median a function of that evidence rather than an external check on it. The exceedance finding $\Pr(q_1 > 1\%) = 0.988$ is similarly prior-conditional: under the conservative prior it drops to 0.605; under the pessimistic prior it rises to saturation (Supplementary §S6). The exceedance finding should be read as the implication of accepting the primary analogical evidence (government HSM and CA cohort data) as the appropriate calibration source, not as robust across the full defensible prior range.

11.3 The EA Targeting Premium

The EA targeting premium translates the empirical base rate of state-actor compromise of cryptographic-relevant systems into a projected rate for EA-equipped systems specifically. No EA-specific empirical dataset exists from which this multiplier could be directly estimated, and the $10\times$ value used in the main analysis is a modelling judgement informed by adjacent precedents rather than a directly measured quantity. The $3\times$ – $15\times$ range used throughout is likewise a *structured author judgement*, constructed from the named anchors set out below—the documented targeting precedents, the sector-resolved actor-mix data, and the qualitative disparity argument—rather than the output of a formal multi-expert elicitation protocol, and it is presented as such. The update rule in Section 11.9 is the mechanism by which operating experience revises it. Applied to the pooled Stream A + B rate (0.545%/yr), the projections at $3\times$, $5\times$, $10\times$, $15\times$ are 1.6%, 2.7%, 5.3%, 7.8%; applied to the Stream A-anchored T-EA rate (0.92%/yr), the projections are 2.7%, 4.5%, 8.8%, 12.9%. The remainder of this subsection sets out the external evidence that constrains the plausible premium range and identifies the empirical work that would tighten it.

Lower-bound evidence (against premium $< 3\times$). Three lines of evidence argue against a multiplier substantially below $3\times$. First, the 2024 Salt Typhoon campaign demonstrably targeted CALEA-mandated lawful-intercept infrastructure at multiple major US carriers [5, 6]: the lawful-intercept management plane was a specific operational objective, and the attack succeeded despite the carriers’ mature regulatory posture. The base-rate analogue for state-actor compromise of a comparable non-EA-equipped carrier infrastructure component over a similar window is substantially below the observed Salt Typhoon prevalence. A single precedent does not pin down the ratio, but it rules out values close to $1\times$. Second, the Verizon DBIR documents, across successive editions, a marked disparity in the share of breaches attributable to state-aligned espionage actors across target sectors: high-value and government target classes exhibit actor-mix ratios several times the cross-sector base rate [37, 38]. The qualitative disparity is consistent with a multiplier of at least 3 – $5\times$ for cryptographic-infrastructure targets, even if the cross-domain rate ratio is not directly transferable. Third, ETSI’s standardised threat, vulnerability and risk-analysis methodology [57] frames threat likelihood in terms of attacker capability and motivation, recognising that well-resourced, deliberately targeted attacks can realise compromises beyond the reach of the broader opportunistic-criminal profile dominant in the carrier-network base rate. This asymmetry is the qualitative substance of the premium and is also inconsistent with multipliers near $1\times$.

Upper-bound evidence (against premium $\gtrsim 15\times$). Two considerations argue against very large multipliers. First, Salt Typhoon compromised some but not all CALEA-mandated US carriers within the observation window. A multiplier of $\sim 20\times$ applied to the Stream B+A pooled rate would predict more frequent or more complete compromise of the same infrastructure class than the public record supports. Second, the Bayesian Layer IV upper percentile region for q_1 (the OTT-EA 90%-CI upper bound is $\sim 17\%$ and the T-EA upper bound is $\sim 16\%$) is already very high. A Pillar I central-tendency projection at $15\text{--}20\times$ would push the implied central rate toward $8\text{--}11\%$, exceeding plausibility-bounded historical analogues at the central tendency even before tail effects are considered. The 95% upper bound of the Stream B Garwood CI at $10\times$ already reaches 7.66% , which sits at the boundary of historically defensible critical-infrastructure annual compromise probabilities.

Defensible range and central estimate. The above considerations support a defensible range of approximately $3\text{--}15\times$ for the EA targeting premium, with $10\times$ representing the upper-mid region of that range rather than its modal point. Under this calibration the centralised single-operator projected rate (from the pooled rate) spans $1.6\text{--}7.8\%$, with the median of the range at roughly $4\times\text{--}6\times$ giving $2.2\text{--}3.2\%$. The parallel Stream A-anchored T-EA range is $2.7\text{--}12.9\%$ across $3\text{--}15\times$ (with $10\times$ giving the 8.8% headline). Both ranges are intentionally wider than any single-point headline and reflect the genuine uncertainty in this parameter.

Implications for the headline. The architecture-class *ordering* (T-EA versus OTT-EA, structural ordering S1, and the $\gamma_X/\gamma \geq 1$ -driven OTT-EA tail-heaviness) does not depend on the premium calibration. The premium scales the central rate but not the architectural divergence. The Fréchet–Hoeffding interval $[2.2\%, 7.5\%]$ from Pillar II (§6) does not depend on the premium calibration at all: it is derived from the seven-scenario per-channel probabilities without any single-operator pooling step. The $2.7\text{--}12.9\%$ Stream A-anchored T-EA range and the $1.6\text{--}7.8\%$ pooled centralised single-operator range are the relevant calibrated intervals for the central tendency. The qualitative findings rest on structural rather than calibration-dependent arguments.

Future work to tighten the bound. A matched-cohort study comparing compromise rates among CALEA-mandated US carriers over 2010–2024 against equivalent non-CALEA-mandated carrier infrastructure over the same window could quantitatively bound the multiplier from observed compromise-rate differentials. Similar approaches could exploit the EU-CSAM regulation trajectory, jurisdictional variation in lawful-intercept obligations across OECD members, and the asymmetric compromise records of CA infrastructure under different audit regimes. None of these analyses is performed in the present paper. Identifying them as the empirical work that would tighten the most consequential single calibration parameter is itself a contribution.

11.4 Regulatory Defensive Uplift: The Unmodelled Counterfactual

The modifier structure (Equation 24) captures three multiplicative effects of an EA mandate: increased attack surface (δ_{EA}), elevated adversarial targeting (δ_{target}), and key concentration (δ_{concen}). It does not include a compensating modifier $\delta_{def} \geq 1$ for the defensive uplift a regulatory mandate may itself impose (mandatory HSM certification, audit-trail requirements, certified incident-response capability, personnel vetting above the commercial baseline). This is the strongest pro-EA counter the framework does not directly engage: a defender would argue that unregulated Stream A and Stream C operators understate the rate a mandated operator would face, so δ_{def} might offset $\delta_{EA} \cdot \delta_{target} \cdot \delta_{concen}$ in part or whole.

Three observations bound plausible δ_{def} . (i) Salt Typhoon (2024) occurred at CALEA-regulated US carriers operating under the most mature lawful-intercept regulatory regime in

the Western world. The regulation did not prevent state-actor compromise of the orchestration layer. (ii) The Stream B CA cohort operates under formal CCADB-anchored governance with mandatory audit, transparency-log, and revocation requirements, which is a precise analogue of the regulatory uplift a defender would invoke. The resulting per-CA rate (0.45%/yr) is the best empirical upper bound on the defensive uplift attainable through CA-equivalent regulation, since it already incorporates the regulatory benefits. (iii) The regulatory cadence is empirically lagging rather than leading: standards harden in response to compromise, not in anticipation. The empirical record offers no clear support for a defensive uplift large enough to nullify the EA penalty. The most-regulated environment in the analogue set is the one where the largest documented compromise occurred. Future work should treat δ_{def} as a fourth modifier with prior informed by the analogue cohort’s regulatory characteristics. The qualitative conclusions of the present analysis are expected to survive any δ_{def} consistent with the Stream B versus Stream C ratio.

11.5 The Cross-Cutting Coupling Ratio γ_X/γ

The OTT-EA architectural findings rest on the latent campaign variable $Z(t)$ being coupled more strongly to cross-cutting edges than to subgraph-internal edges (Section 8.5, Equation 27). The prior median $m = 2$ is calibrated against the Stream C cross-cutting fraction $\hat{p}_X = 7/14$ (Section 8.5). The remaining specification choice is the prior width σ . The OTT-EA tail-inflation magnitude is sensitive to σ : Table 11 reports the prior-integrated 95th-percentile uplift across $\sigma \in \{0.25, 0.40, 0.50, 0.60, 0.75\}$. At $\sigma = 0.25$ the uplift is $\times 2.67$ (close to the fixed- $\gamma_X/\gamma = 2$ value); at $\sigma = 0.75$ it reaches $\times 3.42$. The *direction* of the architectural divergence (OTT-EA tail inflation exceeding T-EA’s $\times 1.53$) is unconditional under any prior with support in $[1, \infty)$, since the constraint $\gamma_X/\gamma \geq 1$ alone is sufficient to guarantee equal-or-greater OTT-EA cross-cutting amplification at every replicate. The *magnitude* of the divergence depends on σ .

Sensitivity to the prior median. The same question arises for the prior median m , and Table 16 reports the complementary sweep over $m \in \{1.2, 1.5, 2, 3, 4\}$ at fixed $\sigma = 0.40$ ($R = 8,000$, seed 2024). Two features stand out. The annual median is only weakly sensitive (2.31% at $m = 1.2$ rising to 3.53% at $m = 4$): the coupling ratio is a tail parameter, not a central-tendency one. The tail uplift, by contrast, is strongly increasing, from $\times 1.73$ at $m = 1.2$ to $\times 12.4$ at $m = 4$. The architectural divergence direction is preserved at every value swept: even at $m = 1.2$, barely above the structural floor, the OTT-EA uplift exceeds T-EA’s $\times 1.53$. The conclusions that depend on m are therefore the quoted inflation magnitudes, not the ordering. The empirical anchoring of m itself is set out in §8.5 and Supplementary §S22.

Table 16: Sensitivity of OTT-EA results to the cross-cutting coupling prior median m at fixed $\sigma = 0.40$ ($R = 8,000$ replicates, seed 2024). Uplift is the prior-integrated 95th-percentile ratio of the full-dependence to the independence configuration; the T-EA reference uplift is $\times 1.53$. The divergence direction is preserved at every m ; its magnitude is calibration-dependent. The $m = 3$ and $m = 4$ rows lie partly in the saturation regime of §9.5 (95th percentiles approaching the $q = 1$ ceiling), so their uplift factors mix tail-decay and ceiling effects and should not be read as pure tail-heaviness.

Prior median m	Median q_1	95th pct. q_1	Median Q_{10}	95th-pct. uplift
1.2	2.31%	10.6%	23.6%	$\times 1.73$
1.5	2.42%	12.5%	26.1%	$\times 2.04$
2.0 (primary)	2.63%	17.4%	31.9%	$\times 2.83$
3.0	3.06%	38.2%	48.1%	$\times 6.22$
4.0	3.53%	76.5%	70.1%	$\times 12.4$

Empirical update path for σ . The Stream C cohort structure already supports a likelihood-based posterior on γ_X/γ . For each Stream C incident i with $X_i = Y$ (cross-cutting outcome) versus $X_i \in \{P, N\}$, the Bernoulli likelihood

$$\Pr(X_i = Y \mid \gamma_X/\gamma, Z_i, \theta) = f(\gamma_X/\gamma, Z_i, \theta)$$

follows from the attack-graph specification: in the saturated regime, $f \rightarrow 1 - e^{-c\gamma_X Z}$ for an edge-weight constant c . Combined with Equation 28 as a regulariser, the fourteen Stream C incidents yield a posterior on γ_X/γ with an empirically anchored spread. The small cohort size means the posterior remains wide, but data-bounded rather than expert-judgement-bounded. This is the highest-priority extension of the framework: it would convert σ from a calibration choice into a measured quantity, removing the last unmeasured parameter from the OTT-EA analysis. The methodology is straightforward. The bottleneck is the case-by-case latent- Z_i assignment, which requires per-incident correlated-campaign indicators not in the existing Stream C documentation (Supplementary §S4).

11.6 Pillar II/III Calibration Validity

Attack-graph topology sensitivity. The Bayesian model uses a stylised six-node, eight-edge attack graph. Comparing it against a seven-node extension (adding an HSM firmware-traversal node) shows that median system hazard falls by 9–11% under the more granular topology, with exceedance probability at the 1% threshold nearly unchanged (0.989 vs 0.981). The direction is favourable: the six-node graph *overstates* risk relative to more detailed architectures. The qualitative dependence-inflation findings are robust to topology variation within the range tested. Full six- versus seven-node sensitivity outputs for both architectures are reported in Supplementary §S13.

Robustness to attempt-rate assignment. A 1,000-permutation robustness check, randomly re-pairing attempt rates to scenarios with all other parameters fixed, yields a central access-pathway projection range of [9.9%, 21.2%] (95% central interval), with the paper’s primary access-pathway value ($\Lambda^{\text{acc}} = 16.8\%$) falling at approximately the 61st percentile of this distribution, modestly above the median and well within the central range. The headline Pillar II figure is not an artefact of an extreme or cherry-picked scenario-attempt-rate assignment.

Non-identifiability and severity. The Bayesian model is not fitted to an EA-specific likelihood. All inference is on prior predictive distributions informed by domain transfer. The model is therefore non-identified in the classical sense: different parameter combinations can produce identical output distributions. The parameter uncertainty decomposition (§9.9.1) confirms that even resolving every uncertain parameter would leave roughly 39% of $\text{Var}(Q_{10})$ for T-EA and 51% for OTT-EA as irreducible structural uncertainty. A further limitation shared across all four layers is that compromise is modelled as a binary event: compromise *severity* conditional on occurrence is not quantified. A session-level decrypt and a decade-spanning multi-million-user exposure are policy-distinct outcomes. A complete risk-benefit determination requires a severity distribution that the present analysis does not provide.

11.7 Statistical Methodology and Inferential Status

The framework’s quantitative outputs depend on statistical-modelling choices whose limitations affect how the numerical results should be read. Four specific caveats apply.

Layer IV is prior predictive, not posterior inference. As disclosed in §8, the reported 95% intervals are forward-sampled prior predictive intervals, not posterior credible intervals: no

EA-specific likelihood exists, so the intervals inherit their content from the analogue-calibrated priors. The framework supports posterior updating when EA-specific incident data eventually arrives.

Variance decomposition under correlated parameters. The EVPPI-style first-order Sobol indices reported in §9.9.1 (Figure 15) assume parameter independence. The decomposition further presumes the inputs have standard, mutually independent marginals; neither holds exactly here. The coupling ratio γ_X/γ has a support-constrained marginal ($\gamma_X/\gamma \geq 1$ by construction), and the modifier tiers δ_{EA} and δ_{target} co-vary across scenarios within architectural class. The reported indices should be interpreted as approximate variance contributions under the marginal-distribution assumption; total Sobol indices (which absorb interaction terms) and moment-independent importance measures [58] would refine the ordering but are unlikely to change the qualitative ranking, in which the three log-normal modifiers contribute comparable first-order shares and, for OTT-EA, the cross-cutting coupling ratio γ_X/γ contributes a smaller share.

Poisson rate models in Pillar I. The Pillar I rate estimates (Streams A, B, and C) use Poisson likelihoods with Garwood confidence intervals. Compromise events may depart from Poisson in two directions: clustering (Salt Typhoon involved multiple carriers within a coordinated campaign. The CA cohort includes coordinated multi-CA compromises) and temporal heterogeneity (rates may evolve as adversary capability and target attractiveness change). The implied rate intervals are therefore likely understated in width. The pooling of Streams A and B assumes rate homogeneity across the two cohorts. Neither departure changes the architectural ordering or the order-of-magnitude scale of the Pillar I anchors, but a careful statistician would refit Pillar I with overdispersed Poisson or negative-binomial likelihoods. The architecture-conditional sensitivity analysis (Table 6) provides the relevant range under realistic departures.

Informal model averaging. The four-layer framework is *informal* triangulation across analytical traditions rather than formal Bayesian model averaging. Each layer’s contribution is weighted by analytical role (consistency check, plausibility bounding, dependence-aware tail characterisation) rather than by explicit prior weight. The advantage is honesty about the limitations of each layer. The disadvantage is the absence of a single posterior weight that a formal Bayesian model average would provide. A formal Bayesian model average over the four layers would require specifying prior weights that are themselves calibration-conditional, a problem the multi-layer triangulation avoids by reporting each layer’s output explicitly. The synthesis hierarchy (§10) is the closest available substitute: findings on which the layers agree are stronger than findings supported by one layer alone.

11.8 Temporal Robustness, Inclusion Sensitivity, and Operator Heterogeneity

Three further robustness analyses are developed in full in Supplementary §S19. The headline results are as follows. *Stationarity*: a stylised 2% annual rate-growth model raises the 10-year cumulative from 53% to 56% from the Pillar II base, directionally adverse but modest, with full trajectories in Supplementary §S15. *Inclusion sensitivity*: the Tier-1-only Stream A cohort at the 10× premium projects to 4.5%, inside the low single-digit range, and removing Salt Typhoon entirely ($k = 5$) leaves the estimate materially unchanged (Supplementary §S19.1). *Joint denominator-and-inclusion corner*: the one-at-a-time sensitivities above can be stacked. Taking the risk-minimising corner simultaneously ($N_A = 75$ and strict Stream B inclusion) gives a pooled rate of $11/3,445 = 0.32\%$ per system-year (Garwood 95% CI [0.16%, 0.57%]), projecting to 3.2% annually at the 10× premium; the adverse corner ($N_A = 35$, full inclusion) gives 0.58%, projecting to 5.8%. The qualitative finding, an order-1% pre-premium anchor and a

low-single-digit projection, survives both corners jointly, falling below 1% only when the premium is simultaneously set at its $3\times$ floor. *Operator heterogeneity*: the Stream C cohort anchors the *unregulated* platform base rate; Stream B’s CCADB-governed Certificate Authorities are the closest regulated-operator analogue, and the roughly factor-two ratio between the two rates bounds the defensive uplift plausibly attributable to EA-style regulation, shifting the OTT-EA central projection from $\sim 3.9\%$ to $\sim 2.0\%$ at the most generous reading. A mandate spanning less well-resourced operators faces the converse adjustment, since systemic risk tracks the capability distribution across the mandated population rather than its best-resourced member.

11.9 Falsifiable Implications

Although no EA-specific incident record exists today, the framework is not insulated from evidence. It makes observable commitments, three of which are stated here so that future data can confirm or discredit the calibration. One framing point first: these commitments discipline the calibration layer, the analogue anchoring and the coupling mechanism, rather than the EA projection itself. The transfer step, the targeting premium, remains the least directly testable link, and the second commitment below is its only current handle.

First, a forward prediction from Stream B. At the fitted CA compromise rate, the Gamma–Poisson predictive distribution for the 2025–2030 window (approximately 780 CA-operator-years at current cohort size) has mean 3.5 disclosed incidents with 95% predictive interval $[0, 8]$. A zero-incident six-year run has predictive probability $\approx 4.9\%$ and would warrant downward revision of the centralised-operator anchor; a count above eight would warrant the converse. This commitment tests the analogue anchor directly; the transfer step is the second commitment’s business.

Second, an update rule for deployed systems. Any deployed T-EA-class system carries a stated first-decade compromise probability under each premium calibration. Clean operating history is informative against the premium: ten system-years without a Tier 1 incident carries a likelihood ratio of approximately 1.5 favouring the $3\times$ over the $10\times$ targeting premium at the pooled base rate, and the Layer IV machinery supports the corresponding posterior reweighting directly (§11.7). The premium calibration is not fixed doctrine. It is the parameter the framework most expects operational evidence to move.

Third, a distributional prediction from the coupling mechanism. The cross-cutting coupling prior implies that correlated-campaign periods should disproportionately produce cross-cutting ($X = Y$) incidents in future platform-incident records. A future extension of the Stream C cohort in which the cross-cutting fraction is statistically indistinguishable between campaign-intensive and quiet periods would contradict the γ_X mechanism on which the OTT-EA tail findings rest, independently of any rate calibration.

12 Policy Implications

This section translates the framework’s structural and interval-dominance findings into a basis for policy deliberation. Two qualifications apply throughout. *First*, the framework gives only the risk side of a two-sided risk–benefit analysis. Deciding whether EA deployment is net-beneficial also requires benefit-side estimates, such as law-enforcement effectiveness, counterfactual criminal activity in the absence of EA, and the share of cases in which EA access is decisive rather than incremental. Each of these is a substantial research problem in its own right and lies outside this paper’s scope. The risk findings developed here are inputs to a complete risk–benefit determination, not substitutes for one. *Second*, the framework is designed for comparative reasoning under deep uncertainty, not for predictive forecasting. The implications below are drawn from architecture-level and interval-dominance findings, not from calibrated point projections.

12.1 The Policy Question Reframed

The conventional policy framing asks “Is the security risk of exceptional access systems acceptably low?”. This framing assumes a definitive risk estimate that cannot be produced from currently available data. The framework does not offer one. A more productive reframing is this: *given the assumption-robust architectural findings, and given the calibration-conditional plausibility ranges for the central tendency of compromise risk, under what conditions would an EA mandate be net-beneficial?* The framework’s contribution to this reframed question has two parts. First, it constrains the risk-side inputs to a structured plausibility range. Second, it separates the comparative findings that are robust to calibration choice from the specific magnitudes that are not.

12.2 Interpreting the Probabilities

A statement such as “annual compromise probability of 4%” licenses less than it appears to, so this section is precise about what it does and does not support. It does not support a harm forecast: the framework quantifies the probability of the compromise event, not its consequence, and the same probability attaches to deployments of very different population exposure. It does not support cross-domain comparison against actuarial risks whose probabilities are measured rather than projected. What it does support is comparative and threshold reasoning: whether one architecture’s profile dominates another’s, whether cumulative exposure over a stated deployment horizon exceeds a stated acceptability threshold, and how far a conclusion survives calibration change. The cumulative-horizon and exceedance-probability framings (§9.6–9.7) are the forms in which these probabilities are usable for policy, and they are the forms this section relies on. Consequence modelling, which would convert them into expected-harm terms, is the natural companion analysis and is developed separately.

12.3 Risk Profile Summary

The architectural pattern visible across the table is consistent: the OTT-EA FH interval lies wholly below the T-EA FH interval, but the Bayesian upper-percentile figures are similar or higher for OTT-EA, reflecting the architectural divergence in tail behaviour established in Sections 9.4 and 8.

12.4 EA Adds a New Risk Surface

The analysis establishes that the EA mandate creates key-material exfiltration as a new outcome class: absent an EA key-management layer, there is no EA-specific key material to exfiltrate. However, the policy-relevant comparison is not between EA risk and zero baseline risk, but between EA risk and the risk that an operator already faces without EA. An operator without EA infrastructure already holds sensitive non-EA key material (TLS private keys, code-signing keys, device authentication keys) and faces non-zero key-compromise risk. The Pillar II model estimates the non-EA baseline access-pathway compromise rate at 12.3% annually, with the EA system adding 4.5 percentage points to access-pathway risk and 7.3% of EA-specific key-material exfiltration risk above the zero baseline.

The appropriate policy question is therefore: does adding EA infrastructure materially and irreversibly worsen an operator’s already non-trivial risk profile? The structural argument of Section 8 establishes that it does, for the reasons stated there (increased attack surface, elevated targeting, and key concentration). The quantitative question is how much worse, and under what architectural conditions the incremental risk can be minimised.

One decomposition, three expressions. The baseline comparison appears in three forms in this paper, and they express a single decomposition rather than three different claims. The

Table 17: Architecture-conditional summary risk profile. The three column families are different quantities and are not mutually bounding; §9.2 gives the usage rule and §10.1 the conditioning conventions. Cumulative rows assume stationarity (assessed in Supplementary §S19.1); 25-year Bayesian upper percentiles are stationarity extrapolations, not direct simulations. All values are probability-side quantities and exclude forward-secrecy degradation, for which they are lower bounds (§11.1).

Risk metric	Class	Channel-min.*	FH int.†	Bayes. 95th-pc.‡
Annual operational compromise	T-EA	~1.5%	[2.2%, 7.5%]	~17%
	OTT-EA	~1%	[1.1%, 4.0%]	~17%
10-year cumulative	T-EA	~14%	[20%, 54%]	~84%
	OTT-EA	~10%	[11%, 34%]	~94%
25-year cumulative¶	T-EA	~30%	[43%, 86%]	~99%
	OTT-EA	~22%	[24%, 64%]	~99%
Pr(annual risk > 1%)§	T-EA	—	—	0.6 to 0.99
	OTT-EA	—	—	0.5 to 0.91

* Channel-minimum heuristic: maximum single-channel rate under the four-channel decomposition (Section 7, conditional on channel exhaustiveness, which we do not prove). It bounds risk under a different decomposition from FH and the two are not directly comparable. The *model-consistent* lower bound on annual risk is the FH lower bound, not the channel-minimum heuristic.

† Pillar II Fréchet–Hoeffding interval, model-consistent under any dependence structure within the seven-scenario model.

‡ Bayesian 95th-percentile of q_1 under the primary prior calibration. Bayesian priors are calibrated to architecture-matched three-pillar empirical ranges, so the upper-percentile values capture the dependence-aware tail under the primary calibration rather than an independent estimate of it. Annual values from Table 10; 10-year cumulative values from the same simulation.

¶ The 25-year Bayesian column is $1 - (1 - q_1^{95})^{25}$ under stationarity rather than a direct simulation of Q_{25}^{95} ; under realistic positive year-to-year dependence the true Q_{25}^{95} would be lower.

§ Range across primary and conservative prior calibrations (Supplementary §S6).

Pillar I analogue rates measure the *baseline*: the compromise rate of high-value cryptographic infrastructure as a class, predominantly without EA-specific components. The EA *increment* above that baseline is carried entirely by the targeting premium and the Layer IV modifiers, which is why both are judgement-bounded and swept rather than asserted. And the $\delta = 1$ counterfactual of Proposition 1 is the model-internal expression of the same split: switching the modifiers off recovers the baseline parameterisation. The increment is therefore not double counted, with one bounded exception: the Stream A Tier 1 stratum includes EA-class systems, most directly Salt Typhoon, so a fraction of the increment is present in the base rate. The Salt-Typhoon-removal sensitivity (Supplementary §S19.1) bounds that leakage and shows the headline materially unchanged.

12.5 The Irreversibility Asymmetry

This subsection states a consequence-side observation. It sits outside the quantified probability framework and is made qualitatively, because any complete risk–benefit determination needs it. A structural feature of EA risk not captured by point estimates is the fundamental asymmetry between benefits and consequences. Benefits are *temporal and reversible*: EA interception benefits accrue during the operational period. If the mandate is withdrawn, future benefits cease. Breach consequences are *permanent and irreversible*: once key material is exfiltrated, all historical traffic protected under the compromised keys becomes retrospectively decryptable. This asymmetry means that standard expected-value maximisation, which treats gains and losses symmetrically, may systematically underweight the breach scenario. A complete risk-benefit analysis should account for this asymmetry explicitly. The framework provides the risk-side inputs but not the benefit-side estimates required to complete such an analysis.

12.6 Implications from the Bayesian Model

The Bayesian layer’s tail and dependence findings carry several implications. First, *uncertainty is irreducible in the current data environment*: any defensible quantitative estimate will carry credible intervals spanning at least one order of magnitude (the primary calibration’s 90% interval spans more than thirty-fold). Narrow point estimates presented without accompanying uncertainty characterisation should be viewed with scepticism. Second, *under risk-averse decision frameworks tail risk becomes a primary design criterion*: the heavy-tailed character of the model output, robust at policy-relevant calibrations, means EA system designs evaluated under maximin, CVaR-weighted, or other tail-sensitive criteria should be ranked primarily on their worst-case behaviour, with design features that reduce tail risk (rapid revocation, compartmentalised key custody, strong detection and response) preferred over features that reduce expected risk alone. Under risk-neutral expectation-based criteria, the central-tendency comparison dominates and the architectural ordering reverses (T-EA exceeds OTT-EA at the median). The choice of decision framework is itself a jurisdiction- and context-specific determination outside this paper’s scope. Third, *deployment horizon is a critical variable*: cumulative risk grows substantially with deployment horizon, so policy frameworks authorising permanent or indefinitely-renewable EA infrastructure without periodic reassessment may systematically underestimate long-run risk. Fourth, the exceedance probabilities reported in §9.7 are elevated across the low-threshold range under the primary prior calibration. For illustration, $\Pr(q_1 > 1\%) = 0.988$ for T-EA and 0.907 for OTT-EA. These place a heavy burden of evidence on benefit-side estimates if risk is to be deemed acceptable at whichever threshold a policy reader selects. The choice of acceptability threshold is itself a jurisdiction-specific determination outside this paper’s scope.

12.7 Architectural Alternatives: Threshold Schemes

Both quantified classes share the property that key material sits under unitary operator authority. A distributed threshold scheme, in which key material is split across N independent trustees with a t -of- N reconstruction requirement, removes that property, and an illustrative quantitative contrast (per-node rates borrowed from the Pillar III channel-aggregate projection, so order-of-magnitude only) shows why the design class matters: a 5-of-9 architecture at $p = 0.05$ per node yields a reconstruction probability of 3.3×10^{-5} under independence, rising to roughly 0.5% annually once a 10% common-mode failure fraction is included, still well below the centralised projections. The full contrast, including the historical lineage from Micali’s fair cryptosystems through verifiable partial key escrow, the (p, ρ) sensitivity table, and the four operational questions that govern deployability (trustee independence, collusion-resistant selection, cross-jurisdictional handling, and rotation cost), is developed in Supplementary §S16 and §S17. The risk reduction is unambiguous. The operational cost of obtaining it is the empirical question that follow-on engineering work would need to resolve.

12.8 Hybrid Client-Side Scanning Architectures

Hybrid client-side scanning (CSS), in which content matching runs on user devices using operator-distributed key material, is treated qualitatively: the Pillar I anchors contain no incidents architecturally matched to endpoint-distributed key compromise, so a calibrated CSS analysis would need an empirical anchor this paper does not have. The structural findings nonetheless transfer, and all of them run against CSS. The dominance result extends ($\delta \geq 1$ on structural grounds); the mobile platform itself becomes a new cross-cutting infrastructure, plausibly enlarging the cross-cutting fraction beyond OTT-EA’s; endpoint distribution adds compromise modes outside the scenario set; and the tail-inflation mechanism applies a fortiori. The precautionary reading is that CSS carries at least the OTT-EA risk profile with material additional endpoint-distribution risk. The full argument is in Supplementary §S18, and quantification to match the rigour applied to T-EA and OTT-EA is identified as a research priority.

12.9 Investment in Characterising Uncertainty

The parameter uncertainty decomposition (Section 9) identifies the system targeting intensity (δ_{target} , 25.0% of $\text{Var}(Q_{10})$ for T-EA), the EA-specific attack-surface modifier (δ_{EA} , 18.7%), and concentration (δ_{concen} , 17.7%) as the parameters whose empirical characterisation would most reduce output uncertainty. Regulatory frameworks requiring transparency about the scale of EA deployments (number of users covered, number of concurrent requests, and targeting intensity relative to non-EA infrastructure) would directly reduce uncertainty in these parameters and improve the basis for future risk assessments.

13 Conclusion

This paper has built a structured uncertainty framework for evaluating systemic compromise risk in lawful exceptional access architectures. The framework is offered as a decision-support tool, not as a forecast. No calibrated point projection of an annual EA compromise probability is possible from the available evidence, and the framework does not attempt one. What it does is separate, as transparently as the evidence allows, the architectural and structural findings that are robust to defensible calibration choices from the specific magnitudes that are not.

The findings themselves are stated in tiered form in the synthesis (§10, Table 1) and are not restated here. The structural ordering, the architectural divergence in distribution shape, and the interval-dominance brackets carry the policy weight, in that order of robustness.

The contribution of the paper is not a numerical estimate of EA compromise risk. No such estimate can be validated against the empirical record, so the framework offers none. The contribution is a structured basis for comparative reasoning. For any specific risk claim, the framework makes explicit which assumptions it depends on and which it does not. This is, in our view, the most that can responsibly be said about EA compromise risk from current evidence. It is also, plausibly, enough to inform deliberation in a domain where any quantitative claim must otherwise rest on undefended judgement. Key-material exfiltration is irreversible. Once keys leak, all previously protected communications become decryptable. This makes the risk side asymmetric in any complete risk–benefit determination. The asymmetry weighs particularly heavily for OTT-EA, where the exposed population is an order of magnitude larger ($O(10^8)$ to $O(10^9)$ users per major platform operator, against $O(10^7)$ to $O(10^8)$ for a national-scale carrier under T-EA); a consequence-side observation, stated qualitatively, since exposure magnitude lies outside the quantified framework. The highest-value empirical extension is already identified within the framework: per-incident latent-campaign assignment in the Stream C cohort would convert the coupling-ratio spread from a calibration choice into a measured quantity (§11.5), removing the last unmeasured parameter from the OTT-EA analysis and tightening the findings this paper can only bracket.

Acknowledgements

The author thanks colleagues at the University of Surrey for helpful discussions during the development of this work.

Funding

No external funding was received for this work.

Conflicts of Interest

The author declares no conflicts of interest.

Data Availability

All code and data required to reproduce the analyses in this paper are publicly archived at <https://doi.org/10.5281/zenodo.20554740>. The archive includes: (i) the full Stream A system-class list and the Stream C incident classification table with per-incident cross-cutting assignments; (ii) the Pillar II Monte Carlo engine (200,000 iterations); (iii) the Bayesian layer sampler (8,000 replicates for headline values, 4,000 for sensitivity analyses); (iv) the GPD tail-fitting and bootstrap-CI scripts; (v) the Pillar I empirical analyses for all three streams; (vi) the prior-sensitivity sweep and the γ_X/γ coupling sweep; (vii) the threshold-scheme reconstruction calculator; and (viii) all figure-generation code. The orchestrator script `run_all.py` reproduces every numerical claim and every figure in the paper end-to-end. All scripts use seed 2024 unless explicitly noted otherwise in the source.

Supplementary Material

Quantifying Compromise Risk in Exceptional Access Architectures Under Sparse and Indirect Evidence

This supplementary material accompanies the main paper above. References prefixed with S (e.g. Section S2, Table S3) refer to this supplement; all other references are to the main paper. All bibliographic citations are listed once at the end of this document.

This supplementary document accompanies the main paper. References to *Section*, *Table*, *Equation*, and *Figure* numbers prefixed with S (e.g. Section S2) refer to this supplement; all other references are to the main paper. Bibliographic citations are drawn from the shared `references.bib` file and listed at the end of this supplement.

S1 Notation, Conventions, and Reproducibility

S1.1 Notation summary

For convenience, the architectural and probabilistic notation used throughout is collected here. Subscripts T and OTT denote T-EA and OTT-EA configurations respectively where disambiguation is required.

q_1	Annual (year-1) compromise probability of the relevant operational outcome (key-material compromise for T-EA; joint key-and-data compromise for OTT-EA).
Q_T	Cumulative compromise probability over T years; $Q_T = 1 - \prod_{t=1}^T (1 - q_t)$ for the per-year sequence.
$\Lambda_T^k, \Lambda_{OTT}^{op}$	Pillar II key-compromise (T-EA) and operational-compromise (OTT-EA) annual probability under independence among scenarios.
$P_3 \cdot P_4$	OTT-EA segregation factor: probability that an attacker who has compromised key material can also reach the encrypted-data store before mitigation. Set at 0.30 (primary).
ξ_c	Per-channel cross-cutting fraction: proportion of channel- c compromises that traverse infrastructure shared between key custody and data planes. Used in OTT-EA Pillar III scaling.
ρ	Per-channel intra-channel dependence parameter (channel-specific bunching of compromises within a campaign).
$Z(t)$	Latent annual campaign intensity, $Z \sim \text{Gamma}(\alpha = 0.6, \beta = 2.0)$ in the primary calibration.
γ	T-EA campaign amplification factor; primary $\gamma = 1.0$.
γ_X	OTT-EA cross-cutting amplification factor; $\gamma_X/\gamma - 1 \sim \text{LogNormal}(0, \sigma^2)$ with $\sigma = 0.40$ (log-space spread), giving prior median $\gamma_X/\gamma = 2$ and constraint $\gamma_X/\gamma \geq 1$ by construction. See §8.5 of the main paper.
$\delta_{EA}, \delta_{\text{target}}, \delta_{\text{concen}}$	EA targeting/attractiveness/concentration multipliers, all ≥ 1 by stochastic-dominance constraint.

S1.2 Reproducibility

The Monte Carlo simulation used to produce all numerical results in Sections 9 and 10 of the main paper is implemented in Python 3.11 using NumPy ≥ 1.26 and SciPy ≥ 1.11 . The canonical implementation is `bayesian_mc_canonical.py`. The closed-form Pillar II/III verification is `p2_p3_closed_form.py`; figure generation is `make_figures.py`. All scripts are deposited alongside this paper and use a fixed seed of 2024 for reproducibility, with a four-seed stability check at

$\{2024, 3024, 4024, 5024\}$ reported in §8.7 of the main paper. Sample size is $R = 8,000$ replicates unless otherwise stated.

S2 Stream A: Government High-Security Systems Cohort

This section provides the incident-level classification and the denominator construction for the Stream A cohort; inclusion criteria and rate estimation are in §5.1 of the main paper.

S2.1 Denominator construction

The cohort is constructed from the union of: US National Security Systems governed under the Committee on National Security Systems framework, including separated cryptographic domains across classified networks, signals-intelligence infrastructure, and FIPS-certified high-assurance government systems [59–61] (~ 14); UK and other Five Eyes sovereign cryptographic infrastructures, including NCSC-governed UK systems and equivalent Canadian, Australian, and New Zealand national communications-security authorities [62] (~ 10); European Union sovereign cryptographic frameworks, including those administered by ANSSI (France), BSI (Germany), and the equivalent national authorities documented in the ENISA framework overview [63–65] (~ 12); NATO collective cryptographic infrastructure and national communications-security authorities listed in the NATO Information Assurance Product Catalogue [66] (~ 8); and CALEA-mandated [67] and ETSI TS 103 221 / 3GPP-equivalent lawful-intercept infrastructures at major Western fixed-line and mobile telecommunications carriers [68–70] (~ 6).

S2.2 Incident classification

Table S1: Stream A incidents (2011–2024) with tier classification. Tier 1 = direct EA architectural analogue: incidents that compromised either the cryptographic primitives of an EA-class system or its operational infrastructure, both of which constitute direct compromise of an EA architecture regardless of which component was breached. Tier 2 = compromise of cryptographic distribution or build-chain infrastructure serving the same high-assurance cohort but without direct compromise of EA-architecture systems themselves. Tier 3 = contextual analogue (insider exfiltration of cryptographic tooling, or compromise of equivalent-target-class government systems with mechanism not architecturally specific to EA).

Incident	Year	Tier	Justification
RSA SecurID [71]	2011	1	Theft of SecurID seed-record key material enabling subsequent compromise of defence-contractor authentication. Direct cryptographic key-material exfiltration.
Equation Group / Shadow Brokers [72]	2016	1	Exfiltration and public release of NSA cryptographic exploitation tooling including implants targeting cryptographic devices. Direct compromise of signals-intelligence cryptographic infrastructure.
Salt Typhoon [42]	2024	1	Adversarial compromise of US telecommunications carriers’ CALEA-mandated lawful-intercept infrastructure at the orchestration layer, accessing the government’s active wiretap target list. Direct compromise of T-EA-architecture exceptional-access infrastructure.
SolarWinds [73]	2020	2	Adversarial compromise of code-signing infrastructure enabling trust-chain abuse against federal cryptographic distribution. Targets the same high-assurance cohort via build-chain rather than direct key-material or infrastructure compromise.
CIA Vault 7 [74]	2017	3	Insider exfiltration of CIA cyber-tooling repository including cryptographic-implant frameworks. Contextual: tooling was exposed but the mechanism was personnel/insider rather than direct system compromise of EA-architecture infrastructure.
OPM [75]	2015	3	Exfiltration of US federal personnel records including security-clearance background-investigation data. Compromise of equivalent-target-class government system; mechanism not architecturally specific to EA.

S3 Stream B: Certificate Authority Cohort

This section documents the Stream B incident base in full, with the inclusion criteria applied and a sensitivity analysis under stricter inclusion. Stream B comprises 11 publicly documented Certificate Authority private-key compromise or operational-failure incidents over the period 2006–2024, drawn from the WebPKI/Mozilla incident archive and the Common CA Database (CCADB).

S3.1 Inclusion criteria

An incident is included in Stream B if and only if it satisfies all of the following:

1. **B1.** The affected entity was a publicly trusted Certificate Authority root or intermediate operator at the time of the incident, listed in at least one major root program (Mozilla, Microsoft, Apple, or Google).
2. **B2.** The incident involved either (a) compromise of private key material, (b) issuance of fraudulent certificates enabled by operational compromise, or (c) operational failure of sufficient severity to constitute a documented private-key trust breach (e.g., distrust events).
3. **B3.** The incident is publicly documented in primary sources: CA incident reports filed with the relevant root programs, formal distrust announcements, or peer-reviewed analyses.
4. **B4.** The incident occurred within the 2006–2024 observation window.

S3.2 Cohort definition and exposure

The relevant denominator is the count of publicly trusted CA operators weighted by years of operation in the window. We estimate $N_B = 130$ distinct CA operators (organisations operating root or major intermediate authorities) active during 2006–2024. Adjusting for windows of operation that did not span the full 19 years, the exposure is $E_B = 2,470$ CA-operator-years. This estimate aligns with historical CCADB cohort tracking.

S3.3 Incident list

Table S2: Stream B Certificate Authority private-key/operational compromise incidents, 2006–2024. Tier 1 = adversarial private-key compromise; Tier 2 = adversarial fraudulent issuance via operational compromise; Tier 3 = operational/governance failure leading to documented trust breach but without confirmed external adversarial compromise. The strict-inclusion sensitivity (Section S2.4) restricts to Tier 1 and Tier 2 only.

Year	CA	Description	Tier
2008	Comodo (RA)	Reseller-mediated mis-issuance ahead of formal policy hardening; documented in Mozilla incident archive	2
2011	Comodo	Comodogate: nine fraudulent certificates issued through compromised reseller (‘ComodoHacker’)	2
2011	DigiNotar	Full operational compromise; ~500 fraudulent certificates including *.google.com; subsequent distrust and corporate dissolution	1
2012	Trustwave	Issuance of an MITM-capable subordinate CA for an enterprise customer; subordinate revoked under pressure	3
2013	TURKTRUST	Mis-issuance of subordinate CA certificates that were used for MITM; documented as governance failure	3
2013	ANSSI/IGC-A	Mis-issuance of subordinate CA used for MITM on a French government network; subsequent constraint of ANSSI root	3
2015	CNNIC/MCS Holdings	Mis-issuance of subordinate that issued fraudulent Google certificates; CNNIC distrusted	2
2016	WoSign/StartCom	Backdating of certificates and other operational failures; eventual full distrust by major root programs	3
2017	Symantec (multiple)	Long-running mis-issuance pattern; phased distrust by Google, Mozilla, others, leading to managed transition	3
2018	Trustico/Comodo	Bulk private-key disclosure in resale dispute; mass revocation event	2
2024	Entrust	Multi-year compliance-failure pattern; distrust decisions by Chrome and Mozilla announced 2024	3

S3.4 Rate estimation and sensitivity

Pooled MLE rate. With $k = 11$ incidents in $E_B = 2,470$ CA-operator-years, the maximum-likelihood estimate is $\hat{\lambda}_B = 11/2,470 = 0.445\%$ per CA-operator-year. The Garwood exact 95% Poisson confidence interval is $[0.222\%, 0.797\%]$.

Strict-inclusion sensitivity (Tier 1 and Tier 2 only). Restricting to Tier 1 (1 incident: DigiNotar) and Tier 2 (4 incidents: Comodo 2008, Comodo 2011, CNNIC 2015, Trustico 2018) gives $k = 5$ in $E_B = 2,470$, yielding $\hat{\lambda}_B^{\text{strict}} = 0.202\%$ per CA-operator-year (Garwood 95%

CI [0.066%, 0.473%]). This strict criterion excludes incidents where the trust breach was a governance/operational failure rather than confirmed external adversarial compromise. The strict rate is therefore a conservative floor for the adversarial-compromise interpretation of Stream B.

Pooling with Stream A. Pooling Stream A ($k_A = 6$ in $E_A = 650$ system-years; pooled rate 0.92%/yr) and Stream B yields a combined rate of $(11 + 6)/(2,470 + 650) = 0.545\%/yr$ (the “two-stream pooled rate”). Under strict Stream B inclusion, the pooled rate is $(5 + 6)/3,120 = 0.353\%/yr$, projecting through a $10\times$ EA targeting premium to 3.5% rather than 5.45%.

Architectural interpretation. Stream B sits architecturally between T-EA and OTT-EA. CA private-key compromise is a centralised, single-operator-key event (T-EA-leaning), but the operational compromise patterns frequently traverse cross-cutting infrastructure (resellers, subordinate-issuance APIs) that resemble OTT-EA cross-cutting. Stream B is therefore reported as an architectural bridge rather than a primary anchor for either class.

S4 Stream C: Platform Incident Base and Operator Inventory

This section provides the classification table and per-incident documentation for the Stream C cohort (Table S3 below), and the operator inventory underpinning $N_C = 75$.

Table S3: Stream C platform-level key-or-data compromise incidents, 2018–2024. **Tier 0** restricts to incidents that are *architecturally unambiguous* OTT-EA analogues: the operator was a documented custodian of cryptographic key material or 2FA seeds at rest, and the compromise involved exfiltration of that material together with the segregated user data it protected. **Tier 1** adds incidents where the operator’s key-custody role required interpretation (directory-service infrastructure, supply-chain mediated key acquisition). **Tier 2** adds looser architectural fits where the OTT-EA mapping is partial. **Tier 3** is included for completeness. These incidents enter the sensitivity analyses (Section 5.3) but not the headline rate. Cloudflare 2023, classified *P/P/P/P*, is documented in the near-miss appendix (Supplementary §S4.2) and is excluded from the cohort on the basis that no customer data or service keys were accessed. Snowflake 2024 and AT&T 2024 are documented as a single combined entry, since the AT&T compromise was a downstream consequence of the Snowflake-customer credential abuse rather than an architecturally independent event. Columns: K = key material obtained; D = encrypted user data obtained; J = joint key-and-data compromise operationally sufficient; X = cross-cutting attack path traversing shared infrastructure. Y = yes (documented), P = partial or interpretive, N = no.

Year	Operator	Incident	Tier	K	D	J	X
2022	LastPass	Two-stage vault + source code [76]	0	Y	Y	Y	N
2022	Twilio	Phishing-led → Authy 2FA seeds [77]	0	Y	Y	Y	Y
2023	Microsoft	Storm-0558 consumer signing key [78]	0	Y	Y	Y	Y
2021	Codecov	Bash uploader supply-chain [79]	1	Y	Y	Y	Y
2023	JumpCloud	DPRK APT directory access [80]	1	Y	Y	Y	Y
2021	Microsoft	Exchange ProxyLogon (HAFNIUM) [81]	2	P	Y	P	Y
2022	Okta	Sitel/Lapsus\$ support engineer [82]	2	P	Y	P	N
2022	GoDaddy	Source code + managed hosting [83]	2	P	Y	P	N
2023	Okta	HAR file → 134 customers [84]	2	Y	P	P	N
2023	CircleCI	Stolen engineer credentials [85]	2	Y	P	P	N
2023	MOVEit	CL0P SQL injection, ~2,000 orgs [86]	2	Y	Y	Y	Y
2024	Microsoft	Midnight Blizzard source code/emails [87]	2	P	Y	P	Y
2022	Slack	Stolen tokens, source code [88]	3	Y	P	N	N
2024	Snowflake/AT&T	Customer credential abuse, AT&T downstream [89, 90]	3	Y	Y	Y	N

S4.1 Per-incident documentation

The classification dimensions are: K = key material obtained; D = encrypted user data obtained; J = joint key-and-data compromise operationally sufficient (the strict OTT-EA analogue); X = cross-cutting attack path traversing infrastructure shared between key and data planes. Y/P/N denote yes (documented), partial/interpretive, no. The tier classification reflects strength of architectural fit to the OTT-EA reference class: **Tier 0** requires the operator to be a documented custodian of cryptographic key material or 2FA seeds at rest, with the compromise involving exfiltration of that material together with the segregated user data it protected; **Tier 1** relaxes the custody requirement to interpretive cases (directory-service infrastructure, supply-chain mediated key acquisition); **Tier 2** permits looser architectural fits where the OTT-EA mapping is partial; **Tier 3** is included only for sensitivity. The Cloudflare 2023 incident, classified $P/P/P/P$, is documented in the near-miss appendix (§S4.2) and is not counted in any rate calculation. The Snowflake 2024 and AT&T 2024 incidents are treated as a single entry, since the AT&T compromise was a downstream consequence of the Snowflake-customer credential abuse and the two are not architecturally independent events.

Tier 0 incidents (architecturally unambiguous OTT-EA analogues)

2022 – LastPass (Tier 0; $K=Y$, $D=Y$, $J=Y$, $X=N$). Two-stage attack: source-code theft followed by exfiltration of encrypted vault data. Key custody (master-password-derived keys held client-side) and encrypted data (vaults) compromised together. $X=N$ because the operator-side architecture did not introduce cross-cutting compromise paths beyond the operator boundary.

2022 – Twilio (Tier 0; $K=Y$, $D=Y$, $J=Y$, $X=Y$). Phishing-led credential compromise leading to access to the Authy 2FA backend. Authentication seeds (cryptographic key material in the strict sense) obtained; downstream impact across multiple customer dependencies including Cloudflare. $X=Y$ because Authy is cross-cutting to many other operator infrastructures.

2023 – Microsoft Storm-0558 (Tier 0; $K=Y$, $D=Y$, $J=Y$, $X=Y$). Compromise of a consumer signing key enabling forged tokens for enterprise email. Both key custody (the consumer signing key) and encrypted/authenticated data (token-validated email) compromised in the strict joint sense. $X=Y$ because the consumer key reached the enterprise validation path, the canonical cross-cutting failure mode. This is the closest historical analogue to the OTT-EA threat model.

Tier 1 incidents (interpretive key custody)

2021 – Codecov (Tier 1; $K=Y$, $D=Y$, $J=Y$, $X=Y$). Bash uploader script tampered, exfiltrating environment-variable credentials of Codecov customers. Both the Codecov advisory and CISA Alert AA21-116A confirm credential and key-material compromise across the customer base. The supply-chain pathway through customer CI infrastructure is the cross-cutting compromise pattern X . The operator’s role as key custodian is supply-chain-mediated rather than direct, and the architectural mapping to OTT-EA key custody requires interpretation, so Tier 1 is the appropriate tier.

2023 – JumpCloud (Tier 1; $K=Y$, $D=Y$, $J=Y$, $X=Y$). DPRK APT compromise of JumpCloud directory-service infrastructure providing cryptographic control over downstream cryptocurrency-customer environments. Joint key-and-data compromise via the directory-service infrastructure, with $X=Y$ reflecting cross-cutting reach into customer environments. The $K=Y$ classification rests on directory-service admin access being equivalent to key-custody

compromise for downstream purposes. The architectural mapping requires interpretation, so Tier 1 is appropriate rather than Tier 0.

Tier 2 incidents (looser architectural fit)

2021 – Microsoft Exchange ProxyLogon (Tier 2; $K=P$, $D=Y$, $J=P$, $X=Y$). Mass exploitation of CVE-2021-26855 et al. on on-premises Exchange. D is direct (mailbox content). K is partial: web shells provided arbitrary code execution including key-material access where it existed; not all victims experienced key compromise. X is the shared Exchange platform reaching multiple key-management endpoints.

2022 – Okta (Sitel/Lapsus\$) (Tier 2; $K=P$, $D=Y$, $J=P$, $X=N$). Compromise of a third-party support engineer endpoint at Sitel, providing constrained access to Okta administrative tooling for ~ 25 minutes. D documented (customer data viewable). K partial (limited session-token-equivalent access; no cryptographic root key compromise).

2022 – GoDaddy (Tier 2; $K=P$, $D=Y$, $J=P$, $X=N$). Multi-year intrusion into managed-hosting environment with source-code theft and customer-data access. Reported in 2023 SEC 8-K filing. The K classification is partial because the cryptographic mapping to OTT-EA key custody is thin; included as Tier 2 for completeness.

2023 – Okta (HAR file) (Tier 2; $K=Y$, $D=P$, $J=P$, $X=N$). HAR file containing session tokens leaked through the support portal, affecting 134 customers. $K=Y$ for session-token-equivalent authentication material; D partial (limited customer-data exposure through session-token misuse).

2023 – CircleCI (Tier 2; $K=Y$, $D=P$, $J=P$, $X=N$). Stolen engineer credentials with malware-mediated access to production secrets. $K=Y$ (customer secrets/tokens); D partial.

2023 – MOVEit Transfer (CL0P) (Tier 2; $K=Y$, $D=Y$, $J=Y$, $X=Y$). SQL injection in the MOVEit Transfer file-transfer product, exploited by CL0P against $\sim 2,000$ organisations. $J=Y$ because individual customer instances suffered joint key/data exposure. $X=Y$ at the ecosystem level: the MOVEit platform was cross-cutting to many customer key/data planes simultaneously. Tier 2 rather than Tier 0 because MOVEit is a managed file-transfer service rather than a dedicated key custodian. The architectural mapping to OTT-EA is partial.

2024 – Microsoft Midnight Blizzard (Tier 2; $K=P$, $D=Y$, $J=P$, $X=Y$). SVR-attributed compromise of Microsoft corporate email and source-code repositories. K partial (D confirmed; key-material access debated in public reporting). $X=Y$ because the corporate infrastructure reached source-code repositories with downstream signing-key implications. Classified as Tier 2: the $J=P$ classification (partial joint compromise) is incompatible with the architectural-strength criterion for Tier 1, which requires documented joint key-and-data compromise.

Tier 3 incidents (sensitivity only)

2022 – Slack (Tier 3; $K=Y$, $D=P$, $J=N$, $X=N$). Stolen tokens and source code; documented key-material exposure but no joint customer-data compromise. Included as a sensitivity analogue at Tier 3.

2024 – Snowflake/AT&T (Tier 3; $K=Y$, $D=Y$, $J=Y$, $X=N$). Customer-credential abuse against ~ 165 Snowflake customer tenants (mediated by stolen credentials, often without MFA). The 2024 AT&T call-records breach affecting 110 million customers was a downstream consequence of the same Snowflake-customer credential compromise and is therefore treated as part of this single entry rather than counted as architecturally independent. $J=Y$ at the per-tenant level. $X=N$ because the operator infrastructure (Snowflake itself) was not compromised; included at Tier 3 as a customer-environment joint- compromise pattern rather than a Snowflake-key-custody compromise.

S4.2 Near-miss exclusion: Cloudflare 2023

The following incident was considered for inclusion in the Stream C cohort but is documented here as a near-miss rather than counted in any rate calculation, on the basis that $D2$ (compromise involved unauthorised access to or exfiltration from key custody, identity, or encrypted-data-handling functions) is not satisfied in a defensible operational sense.

2023 – Cloudflare (Atlassian-mediated APT; $K=P$, $D=P$, $J=P$, $X=P$). A Russian-state-actor lateral movement from a previously-compromised Atlassian instance into Cloudflare engineering systems. Cloudflare’s public incident report indicates the activity was detected within hours, no customer data was accessed, and no service keys were compromised. The incident demonstrates that cross-cutting infrastructure compromise can route an APT toward key-custody assets, but in this case the compromise did not *traverse* that boundary. The $P/P/P/P$ classification reflects this: each dimension shows partial-or-interpretive evidence of the relevant compromise pathway, but no dimension is documented at Y . Including it as $P/P/P/P$ in the rate calculation would assign positive analogical weight to an incident that did not actually involve operational compromise of the relevant assets. We exclude it instead.

A defensible alternative treatment would assign near-misses an analogical-fit weight strictly between zero and one and propagate the weighted count into the rate estimator. We do not adopt this approach because the weight assignment is itself contestable and a weight-zero treatment is the conservative choice for a rate-estimation purpose: it biases the headline rate downward.

S4.3 Operator inventory ($N_C = 75$)

The denominator estimate $N_C = 75$ aggregates the following operator classes active during 2018–2024 and meeting the $D1$ inclusion criterion (major platform providers holding cryptographic key material, authentication infrastructure, or encrypted user data at scale):

- Top-tier cloud infrastructure providers (~ 8): AWS, Azure, GCP, Oracle Cloud, IBM Cloud, Alibaba Cloud, OCI, plus regional tier-1.
- Major SaaS and productivity platforms (~ 15): Microsoft 365, Google Workspace, Salesforce, ServiceNow, Workday, SAP, Oracle Cloud Apps, Atlassian, Zoom, Box, Dropbox, Adobe, Notion, Asana, Monday.
- Identity and authentication providers (~ 8): Okta, Microsoft Entra, Auth0 (now Okta), Ping, ForgeRock (now Ping), OneLogin, Duo (Cisco), JumpCloud.
- Password and secret managers (~ 6): 1Password, LastPass, Bitwarden, Dashlane, Keeper, RoboForm.
- Code hosting and CI/CD platforms (~ 6): GitHub, GitLab, Bitbucket, CircleCI, Jenkins-Cloud, Travis CI.
- Content delivery and edge providers (~ 5): Cloudflare, Fastly, Akamai, Vercel, Netlify.
- Messaging and communications platforms (~ 8): WhatsApp, iMessage/Apple, Signal, Telegram, Wire, Threema, Slack, Microsoft Teams.

- Other globally significant platform operators (~ 19): including major email providers, file-transfer specialists (MOVEit, GoAnywhere), data warehouses (Snowflake, Databricks), payment platforms, regional incumbents, major DNS providers, etc.

The total is ≈ 75 . Sensitivity is reported across $N_C \in \{50, 100\}$ in §5.3 of the main paper.

S4.4 Stratified rate calculation

With $N_C = 75$, $T = 7$ years, $E_C = 525$ operator-years, and 14 included incidents (Cloudflare is classified in the near-miss appendix §S4.2. The 2024 Snowflake and AT&T events are treated as one incident):

Stratification	k	$\hat{\lambda}_C$	95% CI
<i>Architectural-fit stratification</i>			
Tier 0 only (gold standard)	3	0.57%/yr	[0.12%, 1.67%]
Tier 0 + Tier 1	5	0.95%/yr	[0.31%, 2.22%]
Tier 0 + Tier 1 + Tier 2	12	2.29%/yr	[1.18%, 4.00%]
All tiers (incl. Tier 3)	14	2.67%/yr	[1.46%, 4.48%]
<i>Joint-compromise stratification (J)</i>			
$J = Y$ strict, all tiers	7	1.33%/yr	[0.54%, 2.75%]
$J = Y$ strict, Tier 0+1 (headline)	5	0.95%/yr	[0.31%, 2.22%]
$J \in \{Y, P\}$ inclusive	13	2.48%/yr	[1.32%, 4.23%]
<i>Robustness checks</i>			
$J = Y$, all tiers, no Microsoft	6	1.14%/yr	[0.42%, 2.49%]
$J = Y$, Tier 0+1, no Microsoft	4	0.76%/yr	[0.21%, 1.95%]
$J = Y$ all tiers, $N_C = 50$	7	2.00%/yr	[0.80%, 4.12%]
$J = Y$ all tiers, $N_C = 100$	7	1.00%/yr	[0.40%, 2.06%]

The headline anchor cited in the main paper (Section 5.3) is the architectural-fit-restricted strict-joint rate of 0.95%/yr (Tier 0+1, $J = Y$, $k = 5$): incidents where the operator’s key-custody role is documented (Tier 0 or 1) and the compromise involved joint key-and-data acquisition at a level operationally sufficient to map onto OTT-EA decryption. The Tier 0 row provides a very-conservative lower bracket of 0.57%/yr; the all-tiers $J = Y$ row gives 1.33%/yr as a defensible upper bracket. The Garwood exact 95% Poisson interval bounds the empirical content of Stream C at each stratification level.

S5 Architecture-Conditional Structural Adjustment Dimensions

When transferring rate estimates from non-EA analogue populations (Streams A, B, C) to EA populations, structural adjustments are required on dimensions where the analogue and target populations differ. This section enumerates the seven adjustment dimensions used in the paper’s domain-transfer arguments, classified by whether they are (a) structurally identical between architectures (apply to both T-EA and OTT-EA), (b) architecture-conditional (apply differently), or (c) class-specific.

S5.1 The seven adjustment dimensions

D1. Targeting intensity. The EA-target population attracts elevated nation-state and organised-crime targeting relative to non-EA analogues. Multiplier: $\delta_{\text{target}} \in [3, 10]$; primary 5. *Identical across architectures* (the targeting-intensity argument applies equally to centralised key custody and platform-mediated key custody).

D2. EA-specific attack-surface. EA introduces interfaces (request validation, audit logs, key-management APIs) that do not exist in non-EA analogues. Multiplier: $\delta_{\text{EA}} \in [1, 3]$; primary

1.5. *Architecture-conditional*: the surface is concentrated at the request endpoint for T-EA; for OTT-EA, it is split between operator endpoint and (where present) hybrid endpoint-distribution mechanisms (CSS scenarios). §S18 discusses the CSS-specific extension.

D3. Key-material concentration. EA increases the concentration of high-value key material at single targets. Multiplier: $\delta_{\text{concen}} \in [1, 4]$; primary 1.5. *Architecture-conditional*: full concentration for T-EA (single operator holds keys for all jurisdictional users); reduced concentration for OTT-EA (key custody at operator, but data-plane segregation reduces the joint-compromise concentration by $P_3 \cdot P_4 = 0.30$).

D4. Operator best-practice baseline. Streams A, B, C are populated by operators with mature security practice. The EA-target population may include less well-resourced operators. *Identical across architectures*: this is the weakest-operator problem (§S19.2) and applies symmetrically.

D5. Detection and response capability. The detection envelope of EA-instrumented systems is open empirically. *Architecture-conditional*: T-EA systems can in principle detect lawful-intercept abuse via internal audit; OTT-EA systems may have weaker visibility into key-material exfiltration than into data-plane compromise.

D6. Cross-cutting infrastructure exposure. The proportion of campaigns traversing infrastructure shared between key and data planes. Parameter: ξ_c (channel-specific). *Class-specific to OTT-EA*: not applicable in the T-EA configuration, where keys and data are co-located by design.

D7. Segregation gain. The factor by which architectural separation between key custody and data plane reduces joint-compromise probability. Parameter: $P_3 \cdot P_4 = 0.30$ (primary). *Class-specific to OTT-EA*: by construction, $P_3 \cdot P_4 = 1$ (no segregation) for T-EA.

S5.2 Composition under independence

Under independence among adjustment dimensions, the composite T-EA multiplier is

$$M_T = \delta_{\text{target}} \cdot \delta_{\text{EA}} \cdot \delta_{\text{concen}} \in [3, 120], \quad \text{primary value } 5 \cdot 1.5 \cdot 1.5 = 11.25,$$

and the composite OTT-EA multiplier is

$$M_{\text{OTT}} = \delta_{\text{target}} \cdot \delta_{\text{EA}} \cdot \delta_{\text{concen}} \cdot [\xi + (1 - \xi) P_3 P_4] \in [0.9, 103], \quad \text{primary } 11.25 \cdot [0.4 + 0.6 \cdot 0.3] \approx 6.5,$$

where ξ is the average cross-cutting fraction (primary $\xi \approx 0.4$) and the bracketed operational factor is the same $\xi + (1 - \xi) P_3 P_4$ form used in Pillars II and III of the main paper. The ratio $M_{\text{OTT}}/M_T = 0.58$ at primary parameter values is consistent with the architectural ratio of 0.5–0.6 recovered across the three pillars.

S5.3 Sensitivity to dimension-by-dimension perturbation

Dimension	T-EA effect	OTT-EA effect
$\delta_{\text{target}} \downarrow 3$	−40% on M_T	−40% on M_{OTT}
$\delta_{\text{target}} \uparrow 10$	+100%	+100%
$\delta_{\text{EA}} \uparrow 3$	+100%	+100%
$\delta_{\text{concen}} \uparrow 4$	+167%	+167%
$P_3 \cdot P_4 \downarrow 0.10$	no effect	−21%
$P_3 \cdot P_4 \uparrow 0.50$	no effect	+21%
$\xi \downarrow 0.20$	no effect	−24%
$\xi \uparrow 0.60$	no effect	+24%

Among the OTT-EA-specific parameters the multiplier is comparably sensitive to ξ and $P_3 \cdot P_4$ ($\approx \pm 21$ –24% across their ranges), identifying empirical characterisation of the segregation chain (both the cross-cutting fraction and the segregation factor) as the highest-priority research target for narrowing OTT-EA risk uncertainty.

S5.4 Treatment of dependence in the dimension transfer

The composition above assumes independence among dimensions. If δ_{target} and δ_{EA} are positively correlated (high-targeting environments also produce more EA-specific infrastructure), the composite multiplier is larger than the product of marginals. Under perfectly correlated $(\delta_{\text{target}}, \delta_{\text{EA}})$ within their respective ranges, the upper-bound multiplier is:

$$M_{\text{T}}^{\text{dep}} = \mathbb{E}[\delta_{\text{target}} \cdot \delta_{\text{EA}}] \cdot \delta_{\text{concen}} = (\mathbb{E}[\delta_{\text{target}}] \mathbb{E}[\delta_{\text{EA}}] + \text{Cov}(\delta_{\text{target}}, \delta_{\text{EA}})) \delta_{\text{concen}} \leq \delta_{\text{target}}^{\text{max}} \cdot \delta_{\text{EA}}^{\text{max}} \cdot \delta_{\text{concen}}.$$

The Bayesian model in §8 of the main paper captures this dependence through joint priors and the parameter-uncertainty decomposition in §9.9 of the main paper.

S6 Prior Sensitivity for Exceedance Probabilities

The exceedance probability findings of the main paper (§9.7 of the main paper) are conditional on the primary prior calibrations adopted in §8 of the main paper. To assess robustness we re-ran the simulation under three prior calibrations spanning the plausible range of analogical evidence for each architectural class: a *conservative* prior corresponding to an analogue population performing substantially better than the relevant historical record (Stream A for T-EA, Stream C for OTT-EA); the *primary* prior used throughout the main paper; and a *pessimistic* prior corresponding to the relevant population average rate. Reproducibility: `prior_sensitivity.py` in the companion code, with multi-parameter calibration shifts as documented in the script header.

Table S4 reports the architecture-conditional exceedance probabilities under each calibration; all other model parameters are held at primary values.

Table S4: Architecture-conditional exceedance-probability sensitivity to prior calibration. All runs share model structure within each architectural class; only the prior hyperparameters differ. The “primary” row matches the full-dependence column of Table 15 of the main paper.

Calibration	T-EA			OTT-EA		
	median	$\Pr(q_1 > 0.5\%)$	$\Pr(q_1 > 1\%)$	median	$\Pr(q_1 > 0.5\%)$	$\Pr(q_1 > 1\%)$
Pessimistic	12.8%	1.000	1.000	9.8%	1.000	1.000
Primary	4.0%	1.000	0.988	2.6%	0.994	0.907
Conservative	1.2%	0.911	0.605	0.9%	0.747	0.460

Three observations.

(i) *Magnitude is prior-conditional.* Under the conservative prior the exceedance probability at the 1% threshold drops materially: T-EA from 0.988 to 0.605; OTT-EA from 0.907 to 0.460. Under the pessimistic prior the same probability rises to saturation (1.000 for both architectures). The headline exceedance findings are therefore not sound across the full defensible prior range in either architectural class.

(ii) *Direction is robust.* The architectural ordering (T-EA risk at least as high as OTT-EA) is preserved across all three calibrations: T-EA medians exceed OTT-EA medians in every case, and T-EA exceedance probabilities are at least as large as OTT-EA’s, strictly so except under the pessimistic prior, where both architectures saturate. This ordering is downstream of the segregation parameter and the cross-cutting fraction calibration; it is structural rather than calibration-conditional.

(iii) *The conservative-prior policy posture is qualitatively distinct.* At the conservative prior the OTT-EA case crosses below $\Pr(q_1 > 1\%) = 0.5$, supporting a characterisation of “probably below 1% annually”, a policy posture qualitatively different from that under the primary calibration. The T-EA conservative figure remains above 0.5, supporting the weaker

characterisation “more likely than not above 1% annually”. Policy readers should therefore treat the exceedance findings as ranging from “saturated” (pessimistic) to “probably below threshold for OTT-EA, more likely than not above for T-EA” (conservative), with the primary calibration sitting nearer the pessimistic end of that range.

S7 Edge Log-Hazard Specification

The Bayesian edge-hazard priors of §8.3 of the main paper are specified on a log scale. The location parameters μ_{ij}^A are derived via architecture-conditional domain transfer (§S5, this supplement), and the prior widths σ_{ij}^A are calibrated to reflect both within-class operator heterogeneity and analogical transfer uncertainty.

Table S5: Indicative edge log-hazard prior locations and widths under the primary calibration, by architectural class and adversary tier. Locations μ_{ij} are expressed in log-events-per-year units; widths σ_{ij} are in the same units. The ~ 3 log-unit spread between adversary tiers referenced in §8.2.3 of the main paper is visible in the opportunistic-vs-APT column gap; tier-specific edges within each architectural class share a common width.

Edge class	T-EA		OTT-EA	
	μ_{ij}	σ_{ij}	μ_{ij}	σ_{ij}
Opportunistic, perimeter	−6.5	1.5	−6.0	1.5
Opportunistic, key-vault	−7.5	1.5	−7.5	1.5
APT, perimeter	−4.5	1.5	−4.2	1.5
APT, key-vault	−5.0	1.5	−5.0	1.5
APT, cross-cutting (OTT-only)	—	—	−4.5	1.5

The cross-tier spread of approximately three log units between opportunistic and APT edges supports the weakest-link approximation of Equation 18 of the main paper: when adversary tiers differ by this magnitude in log-hazard, the minimum-rate substitute for an exact inclusion–exclusion expansion is accurate to within a few percent on per-replicate compromise probabilities. The topology-sensitivity analysis of §11.6 of the main paper bounds the practical consequence of this approximation at approximately $\pm 10\%$ on median estimates.

S8 OTT-EA Parameter Uncertainty Decomposition

The OTT-EA EVPPI-style variance decomposition referenced in the caption of Figure 15 of the main paper is reported here in tabular form for reproducibility. The first-order Sobol indices below were computed at $R = 2,000$ pick-freeze replicates per parameter at seed 2024 over the OTT-EA configuration. The decomposition is taken over the parameters the canonical engine treats as uncertain, drawn from the canonical priors: the three log-normal modifiers, together with the cross-cutting coupling ratio γ_X/γ , which is OTT-EA-specific. Parameters held fixed in the canonical model (γ , $P_3 \cdot P_4$, σ_λ , and the per-channel ξ and ρ arrays) contribute no output variance and are not decomposed; their effect, together with parameter interactions and the model’s internal channel-noise stochasticity, is captured in the residual.

The OTT-EA first-order reducible variance ($\sim 49\%$ across the four uncertain parameters) is below the T-EA figure ($\sim 61\%$), reflecting the larger interaction structure and internal stochasticity introduced by cross-cutting coupling: the OTT-EA residual ($\sim 51\%$) is the single largest component of $\text{Var}(Q_{10}^{\text{OTT}})$. The corresponding tornado plot referenced in the main paper as the OTT-EA companion to Figure 14 is generated by the companion script `bayesian_tornado.py`.

Table S6: First-order variance contribution of each uncertain parameter to $\text{Var}(Q_{10}^{\text{OTT}})$. The OTT-EA-specific cross-cutting coupling ratio γ_X/γ carries a modest first-order index. The structural constraint $\gamma_X/\gamma \geq 1$ imposed by the prior limits the residual uncertainty available to resolve. The residual is the largest single component, reflecting parameter interactions and internal stochasticity.

Parameter	First-order Sobol index
EA attack-surface modifier ($\delta_{\text{EA}}^{\text{OTT}}$)	14.8%
Concentration ($\delta_{\text{concen}}^{\text{OTT}}$)	13.9%
System targeting intensity ($\delta_{\text{target}}^{\text{OTT}}$)	12.0%
Cross-cutting coupling ratio (γ_X/γ)	8.6%
Sum (first-order)	49.3%
Residual (interactions + internal stochasticity)	50.7%

S9 Pillar II Monte Carlo: Prior Specification

The system-level Pillar II projections of Section 6.4 of the main paper are reported as central point projections: the independence aggregation $\Lambda^{\text{key}} = 1 - \prod_i (1 - \Pr(C_i^{\text{key}}))$ evaluated at the central per-scenario rates. The accompanying Monte Carlo ($N = 200,000$ iterations; `pillar2_mc.py`) characterises the dispersion induced by parameter uncertainty around that central projection. It is a reduced-form propagation: rather than re-running the per-scenario tier-mixing chain, it perturbs the central per-scenario rates and the shared aggregation parameters directly, drawing

- the global APT-tier mixing weight $w_{\text{APT}} \sim \text{Beta}(3, 7)$ (mean 0.30);
- the APT-tier exploitation uplift as a log-normal multiplier with median $2\times$ and log-scale spread $\sigma = 0.30$;
- each per-scenario base rate as a log-normal with median fixed at its central value and the same log-scale spread $\sigma = 0.30$;
- the joint segregation factor $P_3 \cdot P_4 \sim \text{Beta}(3, 7)$ (mean 0.30).

The per-scenario cross-cutting fractions ξ_i are held at their central values.

A log-scale spread of $\sigma = 0.30$ corresponds to a one-standard-deviation multiplicative band of approximately $0.74\times$ to $1.35\times$, and a 95% band of approximately $0.56\times$ to $1.80\times$, about each median. This is a moderate prior width for an empirically uncertain rate, and it contains the $1.2\times$ – $3.0\times$ APT-uplift sensitivity range adopted in the main paper. Because the log-normal priors are centred at the central rates (their median) and the Beta priors at the central mixing values (their mean), the Monte Carlo median reproduces the closed-form central aggregation to within rounding: $\Lambda^{\text{key}} = 7.4\%$ (Monte Carlo median) against 7.3% (closed form), and $\Lambda^{\text{op,OTT}} = 4.0\%$ against 3.9% . The reported central projections are therefore governed by the central parameter values and not by the prior width σ , which affects only the spread of the simulated distribution. That spread is reported through the sensitivity analyses (the OTT-EA grid of Section S10 and the Pillar II sensitivity analysis in the main paper) and is not quoted as a confidence interval on the central projection.

S10 Pillar II OTT-EA Sensitivity Grid

The OTT-EA Pillar II projection is sensitive to two architectural parameters with no T-EA analogue: the segregation factor $P_3 \cdot P_4$ and a global multiplier m_ξ on the central ξ_i values from Table 7 of the main paper. The full joint grid is reported here.

The OTT-EA Pillar II projection spans 2.0–6.0% across the full joint sensitivity range. The lower portion corresponds to architectures with strong segregation, low cross-cutting risk, and effective multi-stage detection (the bottom-left of the grid). The upper portion corresponds to architectures where cross-cutting access is prevalent and detection is weak. The interval $[3.5\%, 4.3\%]$ obtained by varying $m_\xi \in [0.75, 1.25]$ at the central $P_3 \cdot P_4$ value is the defensible central range conditional on the calibration.

Table S7: OTT-EA Pillar II central operational compromise projection $\Lambda_{\text{central}}^{\text{op,OTT}}$ across the joint $(P_3 \cdot P_4, m_\xi)$ sensitivity grid. The central parameterisation ($P_3 \cdot P_4 = 0.30$, $m_\xi = 1.0$) gives the central value of 3.9%. Each cell: independence-based closed-form projection.

	$m_\xi = 0.5$	$m_\xi = 0.75$	$m_\xi = 1.0$	$m_\xi = 1.5$
$P_3 \cdot P_4 = 0.12$	2.0%	2.5%	3.0%	4.1%
$P_3 \cdot P_4 = 0.30$	3.1%	3.5%	3.9%	4.7%
$P_3 \cdot P_4 = 0.50$	4.3%	4.6%	4.9%	5.5%
$P_3 \cdot P_4 = 0.64$	5.1%	5.3%	5.6%	6.0%

S11 Pillar III OTT-EA Sensitivity Grid

The OTT-EA channel-aggregate (Pillar III) projection is sensitive to the same two clusters of parameters as Pillar II: the segregation factor $P_3 \cdot P_4$ and the per-channel cross-cutting fractions ξ_c (multiplied by a global m_ξ). The grid analogous to §S10 but applied to the Pillar III decomposition is:

Table S8: OTT-EA Pillar III channel-aggregate projection $P_{\text{ref}}^{\text{OTT}}$ across the joint $(P_3 \cdot P_4, m_\xi)$ sensitivity grid, where m_ξ multiplies the central ξ_c values from Table 8 of the main paper. The central parameterisation gives 3.0%.

	$m_\xi = 0.5$	$m_\xi = 0.75$	$m_\xi = 1.0$	$m_\xi = 1.5$
$P_3 \cdot P_4 = 0.12$	1.5%	1.9%	2.3%	3.2%
$P_3 \cdot P_4 = 0.30$	2.3%	2.6%	3.0%	3.6%
$P_3 \cdot P_4 = 0.50$	3.2%	3.4%	3.7%	4.1%
$P_3 \cdot P_4 = 0.64$	3.8%	4.0%	4.2%	4.5%

The OTT-EA Pillar III aggregate spans 1.5–4.5% across the full joint sensitivity range, with the same architectural interpretation as the Pillar II grid. The defensible central interval at intermediate ξ -multiplier values is approximately [2.6%, 3.3%].

A separate sensitivity examines an alternative calibration in which the OTT channel base rates exceed the T-EA rates (doubling p_{zeroday} and p_{supply} from 1.5% to 3.0% each, on the argument that platform codebase and supply-chain complexity exceed those of T-EA infrastructure). This gives a Pillar III channel-aggregate projection of approximately 4.7% at the central segregation calibration, narrowing the gap to T-EA. This calibration is presented as a sensitivity rather than the headline because the empirical evidence on whether platform zero-day and supply-chain rates exceed those of T-EA infrastructure is mixed, and because the channel-minimum heuristic argument of Pillar III is most defensible when channel rates are taken at minimum-viable values applicable across architectural classes.

S12 Detailed EVPPI Variance Decomposition

This section reports the detailed parameter contributions to the EVPPI-style variance decomposition summarised in the main paper. The decomposition is taken over the parameters the canonical Monte Carlo engine treats as uncertain, drawn from the canonical priors: the three log-normal modifiers (δ_{EA} , δ_{target} , δ_{concen}) for both architectures, together with the cross-cutting coupling ratio γ_X/γ for OTT-EA. Quantities held fixed in the canonical model (γ , $P_3 \cdot P_4$, σ_λ , and the per-channel ξ/ρ arrays) contribute no output variance and are not decomposed. The first-order reducible totals are $\sim 61\%$ for T-EA (three modifiers) and $\sim 49\%$ for OTT-EA (three modifiers plus γ_X/γ). The residual reflects parameter interactions and the model’s internal channel-noise stochasticity.

T-EA contributions to $\text{Var}(Q_{10}^{\text{T}})$. System targeting intensity ($\delta_{\text{target}}^{\text{T}}$, 25.0%), EA-specific attack-surface modifier ($\delta_{\text{EA}}^{\text{T}}$, 18.7%), and concentration ($\delta_{\text{concen}}^{\text{T}}$, 17.7%). The three contributors

are comparable in magnitude, reflecting a relatively flat decomposition where no single parameter dominates. The residual ($\sim 39\%$) absorbs parameter interactions and the model’s internal stochasticity.

OTT-EA contributions to $\text{Var}(Q_{10}^{\text{OTT}})$. EA-specific attack-surface modifier ($\delta_{\text{EA}}^{\text{OTT}}$, 14.8%), concentration ($\delta_{\text{concen}}^{\text{OTT}}$, 13.9%), system targeting intensity ($\delta_{\text{target}}^{\text{OTT}}$, 12.0%), and the cross-cutting coupling ratio (γ_X/γ , 8.6%). The three modifiers are again comparable in magnitude; the OTT-EA-specific γ_X/γ carries a smaller first-order index, in part because the structural constraint $\gamma_X/\gamma \geq 1$ enforced at the prior level leaves relatively little remaining uncertainty to resolve, so additional empirical pinning of γ_X/γ yields modest direct variance reduction. Its role in the architectural-divergence direction is carried principally by the constraint itself rather than by residual uncertainty about its value. The residual ($\sim 51\%$) is the single largest component, larger than for T-EA, reflecting the additional interaction structure introduced by cross-cutting coupling.

S13 Attack Graph Topology Sensitivity

Table S9 reports the sensitivity of the Bayesian Layer output to the attack-graph topology, comparing the canonical six-node, eight-edge graph against the seven-node variant that inserts an HSM-firmware traversal node between the hardware-key-store entry and the key-extraction sink (the additional serial gate is modelled as a Beta-distributed firmware-pass probability attenuating the zero-day channel hazard). All other parameters are held at their central calibration. The figures are reproduced by `graph_topology_sensitivity.py` ($R = 4,000$ replicates per architecture and topology, seed 2024).

Table S9: Bayesian Layer outputs under the six-node and seven-node attack-graph topologies, for both architectures. The more granular seven-node topology lowers the median system hazard by 9–11%; the exceedance probability $\Pr(q_1 > 1\%)$ is nearly unchanged.

Quantity	T-EA		OTT-EA	
	6-node	7-node	6-node	7-node
Median q_1	4.1%	3.6%	2.7%	2.4%
95th percentile q_1	17.6%	15.2%	17.6%	16.6%
Median Q_{10}	36.2%	32.9%	31.6%	28.6%
95th percentile Q_{10}	84.1%	80.4%	93.2%	91.7%
$\Pr(q_1 > 1\%)$	0.989	0.981	0.901	0.868

The seven-node topology lowers the median annual hazard by approximately 11% for T-EA and 10% for OTT-EA, and the median 10-year cumulative hazard by approximately 9% for both; the exceedance probability at the 1% threshold is nearly unchanged. The direction is favourable, since the coarser six-node graph *overstates* risk relative to the more granular topology, and the qualitative dependence-inflation findings are unaffected.

S14 Pillar II Sensitivity Figures

The two-way sensitivity grid and one-way tornado for the Pillar II central projection, referenced from the main paper, are reproduced here.

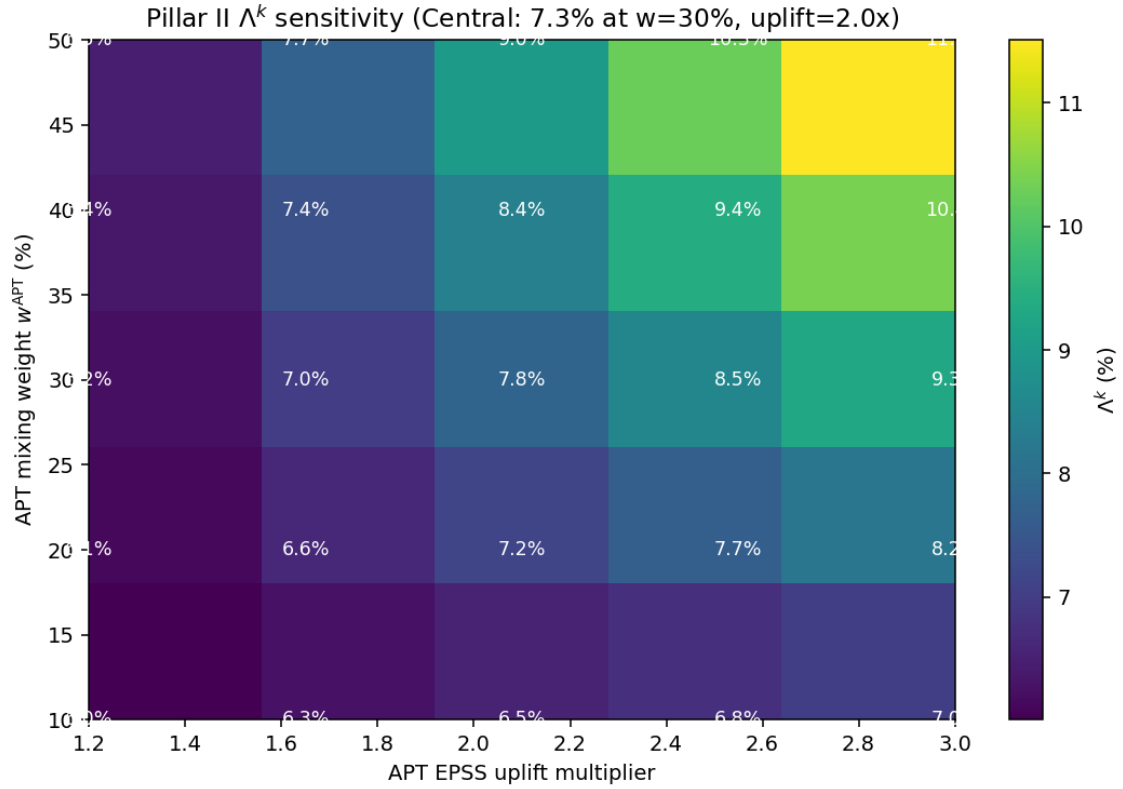


Figure S1: Two-way sensitivity grid for the Pillar II central projection, varying the APT mixing weight w_{APT} (x-axis, 10–50%) against the APT EPSS uplift multiplier (y-axis, 1.2 $\times$ –3.0 $\times$). Left panel: mean annual key-material exfiltration probability. Right panel: mean annual access-pathway compromise probability. The central parameterisation ($w_{\text{APT}} = 0.30$, uplift $\times 2.0$) yields the headline 7.3%/16.8% values. Across the full grid the key-material projection spans 5.5%–7.8%, with 5.5% serving as the Pillar II parametric floor under independence. Each cell: 200,000 Monte Carlo iterations; seed 2024.

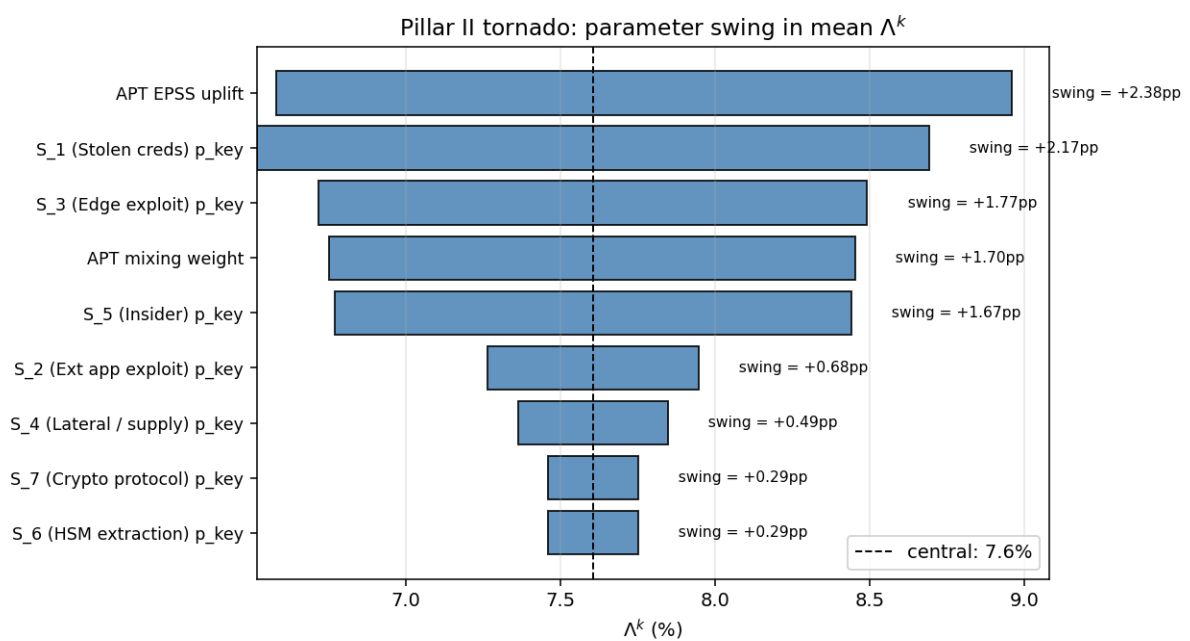


Figure S2: One-way sensitivity tornado for the Pillar II central projection of mean annual key-material exfiltration probability. Each parameter is varied across its prior 10th–90th percentile range holding all other parameters at central values. Vertical line marks the central estimate (7.3%). Dominant drivers are the conditional key-material probabilities for S_1 , S_3 , S_5 , and the global APT mixing weight; campaign parameters and specialist-technique attempt rates contribute less than 0.4 pp of range each.

S15 Non-stationary Cumulative Trajectory

Figure S3 extends the stationarity sensitivity from §S19.1 to a 25-year deployment horizon across three growth scenarios for both architectures.

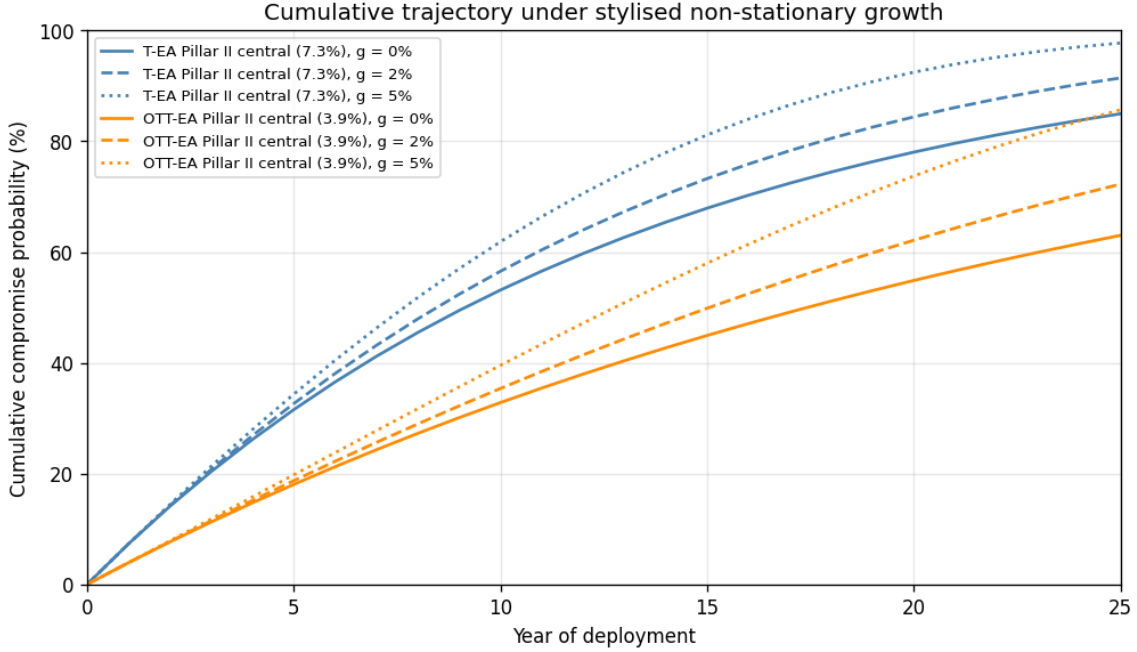


Figure S3: Cumulative compromise probability over a 25-year deployment horizon under stylised non-stationary growth in the annual rate. Solid lines: stationary baseline ($g = 0$). Dashed: 2% annual relative rate growth. Dotted: 5% growth. T-EA in blue (starting from the Pillar II central estimate 7.3%); OTT-EA in orange (starting from 3.9%). The gap to the stationary projection is modest in the first decade but grows substantially beyond year 15, illustrating why multi-decade EA-system commitments are more sensitive to assumed rate-growth dynamics than the headline 10-year projections suggest.

S16 Threshold-Scheme Quantitative Contrast

The quantitative analysis in this paper covers two architectural classes under single-operator deployment: T-EA (transmission-layer, with $\mathcal{K}$ and $\mathcal{D}$ co-located in carrier infrastructure) and OTT-EA (application-layer, with $\mathcal{K}$ and $\mathcal{D}$ architecturally segregated within a global platform). Both share the property that key material is held under unitary operator authority. A distributed threshold scheme, in which key material is split across N independent trustees with a t -of- N reconstruction requirement, alters the risk profile by removing the unitary-operator property itself. This subsection presents an illustrative quantitative contrast under the strong caveat that the per-node compromise rate is borrowed from the T-EA Pillar III channel-aggregate projection rather than measured empirically for threshold-scheme nodes specifically. Threshold-scheme nodes have a different attack surface from the single-operator T-EA cohort (narrower scope per node, distinct trust relationships, different operational tempos), and a quantitative risk analysis of threshold-based EA deployment would require an empirical anchor distinct from the three streams developed in this paper. The numbers below are presented as an order-of-magnitude illustration of the architectural-choice effect, not as a calibrated projection.

Threshold-based EA proposals have a substantial history. Micali’s *Fair Public-Key Cryptosystems* [45] introduced the verifiable secret-sharing approach to key escrow, splitting user private keys across n trustees with a k -of- n reconstruction threshold. Bellare and Goldwasser’s *Verifiable Partial Key Escrow* [46] and the contemporaneous Failsafe Key Escrow scheme of Leighton [91] extend this approach with security-game reductions. The Denning–Branstad taxonomy

[47] catalogues over a dozen historical key-escrow proposals, many of them based on threshold reconstruction. More recent deployment-grade systems, including Apple’s Cloud Key Vault and the iCloud Keychain HSM-quorum recovery scheme, use related multi-trustee reconstruction architectures. The threshold-scheme analysis below addresses a real and historically dominant class of EA proposals, not a hypothetical alternative.

The probability of key reconstruction in a given year is:

$$P(\text{reconstruct} \mid \text{independence}) = 1 - \sum_{k=0}^{t-1} \binom{N}{k} p^k (1-p)^{N-k}, \quad (\text{S1})$$

where p is the per-node annual compromise probability. A 5-of-9 scheme with $p = 0.05$ (close to the T-EA Pillar III channel-aggregate projection of 5.4%) gives $P(\text{reconstruct}) = 3.3 \times 10^{-5}$, approximately three orders of magnitude below the centralised channel-aggregate projection. Incorporating a common-mode failure fraction $\rho \in [0.05, 0.10]$ (shared HSM vendors, operating systems, coordinated nation-state campaigns):

$$P(\text{reconstruct}) = \rho p + (1 - \rho) \cdot P_{\text{indep}}(t, N, p). \quad (\text{S2})$$

At $\rho = 0.10$, $p = 0.05$, this gives $\approx 0.5\%$ annually.

Table S10 illustrates how the threshold-scheme reconstruction probability varies across a range of per-node rates, since the appropriate value of p for individual threshold scheme nodes is uncertain.

Table S10: Threshold-scheme reconstruction probability for a 5-of-9 architecture across a range of per-node annual compromise rates p and common-mode correlation ρ . The $p = 0.05$ row uses the Pillar III centralised-system channel-aggregate projection as an upper bound for the per-node rate; actual node rates may be lower (narrower attack surface per node) or require separate analysis.

	$\rho = 0$	$\rho = 0.05$	$\rho = 0.10$	$\rho = 0.20$
$p = 0.02$	0.000%	0.10%	0.20%	0.40%
$p = 0.05$	0.003%	0.25%	0.50%	1.00%
$p = 0.10$	0.089%	0.59%	1.08%	2.07%

A contour plot of reconstruction probability across the joint (p, ρ) range, with the Pillar III T-EA and OTT-EA channel-aggregate projections marked, is reproduced in Supplementary §S17.

Two caveats apply. First, the per-node rate p is taken from the Pillar III T-EA channel-aggregate projection, which is a conservative upper estimate for individual nodes of a threshold scheme, since each node holds only a share of the key material and presents a correspondingly smaller target. Precise threshold-scheme node rates require separate analysis. Second, the common-mode correction captures systematic failures. Cascading failures from shared cryptographic libraries or shared network infrastructure may not be fully captured by the scalar ρ model. The threshold scheme analysis demonstrates that the quantitative risk profile of this paper applies specifically to single-operator deployments (both the T-EA and OTT-EA classes analysed quantitatively) and can be substantially altered through architectural choice that removes the unitary-operator property. Precise figures for distributed architectures require independent analysis.

Operational feasibility considerations. The mathematical reduction in independent-compromise probability does not by itself establish that a threshold scheme is a deployable EA architecture. The threshold-key-escrow design space has been studied in cryptographic work since the mid-1990s [45, 46, 91] and the underlying secret-sharing machinery is in production use for account-recovery in commercial key-management systems. Four operational questions condition the engineering viability of a lawful-intercept deployment specifically: (i) warrant

throughput, since each reconstruction event requires participation from the threshold quorum of escrow holders and the coordination overhead scales with the number of authorisations per unit time, (ii) escrow-holder selection, since the security property requires that the $N - t + 1$ non-quorum holders are non-collusive in expectation, which constrains selection to entities with non-overlapping institutional incentives and oversight regimes, (iii) cross-jurisdictional handling, since multi-jurisdiction quorum requirements interact with mutual legal assistance and data-localisation regimes in ways that may not match the operational tempo of lawful-intercept work, and (iv) revocation and rotation cost, since periodic re-sharing of secrets to retire compromised or departing escrow holders multiplies the per-period operational burden. The cryptographic mechanisms exist; what is absent in the public literature is a worked assessment of these four operational questions in the lawful-intercept context. The risk reduction is unambiguous. The operational cost of obtaining it is the empirical question that follow-on engineering work would need to resolve.

S17 Threshold-Scheme Reconstruction Contour

Figure S4 reproduces the threshold-scheme reconstruction probability surface referenced in §12.7 of the main paper. The contour visualisation complements the tabulated values in Table S10 of the main paper.

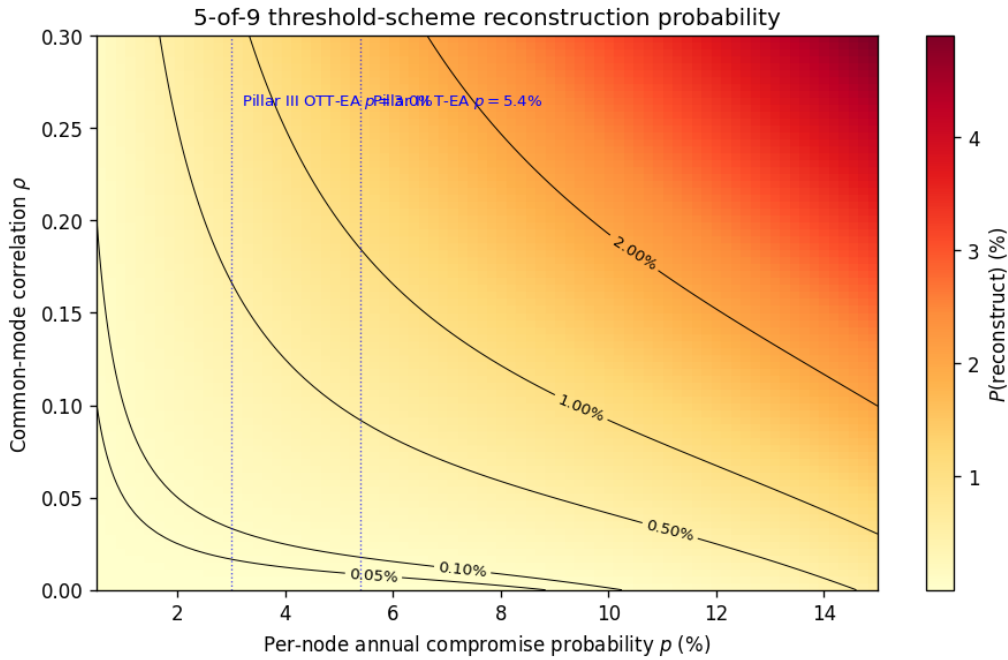


Figure S4: Reconstruction probability for a 5-of-9 distributed threshold scheme as a function of the per-node annual compromise rate p (horizontal axis) and the common-mode correlation ρ (vertical axis). Vertical dotted lines mark the Pillar III T-EA and OTT-EA channel-aggregate projections ($p \approx 5.4\%$ and $p \approx 3.0\%$ respectively) as plausible upper-bound per-node rates. Contour lines at 0.05%, 0.10%, 0.50%, 1.00%, and 2.00% reconstruction probability. The flat lower-left region illustrates the order-of-magnitude protection that threshold schemes provide against independent compromise. The steep gradient towards the upper-right shows the sensitivity to common-mode failure even at small ρ .

S18 Hybrid Client-Side Scanning Architectures

Hybrid client-side scanning (CSS) architectures, in which detection or content-matching is performed on user devices using operator-distributed key material, are treated qualitatively

in this paper rather than quantitatively. The reasons for the qualitative treatment, and the structural risk-profile observations that follow from it, are as follows.

Why CSS is not quantified in this approach. The quantitative analysis of T-EA and OTT-EA depends on architecturally appropriate empirical anchors (Stream A and Stream C respectively) that have been calibrated against documented incident bases. CSS architectures combine operator-side key custody (similar to OTT-EA) with endpoint-distributed detection key material whose attack surface is governed by mobile-platform security properties [16, 44]. The Pillar I empirical anchors do not contain incidents architecturally matched to the endpoint-distribution component: the Stream C platform incidents involve operator-side compromise rather than endpoint compromise of distributed keys. Quantitative analysis of CSS would require an additional empirical anchor for endpoint-key compromise rates that is outside the calibrated set of this paper.

Structural risk observations applicable to CSS. Several findings of this paper apply to CSS by structural argument:

1. The stochastic dominance result (Proposition 1 of the main paper) extends to CSS: any CSS deployment necessarily increases attack surface relative to the non-CSS counterfactual, attracts elevated targeting (the operator-distributed detection keys are themselves a high-value adversarial target), and concentrates risk at the operator-side detection-list custody component. The $\delta^{\text{CSS}} \geq 1$ constraint applies to each modifier on structural grounds.
2. The cross-cutting coupling argument (§8.5 of the main paper) applies to CSS in modified form. CSS architectures introduce a new cross-cutting infrastructure, the mobile platform itself, which is shared between the detection key custody and the endpoint scanning function. A campaign compromising the platform vendor’s signing infrastructure (Storm-0558-class) potentially compromises all CSS detection logic on devices simultaneously. The cross-cutting fraction for CSS architectures is therefore plausibly larger than for OTT-EA, further compressing any segregation gain.
3. The endpoint distribution introduces new compromise modes not present in T-EA or OTT-EA: device-level malware affecting detection logic, platform-level update infrastructure compromise, and user-level evasion or detection-trigger abuse. These modes are documented qualitatively in the cryptographic literature [44] but are not parameterised in our scenario set.
4. The architecture-conditional Bayesian framework’s tail finding applies a fortiori to CSS: under correlated-campaign conditions, the larger cross-cutting attack surface produces larger tail inflation than for OTT-EA. The CSS Bayesian distribution, were it constructed, would plausibly exhibit a heavier upper tail than either T-EA or OTT-EA.

Policy implication. The qualitative treatment of CSS is not neutral on its risk profile relative to T-EA and OTT-EA. Each of the four observations above is unfavourable to CSS, and there are no corresponding architectural arguments running in the opposite direction. A precautionary policy posture is to treat CSS as carrying *at least* the OTT-EA risk profile, with material additional risk from the endpoint-distribution attack surface. Quantitative analysis of CSS to match the rigour applied to T-EA and OTT-EA in this paper is identified as a research priority.

S19 Temporal Robustness, Inclusion Sensitivity, and Operator Heterogeneity

S19.1 Temporal and Inclusion Robustness

Stationarity. The cumulative calculations assume a stationary annual compromise rate over the deployment horizon. Three structural trends suggest the rate is more likely to increase than decrease: adversary capability growth, defensive posture degradation over multi-decade infrastructure lifetimes, and attack-surface expansion as EA systems become institutionally identified targets. A stylised non-stationary model with 2% relative annual rate growth raises the 10-year cumulative from 53% to 56% starting from the 7.3% Pillar II projection: a modest but directionally consistent adjustment. The full 25-year trajectory across three growth scenarios

($g = 0, 2\%, 5\%$) for both architectures is reported in §S15. Conversely, technical improvements (mandatory FIPS 140-3 Level 4 HSM standards, air-gapped key ceremony requirements, or improved detection capabilities) could reduce the rate over time. The framework does not foreclose this possibility.

Inclusion-criterion sensitivity for Stream A. The tier-stratified rates (Table 5 and §5.1 of the main paper) characterise the inclusion-criterion sensitivity. The Tier 1 cohort (direct T-EA architectural analogues, $k = 3$) at $10\times$ premium projects to 4.5%, still inside the low single-digit annual range produced by the framework. The qualitative finding (T-EA compromise risk in the low single-digit percentage range) is robust to inclusion criterion across all three tiers.

Salt Typhoon role. A separate concern is the inclusion of Salt Typhoon, which both motivates the paper and enters the parameter calibration. The $k = 5$ result with Salt Typhoon removed ($\hat{P} = 31.9\%$, 95% CI [11.7%, 59.2%]) is materially consistent with $k = 6$, so the motivational use does not inflate the headline estimate.

S19.2 Operator Heterogeneity and Regulatory Baseline

Stream C operator cohort and regulatory counterfactual. The Stream C platform-incident cohort (§5.3 of the main paper) comprises operators (Microsoft, Okta, LastPass, Twilio, and others) operating under commercial and industry-framework standards (SOC 2, ISO 27001) rather than any EA-style regulatory mandate. A defender of OTT-EA would argue that this systematically biases the Stream C base rate upward: under an EA-mandate counterfactual, regulator-defined minimum standards (mandatory hardware-backed key custody, formal audit trails, certified incident response) would force defensive postures that several Stream C incidents specifically reflect the absence of. Stream B (Certificate Authorities) is the closest empirical analogue to a “regulated EA operator”: CAs operate under formal CCADB governance with mandatory audit, transparency-log, and incident-disclosure obligations comparable to what an EA mandate would impose. The Stream B per-system rate (0.45%/yr) is approximately half the Stream C rate (0.95%/yr), and this ratio is the best available empirical upper bound on the defensive uplift attainable through CA-equivalent regulation. A defender accepting this ratio as evidence could legitimately discount the Stream C base by a factor of approximately two, shifting the OTT-EA central projection from $\sim 3.9\%$ to $\sim 2.0\%$. The discounted figure remains material and above the channel-minimum heuristic, but sits at the lower end of the defensible range. The Stream C cohort is therefore best read as anchoring the *unregulated* platform base rate. The OTT-EA-mandated case lies between this rate and the Stream B regulated-operator rate, with the empirical evidence insufficient to pin its precise location.

Weakest-operator problem. EA mandates are typically drafted to apply across all qualifying operators within a jurisdiction. The systemic risk profile is determined by the *distribution* of security capabilities across the operator population, not by the performance of the best-resourced operator. The model’s analysis corresponds to a well-resourced operator matching best-in-class historical performance. A mandate that includes less well-resourced operators will face a higher systemic risk profile than the framework’s central projections suggest.

S20 Proof of the Stochastic Dominance Proposition

Proof of Proposition 1 of the main paper. By definition the no-EA counterfactual of class A is the same model on the same attack graph with the three modifiers fixed at unity, so every edge (i, j) carries the baseline hazard λ_{ij}^A . Assumption (ii) gives $\delta_{EA}^A \delta_{target}^A \delta_{concen}^A \geq 1$, so under the EA configuration the modified hazard of Equation (24) of the main paper satisfies $\tilde{\lambda}_{ij}^A \geq \lambda_{ij}^A$ on

every edge. Assumption (i) ensures the EA graph indeed carries the EA-specific edges on which this uplift acts, but the inequality is driven by assumption (ii) alone. Because the per-period compromise probability $1 - e^{-\Lambda}$ is increasing in the total hazard Λ , it follows that $q_k^{\text{EA},A} \geq q_k^{\text{noEA},A}$ for each year k . For T-EA, this directly gives $Q_T^{\text{EA},T} \geq Q_T^{\text{noEA},T}$ for all T . For OTT-EA, the operational-compromise probability of Equation (29) of the main paper is monotonic in each component, so the same conclusion holds: $Q_T^{\text{EA},\text{OTT}} \geq Q_T^{\text{noEA},\text{OTT}}$ for all T . Since the inequalities hold for every parameter realisation, they hold distributionally. $\square$

S21 Full EA-Modifier Prior Specifications

This section gives the full prior specifications for the three EA-system modifiers (δ_{EA} , δ_{target} , δ_{concen}) summarised in §8.3 of the main paper.

Prior families. Each modifier is assigned a shifted log-normal prior enforcing the structural constraint ≥ 1 by construction, parameterised in the same way as the cross-cutting coupling ratio in the main paper, by its prior median m_k^A and log-space spread σ_k^A :

$$\delta_k^A = 1 + \text{LogNormal}(\log(m_k^A - 1), (\sigma_k^A)^2), \quad k \in \{\text{EA}, \text{target}, \text{concen}\}, \quad (\text{S3})$$

so that the prior median of δ_k^A is m_k^A and the prior places probability one on $\delta_k^A > 1$.

T-EA modifier priors. δ_{EA}^T : $m = 1.35$, $\sigma = 0.50$ (90% credible interval [1.15, 1.80]). δ_{target}^T : $m = 2.34$, $\sigma = 0.55$ (90% CI [1.54, 4.31]). δ_{concen}^T : $m = 1.49$, $\sigma = 0.45$ (90% CI [1.23, 2.03]). Calibration: δ_{target} anchored on Salt Typhoon (CALEA infrastructure as targeted asset) and the Athens affair (lawful-intercept infrastructure compromise); δ_{concen} anchored on per-carrier user-population scale (typically 10^7 – 10^8 subscribers per major regulated operator).

OTT-EA modifier priors. $\delta_{\text{EA}}^{\text{OTT}}$: $m = 1.35$, $\sigma = 0.50$ (equivalent to T-EA; both require additional codebase and interfaces beyond the non-EA baseline). $\delta_{\text{target}}^{\text{OTT}}$: $m = 3.00$, $\sigma = 0.55$ (90% CI [1.81, 5.94]); the prior median is shifted upward relative to T-EA by ≈ 0.25 natural-log units ($\log 3.00 - \log 2.34$), reflecting larger user populations and consequent greater intelligence value, anchored on Storm-0558 and Microsoft Midnight Blizzard. $\delta_{\text{concen}}^{\text{OTT}}$: $m = 3.32$, $\sigma = 0.50$ (90% CI [2.02, 6.28]); the prior median is shifted upward by 0.80 natural-log units relative to T-EA, reflecting per-platform user-population scale (10^8 – 10^9 users per major operator vs 10^7 – 10^8 for T-EA).

Domain mismatch hyperprior. The transport-uncertainty variance is $\tau_\phi = 0.50$ (matching the modifier σ values), producing transport-coefficient draws $\phi_{ij,r}^A \sim \mathcal{N}(0, 0.25)$ that propagate analogical-mapping uncertainty through to the edge hazard rates.

Structural constraint. The constraint $\delta_k \geq 1$ for all three modifiers is structural rather than empirical: it follows from the definitions of attack-surface increase, targeting elevation, and concentration risk relative to the no-EA counterfactual within the same architectural class. This constraint is the basis for Proposition 1 and is invariant under prior reparameterisations within the lognormal family.

S22 Cross-Cutting Prior Calibration: Derivation

This section provides the full derivation of the cross-cutting amplification prior (28) summarised in §8.5 of the main paper.

Empirical anchor from Stream C. The Stream C cohort records, for each of the fourteen documented incidents, a classification $X_i \in \{Y, P, N\}$ indicating whether the attack path traversed cross-cutting infrastructure shared between the key-management and data-storage subsystems ($X_i = Y$) or remained subgraph-localised. Seven of fourteen are classified $X = Y$, giving an empirical cross-cutting fraction $\hat{p}_X = 7/14 = 0.50$. Under the attack-graph specification of §8.5 of the main paper, and a campaign-prior central tendency of unit intensity, the value of the prior median m for γ_X/γ that reproduces $\Pr(X = Y) \approx \hat{p}_X$ at the prior median is $m = 2$. The mapping is constructive (numerically calibrated to the fixed-campaign-intensity midpoint) rather than analytic: $m = 2$ is an empirically anchored choice for the cross-cutting-amplification prior median, not a closed-form derivation.

σ choice. The value $\sigma = 0.40$ is a calibration choice rather than an empirically measured quantity. It is adopted for two specific reasons: (i) it matches the prior width used in the variance-decomposition and tornado analyses (§9.9.1 of the main paper), so the same prior on γ_X/γ runs through every part of the framework that requires one, avoiding the appearance of parameter-tuning between analyses; (ii) the qualitative implications of the OTT-EA tail finding are robust across a wider range $\sigma \in \{0.25, 0.40, 0.50, 0.60, 0.75\}$ reported in Table 11 of the main paper.

Resulting prior characteristics. At $(m, \sigma) = (2, 0.40)$, the prior on γ_X/γ has: median = 2.00; mean ≈ 2.08 ; 5th percentile ≈ 1.52 ; 95th percentile ≈ 2.93 ; 99th percentile ≈ 3.54 . A defender preferring a tighter prior ($\sigma \rightarrow 0.25$) recovers OTT-EA tail magnitudes close to those that would obtain at a fixed $\gamma_X/\gamma = 2$; a defender preferring a wider prior ($\sigma \rightarrow 0.60$) obtains stronger conclusions, principally through the upper-tail mass on γ_X/γ exceeding 3. The framework does not require either alternative to be ruled out.

Tail-uplift mechanism under prior integration. Treating γ_X/γ as sampled rather than fixed produces a heavier prior-integrated upper tail than would obtain at the prior median taken in isolation. This follows from the convexity of the exponential amplification $e^{\gamma_X Z}$ in γ_X : by Jensen’s inequality, the expected amplification under a prior with positive variance exceeds the amplification at the prior mean. High realisations of γ_X/γ (in the right tail of the prior) therefore dominate the upper tail of the output distribution, and this contribution is invisible to any fixed-point evaluation. The mechanism is the principal source of the OTT-EA tail-divergence finding under integrated prior uncertainty.

S23 Monte Carlo Stability Diagnostics

This section gives the full multi-stream stability diagnostic summarised in §8 of the main paper.

Stream setup. Four independent IID streams of $R = 2,000$ replicates each (seeds 2024, 3024, 4024, 5024) were run for each architectural class, as a stability diagnostic complementing the primary $R = 8,000$ (seed 2024) run from which all headline results derive. The implementation is in `bayesian_mc_canonical.py`. The multi-stream diagnostic driver is in `run_all.py`.

Per-stream medians. T-EA per-stream medians for the annual compromise probability q_1^T were 3.98%, 4.01%, 4.01%, 4.06% (max–min = 0.08 pp). OTT-EA per-stream medians for q_1^{OTT} were 2.63%, 2.68%, 2.67%, 2.70% (max–min = 0.07 pp). T-EA per-stream medians for the ten-year cumulative probability Q_{10}^T ranged from 35.95% to 36.51% (max–min = 0.56 pp); OTT-EA Q_{10}^{OTT} ranged from 31.91% to 32.02% (max–min = 0.11 pp), consistent with the headline full-dependence medians of 36.6% and 31.9% from the primary $R = 8,000$ run.

Convergence diagnostic. The Gelman–Rubin $\hat{R}$ statistic [28] computed across the four streams gave $\hat{R} < 1.01$ for all sampled scalar parameters in both architectural configurations. With IID draws these values are trivially close to unity and confirm only that the Monte Carlo is implemented as intended. Effective sample sizes exceeded 7,700 for q_1 and Q_{10} in both configurations across the pooled 8,000 replicates, substantially above the 1,500 rule of thumb for stable quantile estimation.

S24 GPD Goodness-of-Fit Tests

This section reports formal goodness-of-fit tests for the generalised Pareto distribution fits to the upper tail of the year-1 compromise probability q_1 in each architectural class. Two test statistics are used: the Anderson–Darling statistic A^2 as defined for the GPD by Choulakian and Stephens [92], and the Kolmogorov–Smirnov statistic D . P-values are estimated by parametric bootstrap ($R = 2,000$, seed 2024) because the null distributions of A^2 and D depend on the unknown shape parameter ξ when computed from MLE-estimated parameters.

Threshold sensitivity. The asymptotic GPD result holds above a sufficiently high threshold u ; threshold selection involves a bias–variance tradeoff. We report results at the paper’s primary threshold (90th empirical percentile) and at a range of alternatives.

Table S11: T-EA GPD goodness-of-fit across threshold choices. The fitted shape ξ is stable across moderate thresholds (85% to 95%). Both Anderson–Darling and Kolmogorov–Smirnov tests fail to reject the GPD null at the paper’s primary threshold (90th percentile). Rejection at the 97% threshold reflects small-sample behaviour ($n = 240$).

Threshold	n_{exc}	$\hat{\xi}$	$\hat{\sigma}$	A^2	p_{AD}	D	p_{KS}
80%	1,600	0.325	0.049	0.63	0.13	0.022	0.06
85%	1,200	0.287	0.058	0.33	0.60	0.016	0.61
90%	800	0.271	0.066	0.50	0.28	0.028	0.13
92%	640	0.265	0.071	0.73	0.09	0.035	0.04
95%	400	0.179	0.092	0.56	0.21	0.048	0.03
97%	240	0.211	0.096	1.54	0.003	0.083	< 0.001

Table S12: OTT-EA GPD goodness-of-fit across threshold choices. The GPD null is rejected by Anderson–Darling at every tested threshold; the Kolmogorov–Smirnov test rejects from the 90% threshold upward (at 85% the KS p -value of 0.07 is marginal rather than a rejection at the conventional 5% level). The fitted shape parameter $\hat{\xi}$ is also unstable across thresholds, with a sign change at the 97% threshold reflecting saturation effects as the right boundary of q_1 (the upper limit at 1) becomes material. The asymptotic GPD regime is not adequately reached for the OTT-EA upper tail in the parameter regime considered.

Threshold	n_{exc}	$\hat{\xi}$	$\hat{\sigma}$	A^2	p_{AD}	D	p_{KS}
80%	1,600	0.602	0.053	1.02	0.02	0.018	0.21
85%	1,200	0.572	0.066	1.32	0.005	0.024	0.07
90%	800	0.518	0.089	2.26	<0.001	0.037	0.003
92%	640	0.507	0.101	3.69	< 0.001	0.049	< 0.001
95%	400	0.171	0.189	4.97	< 0.001	0.077	< 0.001
97%	240	−0.411	0.397	6.02	< 0.001	0.099	< 0.001

Interpretation. The T-EA GPD fit at the primary threshold (90%, $\xi = 0.271$) is statistically adequate by both Anderson–Darling ($p = 0.28$) and Kolmogorov–Smirnov ($p = 0.13$). The

parametric estimate of ξ for T-EA is stable across moderate thresholds, supporting the asymptotic regime interpretation.

The OTT-EA GPD fit is rejected by Anderson–Darling at every tested threshold and by Kolmogorov–Smirnov from the 90% threshold upward (the 85% KS p -value of 0.07 is marginal). The shape parameter is unstable across thresholds and flips sign at the 97% level as the upper boundary of q_1 (at 1) becomes material. The asymptotic GPD regime is therefore not adequately reached for the OTT-EA upper tail in the parameter regime considered. The most likely cause is structured non-GPD tail behaviour induced by the mixture of contributing OTT-EA scenarios combined with the correlated-campaign coupling on cross-cutting edges, which produces a tail that is not asymptotically Pareto in the form required.

Implications for the tail-divergence finding. The qualitative tail-divergence finding (that the OTT-EA upper tail is heavier than the T-EA upper tail under correlated-campaign conditions) survives this goodness-of-fit assessment because it does not depend on the validity of the GPD fit. The direct empirical percentile comparison (T-EA 95th percentile of 16.5% versus OTT-EA 95th percentile of 17.4%; T-EA 99th percentile of $\sim 24\%$ versus OTT-EA 99th percentile of $\sim 36\%$) is a distribution-free comparison whose interpretation does not require parametric tail modelling. The non-overlapping bootstrap confidence intervals for $\hat{\xi}$ between architectures should be interpreted as a tail-heaviness ordering rather than as a formal statistical inference about Pareto-tail-index difference, because the GPD model under which the bootstrap is computed is misspecified for OTT-EA.

Diagnosing the source of the OTT-EA GPD failure

Three additional diagnostic tests identify the mechanism by which the OTT-EA upper tail departs from the asymptotic GPD regime.

Z-coupling is the proximate cause. Comparing the GPD fit to the OTT-EA q_1 samples with and without the latent campaign variable $Z(t)$ active isolates the Z-coupling contribution. Without $Z(t)$ (independence configuration: OTT_q1_indep), the GPD fit at the 90th percentile is statistically adequate: Anderson–Darling $p_{AD} = 0.13$, Kolmogorov–Smirnov $p_{KS} = 0.15$, $\hat{\xi} = 0.315$. With $Z(t)$ active (OTT_q1_full), the fit is rejected as reported above. For T-EA the GPD fit is adequate in both configurations ($p_{AD} = 0.49$ without Z , 0.28 with), because $Z(t)$ couples uniformly to all T-EA edges and rescales the tail without changing its shape. For OTT-EA, $Z(t)$ preferentially activates cross-cutting edges via $\gamma_X/\gamma \geq 1$, generating a mixture between a subgraph-dominant low- Z regime and a cross-cutting-dominant high- Z regime that no single GPD can capture.

Alternative single-parametric forms also fail. Lognormal and Weibull fits to the OTT-EA exceedances above the 90th percentile are likewise rejected by Kolmogorov–Smirnov ($p < 0.001$ in both cases). The Hill estimator of the Pareto tail index α (parametric only in assuming asymptotic Pareto behaviour) likewise yields unstable values across thresholds ($\hat{\alpha}$ ranging from 1.97 at the 98th percentile to 1.32 at the 80th, corresponding to GPD-shape equivalents $\hat{\xi} = 1/\hat{\alpha}$ between 0.51 and 0.76), mirroring the GPD instability. The OTT-EA upper tail is not adequately described by any single parametric form in the regime of practical sample sizes considered.

A two-component mixture fits the OTT-EA tail. A finite mixture of two GPDs, fitted by maximum likelihood, produces a Kolmogorov–Smirnov statistic of $D = 0.026$ for the OTT-EA upper tail (compared with $D = 0.037$ for the single GPD), with mixing weight $p \approx 0.81$ on a moderate-shape component ($\hat{\xi}_1 \approx 0.10$, capturing the subgraph-dominant low- Z regime) and $1 - p \approx 0.19$ on a heavier bounded-support component (capturing the cross-cutting-dominant

high- Z regime where the upper boundary at $q_1 = 1$ becomes material). The two-component structure is consistent with the model’s mechanistic prediction: under correlated-campaign conditions, cross-cutting edges amplify disproportionately, producing a regime-mixture whose upper tail inherits two different asymptotic shapes. The mixture interpretation explains both the goodness-of-fit failure and the threshold instability of $\hat{\xi}$ reported above.

What this means in practice. The OTT-EA tail-divergence finding is best understood structurally rather than parametrically. The empirical upper-percentile comparison (OTT-EA exceeds T-EA at the 95th and 99th percentiles, distribution-free) and the structural constraint $\gamma_X/\gamma \geq 1$ together establish the ordering. The mixture diagnosis confirms the model’s mechanistic prediction. The parametric Pareto-index interpretation is withdrawn in favour of this structural-and-mechanistic framing. Reproducibility: the diagnostic tests above are produced by `gpd_goodness_of_fit.py` in the reproducibility archive.

References

- [1] Harold Abelson, Ross Anderson, Steven M. Bellovin, Josh Benaloh, Matt Blaze, Whitfield Diffie, John Gilmore, Peter G. Neumann, Ronald L. Rivest, Jeffrey I. Schiller, and Bruce Schneier. The risks of key recovery, key escrow, and trusted third-party encryption. Technical report, MIT Laboratory for Computer Science, 1997.
- [2] Harold Abelson, Ross Anderson, Steven M. Bellovin, Josh Benaloh, Matt Blaze, Whitfield Diffie, John Gilmore, Matthew Green, Susan Landau, Peter G. Neumann, Ronald L. Rivest, Jeffrey I. Schiller, Bruce Schneier, Michael A. Specter, and Daniel J. Weitzner. Keys under doormats: Mandating insecurity by requiring government access to all data and communications. *Journal of Cybersecurity*, 1(1):69–79, 2015. ISSN 2057-2085. doi: 10.1093/cybsec/tyv009.
- [3] Vincent A. W. J. Marchau, Warren E. Walker, Pieter J. T. M. Bloemen, and Steven W. Popper, editors. *Decision Making under Deep Uncertainty: From Theory to Practice*. Springer, 2019. ISBN 978-3-030-05252-2. doi: 10.1007/978-3-030-05252-2.
- [4] Robert J. Lempert, Steven W. Popper, and Steven C. Bankes. *Shaping the Next One Hundred Years: New Methods for Quantitative, Long-Term Policy Analysis*. RAND Corporation, 2003. ISBN 978-0-226-47321-5.
- [5] Sarah Krouse, Dustin Volz, Aruna Viswanatha, and Robert McMillan. U.S. wiretap systems targeted in china-linked hack. *The Wall Street Journal*, 2024. 5 October 2024; first major report confirming access to lawful-intercept infrastructure and wiretap target lists.
- [6] Joe Mullin and Cindy Cohn. Salt typhoon hack shows there’s no security backdoor that’s only for the “good guys”. <https://www.eff.org/deeplinks/2024/10/salt-typhoon-hack-shows-theres-no-security-backdoor-thats-only-good-guys>, October 2024.
- [7] Vassilis Prevelakis and Diomidis Spinellis. The Athens affair. <https://spectrum.ieee.org/the-athens-affair>, 2007.
- [8] Greg Miller. The intelligence coup of the century. Washington Post investigation, with ZDF and SRF, February 2020. Joint CIA/BND ownership of Crypto AG (1970–2018); manipulated cipher devices sold to >100 governments enabled decryption of foreign government communications.
- [9] Susan Landau. *Listening In: Cybersecurity in an Insecure Age*. Yale University Press, 2017.

- [10] OECD. Key concepts and current technical trends in cryptography for policy makers. OECD Digital Economy Papers 364, Organisation for Economic Co-operation and Development, Paris, 2024.
- [11] IAB and IESG. IETF policy on wiretapping. Request for Comments RFC 2804, RFC Editor, 2000. Internet Engineering Task Force policy declining to support wiretap capabilities in IETF protocols; foundational architectural-community statement on exceptional access.
- [12] Mark Nottingham. RFC 8890: The internet is for end users. <https://www.rfc-editor.org/info/rfc8890/>, 2020.
- [13] Ian Levy and Crispin Robinson. Principles for a more informed exceptional access debate. *Lawfare*, November 2018.
- [14] Sharon Bradford Franklin and Andi Wilson Thompson. Open letter to GCHQ on the threats posed by the ghost proposal. Coalition open letter, *Lawfare*, May 2019. Signed by 47 civil-society organisations, security researchers, and technology companies.
- [15] European Commission. Proposal for a regulation laying down rules to prevent and combat child sexual abuse. COM(2022) 209 final, 2022.
- [16] Anunay Kulshrestha and Jonathan Mayer. Identifying harmful media in end-to-end encrypted communication: Efficient private membership computation. In *Proceedings of the 30th USENIX Security Symposium*, pages 893–910, 2021.
- [17] Adam Young and Moti Yung. *Malicious Cryptography: Exposing Cryptovirology*. Wiley, 2004. ISBN 978-0-7645-4975-5.
- [18] Mihir Bellare and Phillip Rogaway. The exact security of digital signatures—How to sign with RSA and Rabin. In *Advances in Cryptology – EUROCRYPT 1996*, volume 1070 of *Lecture Notes in Computer Science*, pages 399–416. Springer, 1996. doi: 10.1007/3-540-68339-9_34.
- [19] Jack Freund and Jack Jones. *Measuring and Managing Information Risk: A FAIR Approach*. Butterworth-Heinemann, 2014. ISBN 978-0-12-420231-3.
- [20] Lawrence A. Gordon and Martin P. Loeb. The economics of information security investment. *ACM Transactions on Information and System Security*, 5(4):438–457, 2002. doi: 10.1145/581271.581274.
- [21] Nayot Poolsappasit, Rinku Dewri, and Indrajit Ray. Dynamic security risk management using Bayesian attack graphs. *IEEE Transactions on Dependable and Secure Computing*, 9(1):61–74, 2012. ISSN 1941-0018. doi: 10.1109/TDSC.2011.34.
- [22] Norman Fenton and Martin Neil. *Risk Assessment and Decision Analysis with Bayesian Networks*. CRC Press, 2nd edition, 2018. ISBN 978-1-4398-0910-5.
- [23] Xinming Ou, Wayne F. Boyer, and Miles A. McQueen. A scalable approach to attack graph generation. In *ACM CCS*, pages 336–345, Alexandria Virginia USA, 2006. ACM. ISBN 978-1-59593-518-2. doi: 10.1145/1180405.1180446.
- [24] Lingyu Wang, Anyi Liu, and Sushil Jajodia. Using attack graphs for correlating, hypothesizing, and predicting intrusion alerts. *Computer Communications*, 29(15):2917–2933, 2006. ISSN 0140-3664. doi: 10.1016/j.comcom.2006.04.001.
- [25] John Homer, Su Zhang, Xinming Ou, David Schmidt, Yanhui Du, S. Raj Rajagopalan, and Anoop Singhal. Aggregating vulnerability metrics in enterprise networks using attack graphs. *Journal of Computer Security*, 21(4):561–597, 2013. ISSN 0926-227X, 1875-8924. doi: 10.3233/JCS-130475.

- [26] Miles A. McQueen, Wayne F. Boyer, Mark A. Flynn, and George A. Beitel. Time-to-compromise model for cyber risk reduction estimation. In Dieter Gollmann, Fabio Massacci, and Artsiom Yautsiukhin, editors, *Quality of Protection: Security Measurements and Metrics*, volume 23 of *Advances in Information Security*, pages 49–64, Boston, MA, 2006. Springer US. ISBN 978-0-387-36584-8. doi: 10.1007/978-0-387-36584-8_5.
- [27] Jerald F. Lawless. *Statistical Models and Methods for Lifetime Data*. Wiley-Interscience, 2nd edition, 2003. ISBN 9780471372111.
- [28] Andrew Gelman, John B. Carlin, Hal S. Stern, David B. Dunson, Aki Vehtari, and Donald B. Rubin. *Bayesian Data Analysis*. CRC Press / Chapman & Hall, 3rd edition, 2013. ISBN 978-1-4398-4095-5.
- [29] Bradley Efron and Robert J. Tibshirani. *An Introduction to the Bootstrap*. Chapman & Hall, 1993. ISBN 978-0-412-04231-7.
- [30] James A. Hanley and Abby Lippman-Hand. If nothing goes wrong, is everything all right? interpreting zero numerators. *JAMA*, 249(13):1743–1745, 1983. ISSN 0098-7484. doi: 10.1001/jama.1983.03330370053031. PubMed PMID: 6827763.
- [31] Stuart A. Klugman, Harry H. Panjer, and Gordon E. Willmot. *Loss Models: From Data to Decisions*. Wiley, 4th edition, 2012. ISBN 978-1-118-31532-3.
- [32] Luca Allodi and Fabio Massacci. Comparing vulnerability severity and exploits using case-control studies. *ACM Transactions on Information and System Security*, 17(1):1–20, 2014. doi: 10.1145/2630069.
- [33] Jay Jacobs, Sasha Romanosky, Benjamin Edwards, Idris Adjerid, and Michael Roytman. Exploit prediction scoring system (EPSS). *Digital Threats: Research and Practice*, 2(3): 1–17, 2021. doi: 10.1145/3436242.
- [34] Jay Jacobs, Sasha Romanosky, Octavian Suciu, Benjamin Edwards, and Armin Sarabi. Enhancing vulnerability prioritization: Data-driven exploit predictions with community-driven insights. In *Proceedings of the 2023 IEEE European Symposium on Security and Privacy Workshops (EuroS&PW)*, pages 194–206, 2023. doi: 10.1109/EuroSPW59978.2023.00027.
- [35] Blake E. Strom, Andy Applebaum, Doug P. Miller, Kathryn C. Nickels, Adam G. Pennington, and Cody B. Thomas. MITRE ATT&CK: Design and philosophy. Technical Report MTR180076, MITRE Corporation, 2018.
- [36] MITRE Corporation. ATT&CK enterprise matrix, version 15. Technical report, MITRE Corporation, 2024. Version 15, 2024.
- [37] Verizon Business. 2024 data breach investigations report. Technical report, Verizon Business, 2024.
- [38] Verizon Business. 2025 data breach investigations report. Technical report, Verizon Business, 2025. 2025 edition.
- [39] Mandiant. M-Trends 2024: Special report. Technical report, Google Cloud / Mandiant, 2024.
- [40] CrowdStrike. 2024 global threat report. Technical report, CrowdStrike Inc., 2024.
- [41] CISA. PRC state-sponsored actors compromise and maintain persistent access to U.S. critical infrastructure. Technical Report AA24-038A, Cybersecurity and Infrastructure Security Agency, 2024.

- [42] Federal Bureau of Investigation and CISA. Joint statement from FBI and CISA on the People’s Republic of China (PRC) targeting of commercial telecommunications infrastructure. <https://www.cisa.gov/news-events/news/joint-statement-fbi-and-cisa-peoples-republic-china-prc-targeting-commercial-telecommunications>, 2024.
- [43] Apple Inc. Advanced data protection for iCloud. <https://support.apple.com/en-gb/guide/security/sec973254c5f/web>, 2024. Accessed 2026.
- [44] Harold Abelson, Ross Anderson, Steven M. Bellovin, Josh Benaloh, Matt Blaze, Jon Callas, Whitfield Diffie, Susan Landau, Peter G. Neumann, Ronald L. Rivest, Jeffrey I. Schiller, Bruce Schneier, Vanessa Teague, and Carmela Troncoso. Bugs in our Pockets: The risks of client-side scanning. *Journal of Cybersecurity*, 10(1):tyad020, 2024. ISSN 2057-2085. doi: 10.1093/cybsec/tyad020. Originally posted as preprint, 2021; published version, 2024.
- [45] Silvio Micali. Fair public-key cryptosystems. In Ernest F. Brickell, editor, *Advances in Cryptology — CRYPTO 1992*, volume 740 of *Lecture Notes in Computer Science*, pages 113–138, Berlin, Heidelberg, 1993. Springer. ISBN 978-3-540-48071-6. doi: 10.1007/3-540-48071-4_9.
- [46] Mihir Bellare and Shafi Goldwasser. Verifiable partial key escrow. In *Proceedings of the 4th ACM Conference on Computer and Communications Security (CCS ’97)*, ACM Conferences, pages 78–91. ACM, 1997. ISBN 978-0-89791-912-8. doi: 10.1145/266420.266439.
- [47] Dorothy E. Denning and Dennis K. Branstad. A taxonomy for key escrow encryption systems. *Communications of the ACM*, 39(3):34–40, 1996. ISSN 0001-0782, 1557-7317. doi: 10.1145/227234.227239.
- [48] Hans Hoogstraaten, Ronald Prins, Daniël Niggebrugge, Danny Heppener, Frank Groenewegen, et al. Black tulip: Report of the investigation into the DigiNotar certificate authority breach. Technical report, Fox-IT, 2012. Project PR-110202, Version 1.0, 13 August 2012.
- [49] Kaspersky Global Research and Analysis Team. TURKTRUST CA problems. Securelist, January 2013, 2013. Two intermediate CA certificates incorrectly issued as end-entity certificates; the resulting fraudulent *.google.com certificate was detected by Google Chrome’s public-key pinning on 24 December 2012.
- [50] Software Engineering Institute. Common sense guide to mitigating insider threats, seventh edition. Technical report, CERT National Insider Threat Center, Software Engineering Institute, Carnegie Mellon University, 2022.
- [51] Steve McConnell. *Code Complete*. Microsoft Press, 2nd edition, 2004. ISBN 978-0-7356-1967-8.
- [52] Leyla Bilge and Tudor Dumitras. Before we knew it: An empirical study of zero-day attacks in the real world. In *Proceedings of the ACM Conference on Computer and Communications Security (CCS)*, pages 833–844, 2012. doi: 10.1145/2382196.2382284.
- [53] Mozilla. CA incident dashboard. Mozilla Wiki, CA Certificate Program, 2024. Tracks publicly disclosed certificate-authority misissuance and compliance incidents reported through Mozilla Bugzilla. Accessed 2026-05-15.
- [54] Common CA Database. Common CA database (CCADB). Online registry maintained by The Linux Foundation; operated collaboratively by the Apple, Cisco, Google, Microsoft and Mozilla root programs, 2024. Population denominator for trusted root Certificate Authorities. Maintenance transferred from Mozilla to The Linux Foundation on 7 May 2024.

- [55] Omar H. Alhazmi, Yashwant K. Malaiya, and Indrajit Ray. Measuring, analyzing and predicting security vulnerabilities in software systems. *Computers & Security*, 26(3):219–228, 2007. ISSN 0167-4048. doi: 10.1016/j.cose.2006.10.002.
- [56] Omar H. Alhazmi and Yashwant K. Malaiya. Application of vulnerability discovery models to major operating systems. *IEEE Transactions on Reliability*, 57(1):14–22, 2008. ISSN 1558-1721. doi: 10.1109/TR.2008.916872.
- [57] European Telecommunications Standards Institute. ETSI TS 102 165-1: CYBER; methods and protocols; part 1: Method and proforma for threat, vulnerability, risk analysis (TVRA). Version 5.3.1, February 2025, 2025.
- [58] Emanuele Borgonovo. A new uncertainty importance measure. *Reliability Engineering & System Safety*, 92(6):771–784, 2007. ISSN 0951-8320. doi: 10.1016/j.ress.2006.04.015.
- [59] Committee on National Security Systems. Committee on national security systems (CNSS) policies and instructions. <https://www.cnss.gov/CNSS/issuances/Policies.cfm>, 2024. Defines governance and separation of U.S. National Security Systems cryptographic domains. Accessed 2026-05-15.
- [60] National Security Agency. Announcing the commercial National Security Algorithm Suite 2.0. NSA Cybersecurity Advisory, PP-22-1338, Ver. 1.0, 2022. Documents cryptographic requirements for classified and national security systems. September 2022. Accessed 2026-05-15.
- [61] National Security Agency. Quantum key distribution (QKD) and quantum cryptography (QC). NSA Cybersecurity guidance, 2020. Guidance on QKD/QC for securing National Security Systems, published October 2020. Accessed 2026-05-15.
- [62] National Cyber Security Centre. Advanced cryptography. <https://www.ncsc.gov.uk/paper/advanced-cryptography>, 2025. NCSC white paper on advanced cryptographic techniques. Accessed 2026-05-15.
- [63] European Union Agency for Network and Information Security. Algorithms, key size and parameters report – 2014, 2014. ENISA’s cryptographic-recommendations report; latest edition in this series. Accessed 2026-05-15.
- [64] Agence nationale de la sécurité des systèmes d’information. ANSSI cryptographic mechanisms recommendations. RGS v2.0, Annexe B1 (version 2.04)., 2020. French sovereign cryptographic authority publications. Accessed 2026-05-15.
- [65] Bundesamt für Sicherheit in der Informationstechnik. Cryptographic mechanisms: Recommendations and key lengths. Technical Guideline BSI TR-02102-1, Version 2026-01, 23 January 2026., 2026. German federal cryptographic governance and standards guidance. Accessed 2026-05-15.
- [66] NATO Communications and Information Agency. NATO information assurance product catalogue (NIAPC), 2024. Catalogue of evaluated information-assurance products for NATO nations and bodies. Accessed 2026-05-15.
- [67] United States Congress. Communications assistance for law enforcement act (CALEA). Public Law 103-414., 1994. Establishes lawful intercept capability requirements for telecommunications carriers. Accessed 2026-05-15.
- [68] European Telecommunications Standards Institute. Lawful interception (LI); internal network interfaces; part 1: X1. Technical Specification TS 103 221-1 V1.23.1, ETSI,

March 2026. De facto lawful-interception internal network interface specification, in use across European and global carrier networks. Multi-part series; Part 1 specifies the X1 administration interface.

- [69] European Telecommunications Standards Institute. Lawful interception (LI); internal network interfaces; part 2: X2/X3. ETSI TS 103 221-2 V1.5.2, October 2021, 2021. Defines standardized lawful interception architectures used across European and partner-state telecommunications systems. Standard family includes TS 103 221 (X1/X2/X3), TS 102 232 (handover interface) and related deliverables. Accessed 2026-05-15.
- [70] 3rd Generation Partnership Project. 3GPP lawful interception architecture and functions, 2024. Mobile-network lawful interception standards (TS 33.126/33.127/33.128) and associated cryptographic and control interfaces, covering 4G and 5G carrier infrastructure. Accessed 2026-05-15.
- [71] Arthur Coviello. Open letter to RSA customers. EMC Corporation, SEC Form 8-K Exhibit 99.1, March 2011, 2011.
- [72] Ellen Nakashima. Powerful NSA hacking tools have been revealed online. The Washington Post, 2016. 16 August 2016.
- [73] FireEye. Highly evasive attacker leverages SolarWinds supply chain to compromise multiple global victims with SUNBURST backdoor. Mandiant Threat Intelligence Blog, 2020.
- [74] WikiLeaks. Vault 7: CIA hacking tools revealed, 2017.
- [75] Jason Chaffetz, Mark Meadows, and Will Hurd. The OPM data breach: How the government jeopardized our national security for more than a generation. Majority staff report, U.S. House of Representatives, 2016. Majority staff report on the 2015 OPM data breach.
- [76] Karim Toubba. Security Incident December 2022 Update - LastPass - The LastPass Blog. <https://blog.lastpass.com/posts/notice-of-recent-security-incident>, 2022. Two-stage incident: Aug. 2022 source code/development environment intrusion; Nov. 2022 customer vault data exfiltration via developer endpoint compromise.
- [77] Twilio. Incident Report: Employee and Customer Account Compromise—August 4, 2022. Twilio security blog, August 2022. SMS phishing of employees compromised internal systems and 0Auth access to Authy MFA service; affected 209 customers.
- [78] Microsoft Security Response Center. Analysis of Storm-0558 techniques for unauthorized Email Access. Microsoft Threat Intelligence, July 2023. Acquired Microsoft account (MSA) consumer signing key used to forge Azure AD tokens, granting access to OWA and Outlook.com for 25 enterprise organisations including US State Department.
- [79] Codecov. Bash uploader Security update. Codecov security advisory, April 2021. Bash Uploader script tampering compromised credentials of Codecov customers; CISA Alert AA21-116A.
- [80] Bob Phan. Jumpcloud Incident Details. JumpCloud security advisory, July 2023. Sophisticated nation-state attack via spear-phishing of employee; threat actor injected malicious data into commands framework affecting fewer than 5 customers.
- [81] Microsoft Threat Intelligence Center. HAFNIUM targeting Exchange Servers with 0-day exploits (ProxyLogon), March 2021. Mass exploitation of CVE-2021-26855 et al. on on-premises Microsoft Exchange. CISA Emergency Directive 21-02.

- [82] Okta. Updated Okta Statement on LAPSUS\$. Okta security advisory, March 2022. Sub-processor compromise via support engineer workstation; 366 Okta customers potentially affected.
- [83] GoDaddy. Form 10-K Annual Report—Security Incident Disclosure. SEC filing 10-K, fiscal year 2022, February 2023. Multi-year intrusion campaign (2020–2022) affecting cPanel hosting environment; threat actor installed malware redirecting traffic.
- [84] David Bradbury. Tracking Unauthorized Access to Okta’s Support System. <https://sec.okta.com/articles/2023/10/tracking-unauthorized-access-oktas-support-system>, October 2023. Threat actor used stolen credentials to access support case management system; HAR files containing session tokens exfiltrated, enabling downstream attacks on customers including 1Password and Cloudflare.
- [85] CircleCI. Jan. 4, 2023 Security Incident Report. CircleCI engineering blog, January 2023. Malware on engineer’s laptop captured 2FA-backed SSO session token, granting access to production systems and customer secrets stored in CircleCI environment variables and contexts.
- [86] Progress Software. MOVEit Transfer Critical Vulnerability (CVE-2023-34362). Progress Software security advisory, June 2023. SQL injection zero-day in MOVEit Transfer exploited by CL0P ransomware group affecting >2,600 organisations and 90+ million individuals. CISA Alert #CISA-Alert-AA23-158A.
- [87] Microsoft Security Response Center. Midnight Blizzard: Guidance for Responders on Nation-State Attack. Microsoft Threat Intelligence, January 2024. Russian state actor APT29 used password spray on legacy test tenant lacking MFA, then OAuth application abuse to access corporate email of senior leadership and cybersecurity teams. SEC 8-K filing.
- [88] Slack Technologies. Slack Security Update. <https://slack.com/intl/en-gb/blog/news/slack-security-update>, December 2022. Stolen employee tokens used to access externally-hosted GitHub repositories; some Slack source code exfiltrated.
- [89] Mandiant. UNC5537 targets Snowflake Customer Instances for Data Theft and Extortion. <https://cloud.google.com/blog/topics/threat-intelligence/unc5537-snowflake-data-theft-extortion>, June 2024. Stolen credentials (largely from infostealer malware) used to access 165 Snowflake customer instances lacking MFA. Data exfiltration affected Ticketmaster, Santander, AT&T, and others.
- [90] AT&T. Form 8-K—Data Security Incident Disclosure. SEC filing 8-K, July 2024. Form 8-K filed 12 July 2024 under Item 1.05 (Material Cybersecurity Incident); disclosed incident in which call/text records of nearly all AT&T cellular customers were illegally downloaded from a third-party (Snowflake-hosted) cloud workspace between 14–25 April 2024.
- [91] Frank Thomson Leighton. Failsafe key escrow system. U.S. Patent 5,647,000, 1997. Filed 1995; issued 8 July 1997.
- [92] V. Choulakian and M. A. Stephens. Goodness-of-fit tests for the generalized Pareto distribution. *Technometrics*, 43(4):478–484, 2001. ISSN 0040-1706. doi: 10.1198/00401700152672573.